Katrina's Mystic Visitors Guide — Counsel Packet

Tier 2 — Post-NDA Disclosure Set

⚠ CONFIDENTIAL — DO NOT DISCLOSE WITHOUT EXECUTED NDA OR ENGAGEMENT LETTER WITH EXPRESS CONFIDENTIALITY PROVISIONS ⚠

This document is **Tier 2** of the counsel packet prepared for the 2026-04-20 engagement meeting. It is delivered **only after** execution of one of:

- The mutual NDA (template in Tier 1 §B2, or counsel's substitute), or
- An engagement letter that contains express confidentiality provisions covering technical and commercial information disclosed during the engagement.

Until one of the above is in place, this document is not to be distributed, forwarded, printed, or disclosed — including within the receiving law firm beyond the attorney(s) directly engaged with the matter.

What's in this packet

Chapter	Content	Why gated
T2-01	**IP Register** — 14 patentable innovations with novelty analysis and patent-claim-angle sketches	Patent-novelty preservation (35 U.S.C. § 102). Public disclosure starts the 12-month US bar clock and may eliminate foreign filing rights.
T2-02	**Governance and Compliance Framework**	Contains architectural and data-handling details that inform several patent claims; also contains commercial security posture.
T2-03	**Commercialization Strategy**	Tier architecture, market analysis, financial projections, competitor positioning. Competitively sensitive.
T2-04	**Design Review** — architectural decisions	Algorithm-level specificity that overlaps with the IP register.
T2-05	**Future-State Privacy Policy** — covers post-V1 functionality	Describes a cross-project data architecture that is itself a candidate for IP protection.

How to use this packet

1. **Read in order.** T2-01 (IP register) is the priority read — it names the candidate inventions and provides the novelty case for each. Chapters T2-02 through T2-04 are deeper reference and context.
2. **Do not file any patent application based on these documents** without a written instruction from the operator. The operator is not authorizing counsel to file; counsel is authorized to *advise on filing strategy* and to take directed action per an executed engagement letter.

3. **Priority items for counsel consideration:**
    - T2-01 §15 — "Legal Protection Roadmap" — 4 provisional patent filings recommended. Counsel confirmation of the filing priority ordering is the primary ask.
    - T2-02 §4 ("Legal & Regulatory Requirements") and §10 ("Required Legal Documents") — confirm the V1 posture is consistent with §10's list and flag anything missing.
    - T2-03 — review commercial strategy for regulatory exposure beyond what V1 declares.
4. **Handling instructions:**
    - Store digitally in a password-protected or firm-standard secure location.
    - Do not email in cleartext or upload to general file-sharing.
    - If printed, destroy hardcopies after the engagement ends (see NDA §8 — Return or Destruction).

Relationship to Tier 1

Tier 1 (delivered before this packet) covers:

- V1 product description (public-facing)
- Privacy Policy V1 (public-facing draft)
- Pricing and age gate
- Terms of Service stub (public-facing draft)
- Data Safety questionnaire (public-facing)
- Play Store release checklist
- Legal walkthrough (open-decisions menu, with patent strategy redacted — patent content is in T2-01 of this packet)
- Decision checklist
- Tier-2 holdback manifest (the index of this packet)
- Mutual NDA template (B2)

Tier 1 gives counsel the full operational picture. Tier 2 gives counsel the IP-and-strategy depth needed to execute on it.

Operator: Dean Maurice Ellis **Date:** April 2026 **Delivery:** On NDA execution at the 2026-04-20 counsel engagement meeting (or later, on request)

Continue to T2-01 IP Register →

LocationMapApp v1.5 — Intellectual Property Register

Author: Dean Maurice Ellis **Copyright:** (c) 2026 Dean Maurice Ellis. All rights reserved. **Date:** March 3, 2026 **Status:** Proprietary — not licensed for redistribution

---

1. Adaptive Radius Cap-Retry Algorithm

Key Files: `PlacesRepository.kt`, `server.js`

Description: A self-tuning search radius algorithm for POI discovery via the Overpass API. The system begins with a proxy-hinted radius and dynamically adjusts based on result density. When too many results are returned (API overload), the radius is halved and retried. When too few results are returned, the radius expands. A minimum radius floor (100m) prevents infinite shrinking, while adaptive 20km fuzzy matching ensures coverage in sparse areas.

Novelty: Existing geocoding APIs use fixed radii. This system creates a feedback loop where the search area self-calibrates to local POI density without prior knowledge of the area, avoiding both API overload and under-discovery.

Patent Claim Angle: A method for dynamically adjusting geospatial search radii based on real-time result density feedback, comprising cap-retry halving on overload, proxy-hinted initial radius estimation, and minimum radius floor constraints.

---

2. Probe-Calibrate-Spiral Scanner

Key Files: `MainActivity.kt`

Description: A multi-phase area scanner for systematic POI discovery. Phase 1 (Probe) sends a single query to estimate local POI density. Phase 2 (Calibrate) uses the probe results to compute optimal cell size for the area. Phase 3 (Spiral) executes a recursive 3x3 grid subdivision pattern, scanning outward in a spiral from the user's location with 30-second pacing to respect API rate limits. The scanner preserves state for pause/resume across app lifecycle events.

Novelty: Conventional area-scanning approaches use fixed grids. This system adapts grid density to local conditions before scanning begins, then uses spiral ordering to prioritize nearby areas while maintaining systematic coverage.

Patent Claim Angle: A method for area-adaptive geospatial scanning comprising density probing, grid calibration based on probe results, and spiral-ordered recursive subdivision with rate-limited execution and state preservation.

---

3. 10km Probe Expanding Spiral

Key Files: `MainActivity.kt`

Description: A large-scale discovery algorithm that uses an expanding spiral pattern of 10km-wide probe points for efficient low-density area exploration. The system estimates fill radius from initial probe results

to determine how far each discovery point's results extend, minimizing redundant queries in sparsely populated regions.

Novelty: Unlike uniform grid scanning, this approach uses wide probes specifically calibrated for low-density areas, with fill radius estimation to avoid redundant queries where POIs are sparse.

Patent Claim Angle: A method for large-scale geospatial discovery using expanding spiral probes with fill radius estimation for adaptive coverage of low-density regions.

---

4. Idle Auto-Populate with Density Guard

Key Files: `MainActivity.kt`

Description: An intelligent background population system that detects 10 minutes of GPS stationarity (user not moving) and automatically triggers the full Probe-Calibrate-Spiral scanner with extended 45-second delays. A density guard checks whether 100+ POIs already exist within 10km before starting, preventing redundant scanning of already-populated areas. Any UI interaction immediately resets the idle timer and halts scanning. Scanner state is preserved for resume after interruption.

Novelty: The combination of GPS stationarity detection, density-aware gate, and interruptible scanning with state preservation creates an autonomous discovery system that operates only when beneficial and never when the user is actively engaged.

Patent Claim Angle: A method for autonomous geospatial data population comprising GPS stationarity detection, local density evaluation as a pre-scan gate, interruptible execution with state preservation, and adaptive delay timing.

---

5. JTS R-Tree Geofence Engine

Key Files: `GeofenceEngine.kt`

Description: A high-performance on-device geofence evaluation engine using JTS Topology Suite's R-tree spatial index. The engine supports 5 live zone types (TFR, military, school, exclusion camera, DJI no-fly) and evaluates device position against 220,000+ polygon boundaries in real time. Zone entry/exit events trigger configurable alerts with zone-specific metadata.

Novelty: Mobile geofence systems typically use simple circle-based proximity checks with limited zone counts. This engine handles complex polygon geometries at scale using spatial indexing, enabling real-time evaluation against hundreds of thousands of zones on a mobile device.

Patent Claim Angle: A mobile geofence system using R-tree spatial indexing for real-time device position evaluation against large-scale polygon zone databases with configurable multi-type alert triggers.

---

6. Multi-Source Downloadable Geofence Databases

Key Files: `GeofenceDatabaseRepository.kt`, `cache-proxy/geofence-databases/build-military.js`, `build-excam.js`, `build-nces.js`, `build-dji-nofly.js`

Description: A system for building, distributing, and importing pre-compiled geofence databases from multiple authoritative sources. Four build scripts transform raw data from ArcGIS (military bases), government registries (schools/NCES), DJI no-fly zones, and exclusion camera databases into optimized SQLite format for on-device import. Users can download and install zone databases independently.

Novelty: Geofence databases are typically hardcoded or require server-side evaluation. This system enables

offline geofence evaluation by transforming diverse authoritative sources into a standardized downloadable format with on-device spatial indexing.

Patent Claim Angle: A method for creating distributable geofence databases from heterogeneous authoritative geospatial sources, comprising source-specific ETL pipelines, standardized SQLite output format, and on-device spatial index construction.

---

7. Overpass Fair-Queue with Rate Limiting

Key Files: `server.js`

Description: A serialized request queue for upstream Overpass API calls that ensures fair access across multiple clients. The system enforces a 10-second minimum gap between upstream requests, uses round-robin scheduling with a 5-request cap per client, and provides a centralized queuing point that prevents API abuse while maximizing throughput for all connected devices.

Novelty: Most Overpass API clients manage rate limiting independently, leading to conflicts when multiple devices share an API key. This centralized fair-queue with per-client caps and round-robin scheduling provides coordinated access control.

Patent Claim Angle: A proxy-based request queuing system for rate-limited APIs comprising serialized upstream dispatch, per-client request caps, round-robin fair scheduling, and configurable minimum inter-request delays.

---

8. Smart Fuzzy Search with Keyword Hints

Key Files: `server.js`

Description: A multi-strategy search system combining PostgreSQL pg_trgm trigram similarity matching (threshold >0.2) with ILIKE substring search and ~80 keyword-to-category mappings. The system uses composite scoring to rank results, provides category hints in search responses (e.g., "Fuel & Charging" for "gas station"), and implements progressive distance expansion (50km -> 100km -> 160km) until a threshold of 50 results is reached, with a 200-result cap.

Novelty: The combination of trigram fuzzy matching, keyword-to-category semantic mapping, composite scoring, progressive distance expansion, and result-count-driven search termination creates a search experience that handles both exact and fuzzy queries with intelligent scope management.

Patent Claim Angle: A geospatial search system combining trigram similarity matching, keyword-to-category semantic mappings, composite relevance scoring, and progressive distance expansion driven by result count thresholds.

---

9. Filter and Map Mode

Key Files: `MainActivity.kt`

Description: An exclusive map visualization mode triggered from Find dialog results. When activated, the system clears all non-POI layers (transit, aircraft, webcams, METAR, geofences, radar), stops background data refresh jobs, and displays only the filtered POI subset with force-labeled markers at any zoom level. The view centers on the result centroid at zoom 15. A status line indicator enables tap-to-exit, and the mode auto-exits when the Find dialog reopens. Radar state is saved and restored on exit.

Novelty: Map applications typically overlay search results on existing map content. This mode creates a

clean, dedicated view of search results by temporarily suspending all other map layers and background operations, providing focused visualization with full state restoration on exit.

Patent Claim Angle: A method for exclusive map visualization of filtered results comprising layer suspension, background job halting, forced marker labeling, centroid-centered display, and complete state restoration on mode exit.

---

10. Aircraft Auto-Follow with Rotation

Key Files: `MainActivity.kt`

Description: An automatic aircraft tracking system that follows individual aircraft using globally-tracked ICAO24 identifiers. The system maintains flight path trails, implements 3-strike tolerance for temporary signal loss (aircraft disappearing from ADS-B coverage), and supports 20-minute auto-rotation to cycle through tracked aircraft.

Novelty: Aircraft tracking apps typically require manual selection and lose track on signal gaps. This system provides autonomous follow with signal loss tolerance and automatic rotation through multiple tracked aircraft.

Patent Claim Angle: A method for autonomous aircraft tracking comprising persistent identifier tracking across data refresh cycles, configurable signal loss tolerance, flight path trail accumulation, and timed rotation across multiple tracked targets.

---

11. Priority-Based Status Line System

Key Files: `StatusLineManager.kt`

Description: A UI status communication system with 8 priority levels that manages competing status messages from multiple subsystems (GPS, weather, scanning, errors, social, filter mode). Higher-priority messages preempt lower-priority ones, with automatic message expiry and restoration of the next-highest-priority pending message. The status line also supports tap-to-action callbacks for interactive status items.

Novelty: Mobile apps typically use simple status indicators or toast messages. This priority-queue-based system provides structured, preemptive status management across multiple concurrent subsystems with interactive callbacks.

Patent Claim Angle: A priority-based status line management system for mobile applications comprising multi-level message preemption, automatic expiry with next-priority restoration, and tap-to-action callback registration.

---

12. Silent Fill

Key Files: `MainActivity.kt`

Description: A lightweight, non-intrusive POI population method that executes a single Overpass search on specific triggers: app startup, state restoration, and long-press events. The fill operates with a 3-4 second delay to avoid interfering with user interactions, populating nearby POIs without the overhead of a full scanner cycle.

Novelty: Unlike full scanning algorithms, Silent Fill provides just-enough POI coverage for immediate use with minimal latency and zero user interaction, complementing the heavier scanner algorithms for ongoing discovery.

Patent Claim Angle: A method for lightweight geospatial data population triggered by application lifecycle events, comprising delayed single-query execution timed to avoid user interaction interference.

---

13. Device-Bonded Authentication

Key Files: `AuthRepository.kt`, `server.js`

Description: An authentication system that bonds user accounts to device identity without traditional login/logout flows. Registration generates a device-specific credential using Argon2id password hashing, with JWT access tokens and 365-day refresh tokens for persistent sessions. The system eliminates password management overhead while maintaining cryptographic security through device binding.

Novelty: Most mobile auth systems use email/password or OAuth flows. Device bonding eliminates the login/logout UX entirely while maintaining security through hardware-bound credentials and industry-standard token management.

Patent Claim Angle: A device-bonded authentication method comprising hardware identity-based registration without explicit login flows, Argon2id credential hashing, and long-lived refresh token management for persistent mobile sessions.

---

14. Bbox Snapping for Cache Optimization

Key Files: `server.js`

Description: A coordinate rounding system that snaps bounding box queries to fixed grid intervals (METAR/webcams at 0.01 degrees, aircraft at 0.1 degrees) to maximize cache hit rates. By rounding viewport coordinates to predictable values, multiple slightly-different viewport positions map to the same cache key, dramatically reducing upstream API calls.

Novelty: Geospatial API proxies typically cache exact bounding box queries, resulting in poor cache hit rates as users pan the map. Bbox snapping trades minimal precision for dramatically improved cache efficiency by quantizing the coordinate space.

Patent Claim Angle: A method for improving geospatial API cache efficiency by quantizing bounding box coordinates to configurable grid intervals, comprising per-data-source snap granularity and deterministic cache key generation from rounded coordinates.

Legal Protection Roadmap

Immediate Actions (This Week)

1. **Copyright headers** — Added to all 131+ source files (Kotlin, XML, JavaScript, Shell, SQL)
2. **Repository visibility** — Ensure GitHub repository is set to private (`gh repo edit --visibility private`)
3. **License posture** — No open-source license file; "All Rights Reserved" via copyright headers

Week 1

1. **US Copyright Registration** — File with US Copyright Office
    - Form: TX (literary work — software source code)

- Fee: $65 (single author, single work)
- Submit: representative source code deposit (first 25 + last 25 pages)
- Protection: statutory damages + attorney fees eligibility upon registration

Month 1

1. **Provisional Patent Applications** — File with USPTO (micro-entity rate: $320 each)
    - **Priority 1:** Adaptive Radius Cap-Retry Algorithm (#1)
    - **Priority 2:** Probe-Calibrate-Spiral Scanner (#2)
    - **Priority 3:** Overpass Fair-Queue (#7)
    - **Priority 4:** JTS R-Tree Geofence Engine (#5)
    - Each provisional provides 12 months to file a full utility patent

Month 2-3

1. **IP Attorney Consultation** — Engage patent attorney for:
    - Review provisional applications
    - Advise on utility patent conversion strategy
    - Evaluate remaining 10 innovations for patentability
    - Trade secret vs. patent strategy for server-side algorithms

Ongoing

1. **Trade Secret Protection** — Server-side algorithms (proxy code, queue logic, fuzzy search, bbox snapping) may be better protected as trade secrets than patents since they never ship to users
    - Document confidential parameters separately from public code
    - Restrict proxy source access to authorized personnel only
    - Maintain access logs for all code repositories
2. **NDA Requirement** — Require signed NDA before sharing any source code with collaborators, contractors, or potential investors
3. **Trademark** — Consider USPTO trademark registration for "LocationMapApp"
    - Filing fee: $250-350 (TEAS Plus / TEAS Standard)
    - Class: IC 009 (mobile application software)

Timeline Summary

When	Action	Cost
Now	Copyright headers + private repo	$0
Week 1	US Copyright registration	$65
Month 1	4 provisional patents	$1,280
Month 2-3	IP attorney engagement	$2,000-5,000
Month 6	Trademark filing	$250-350

Month 12	Utility patent conversions	$5,000-15,000/ea

LocationMapApp — Social Layer Governance

> *Reference document for legal, privacy, technical, and architectural decisions governing the social/community features of LocationMapApp.*

Last Updated: 2026-03-03

Table of Contents

1. Core Privacy Principles
2. Identity Model
3. Access Hierarchy
4. Legal & Regulatory Requirements
5. Technical Security Requirements
6. Architecture Constraints
7. Content Moderation Policy
8. Data Retention & Deletion
9. Location Data Governance
10. Required Legal Documents
11. Phase Plan
12. Database Schema Reference
13. Risk Register

---

1. Core Privacy Principles

These are non-negotiable architectural constraints. They are enforced by design (no API endpoint exists to violate them), not by policy.

1.1 Server-Mediated Everything

- All communication flows: `User A → Server → Server → User B`
- No direct client-to-client connections (no peer-to-peer WebSockets, no direct IP exchange)
- The server is always the intermediary for every message, file share, and data exchange

1.2 No User Information Exposure

- No user's IP address is ever stored, logged, forwarded, or accessible
- No user's device identifier is stored (device UUID used once during registration handshake, then discarded)
- No network metadata is passed between users
- No user enumeration — no endpoint lists users by anything traceable
- Message metadata is server-generated (timestamps, IDs) — no client fingerprint data attached

- No "last seen," "online now," or presence indicators unless a user explicitly opts in

1.3 A User IS Their Chosen Name — Nothing More

- Display names are the only identity visible to any other user
- No other user can obtain information about another user — not even moderators
- Moderators act on content and display names only — zero visibility into who the person is
- Account recovery data (email, OAuth ID) is a private channel between the user and the system exclusively
- Even application logs reference users by opaque server-generated UUID only, never PII

1.4 Privilege by Design, Not Permission

- No API endpoint returns PII columns — excluded at the query level, not filtered in middleware
- Moderator views are served by dedicated queries that JOIN only `display_name`, never `email/device_id`
- The only path to PII is direct `psql` access on the server — restricted to root/god (system owner)
- The application literally cannot leak what it never queries

1.5 Terminology

- **Never use the word "anonymous"** in user-facing materials, marketing, or legal documents
- The FTC classifies any system with persistent identifiers as identifiable — "anonymous" claims are legally actionable
- **Use "pseudonymous"** — users pick a name, we don't require real identity, but we don't claim they're invisible
- Acceptable phrasing: "We minimize data collection," "We do not link your activity to a named identity," "We do not sell your personal information"

---

2. Identity Model

2.1 Tiered Identity

Tier	Name	What's Stored	What's NOT Stored	Capabilities
0	Pseudonymous	Server-generated UUID, display name, created_at	Device UUID, IP, email, location history	Read, comment, join public rooms
1	Recoverable	+ encrypted email (AES-256-GCM)	Device UUID, IP, location history	+ create rooms, build reputation
2	OAuth-linked	+ OAuth provider/ID hash	Raw OAuth token, device UUID, IP	+ account recovery across devices

2.2 Identity Rules

- Server generates a fresh UUID for each user — identity is NEVER derived from device
- Device UUID touches the wire once during initial registration, is never stored server-side
- Display names are user-chosen, not derived from email or OAuth profile

- Email is encrypted at rest (AES-256-GCM), stored only for account recovery
- OAuth IDs are stored as one-way hashes, never raw
- No index exists on encrypted email column — it cannot be queried from the application layer
- A separate `auth_lookup` table maps `email_hash → user_id` for login purposes only

2.3 Account Lifecycle

- **Creation:** App requests `POST /auth/register` — server generates UUID, returns JWT + refresh token
- **Upgrade (Tier 0→1):** User provides email via `POST /auth/link` — encrypts and stores, preserves all existing data
- **Upgrade (Tier 1→2):** User links Google/Apple via `POST /auth/link-oauth` — stores hashed provider ID
- **Deletion:** User requests `POST /auth/delete` — cascading hard delete within 45 days (see Section 8)

---

3. Access Hierarchy

The system has two distinct power domains: **platform-level** (controls the entire application) and **room-level** (controls a single chat room branch). Platform-level roles have superuser access to all information. Room-level roles exist only within their room and have zero visibility into the platform or other rooms.

3.1 Platform-Level Roles (Superuser Domain)

```
OWNER (system owner):
  ├── Access: EVERYTHING — full database, encryption keys, server infrastructure
  ├── Method: direct PostgreSQL CLI, server SSH, application admin panel
  ├── Can: decrypt emails, view all user data, all platform operations
  ├── Can: create/remove Developer/Product Support accounts
  ├── Can: override any room-level decision
  ├── Can: respond to law enforcement requests
  └── Ultimate authority over the entire platform

DEVELOPER / PRODUCT SUPPORT (platform staff):
  ├── Access: ALL information needed to control the application
  ├── Method: application admin panel + internal API endpoints
  ├── Can see: all user accounts, all rooms, all messages, all content
  ├── Can see: user account details (email, registration date, activity history)
  ├── Can: ban any user from the ENTIRE PLATFORM (not just a room)
  ├── Can: block IPs from accessing the service
  ├── Can: terminate any account permanently
  ├── Can: access any chat room, read any message
  ├── Can: override room-level admin/moderator decisions
  ├── Can: respond to user reports escalated beyond room level
  ├── Can: review flagged content from automated moderation
  ├── Must: document ALL contact with any individual user
  │         (logged to support_interactions table with timestamp,
  │          staff member ID, user ID, action taken, reason)
  ├── Cannot: access server infrastructure or encryption keys (Owner only)
  └── Cannot: create other Dev/Product Support accounts (Owner only)
```

Platform-level access is privileged. These roles exist to run and protect the application. They can see everything because they need to — for abuse response, legal compliance, and platform safety. This access

is audited and logged.

3.2 Room-Level Roles (Scoped to One Room Only)

```
ROOM ADMINISTRATOR (user who creates a chat room):
  ├── Scope: ONLY the room they created — zero access elsewhere
  ├── Can see: display names and content within their room
  ├── Can: set room name, description, public/private status
  ├── Can: promote any room member to Room Moderator
  ├── Can: demote Room Moderators back to member
  ├── Can: mute any user for X hours (configurable duration)
  ├── Can: kick any user from the room (immediate removal)
  ├── Can: ban any user from the room (permanent, cannot rejoin)
  ├── Can: delete any message in their room
  ├── Can: set room rules / pinned messages
  ├── Can: close/archive the room
  ├── Cannot see: any user information beyond display_name
  ├── Cannot see: user emails, IPs, device info, or account details
  ├── Cannot: affect users outside their room
  ├── Cannot: ban users from the platform (must flag to Product Support)
  └── Cannot: access other rooms' content or membership

ROOM MODERATOR (promoted by Room Administrator):
  ├── Scope: ONLY the room they were promoted in
  ├── Can see: display names and content within their room
  ├── Can: mute any user for X hours (configurable: 1h, 6h, 24h, 72h)
  ├── Can: kick any user from the room (immediate removal)
  ├── Can: ban any user from the room (permanent, cannot rejoin)
  ├── Can: delete messages in their room
  ├── Can: flag users/content for Product Support review (escalation)
  ├── Cannot see: any user information beyond display_name
  ├── Cannot: promote other moderators (Room Admin only)
  ├── Cannot: demote other moderators (Room Admin only)
  ├── Cannot: close/archive the room (Room Admin only)
  ├── Cannot: affect users outside their room
  └── Cannot: override Room Administrator decisions

MEMBER (regular room participant):
  ├── Can: send messages, share POIs, share databases
  ├── Can: report messages/users (flagged for Room Mod → Product Support)
  ├── Can see: display names and content within the room
  └── Cannot see: anything about other users beyond display_name
```

3.3 Room Ban Enforcement

When a Room Admin or Moderator bans a user from a room:

- User is immediately disconnected from the room's Socket.IO channel
- `room_bans` table records: room_id, banned_user_id, banned_by, reason, timestamp
- Server checks `room_bans` on every room join attempt — **banned users cannot rejoin**
- Ban is permanent unless the Room Admin explicitly lifts it
- Banned user can still use other rooms and platform features normally
- If a user is problematic across multiple rooms, Room Admins flag to Product Support for platform-level action

3.4 Platform Ban vs Room Ban

Action	Scope	Who Can Do It	Effect
Room mute	Single room	Room Admin, Room Moderator	Cannot send messages for X hours, can still read
Room kick	Single room	Room Admin, Room Moderator	Removed from room, can rejoin
Room ban	Single room	Room Admin, Room Moderator	Removed from room, **cannot rejoin**
Platform ban	Entire application	Dev/Product Support, Owner	All social features disabled, all rooms disconnected
IP block	Entire application	Dev/Product Support, Owner	Connection rejected at server level
Account termination	Entire application	Dev/Product Support, Owner	Account permanently deleted, all content orphaned

3.5 Escalation Path

```
User reports content
  → Room Moderator reviews (room-level action: delete/mute/kick/ban)
  → If beyond room scope → Room Mod flags to Product Support
  → Product Support reviews (platform-level action: platform ban/IP block/terminate)
  → If legal/infrastructure issue → Escalate to Owner
```

3.6 Support Interaction Logging

ALL Dev/Product Support contact with individual users is documented:

```
CREATE TABLE support_interactions (
    id              BIGINT GENERATED ALWAYS AS IDENTITY PRIMARY KEY,
    staff_user_id   UUID NOT NULL REFERENCES users(id),
    target_user_id  UUID NOT NULL REFERENCES users(id),
    action          VARCHAR(50) NOT NULL,  -- 'review', 'warn', 'ban', 'unban',
'ip_block', 'terminate', 'contact'
    reason          TEXT NOT NULL,
    details         TEXT,                  -- full description of the interaction
    room_id         UUID REFERENCES chat_rooms(id),  -- NULL if platform-level
    created_at      TIMESTAMPTZ NOT NULL DEFAULT NOW()
);
```

This table is append-only — records are never deleted or modified. It serves as the audit trail for all platform-level moderation activity.

3.7 Privacy Boundary Summary

Role	Can see display names	Can see content	Can see PII (email, etc.)	Can see IPs	Can see all rooms
Owner	Yes	Yes (all)	Yes (decrypted)	Yes (if logged)	Yes

Dev/Product Support	Yes	Yes (all)	Yes (via admin panel)	Yes (for blocking)	Yes
Room Administrator	Yes (own room)	Yes (own room)	**NO**	**NO**	**NO**
Room Moderator	Yes (own room)	Yes (own room)	**NO**	**NO**	**NO**
Member	Yes (joined rooms)	Yes (joined rooms)	**NO**	**NO**	**NO**

The line is absolute: **platform staff see everything to control the app. Room-level roles see display names and content in their room only — nothing else, ever.**

---

4. Legal & Regulatory Requirements

4.1 COPPA (Children's Online Privacy Protection Act)

Status: 2025 amendments effective June 23, 2025. Compliance deadline: **April 22, 2026**.

Requirements:

- Age gate REQUIRED before any social feature access (chat, comments, account creation)
- Users indicating age < 13 are blocked from all social features entirely
- Expanded definition of personal information now includes: device IDs, IP addresses, precise geolocation
- Data retention: delete when no longer necessary, provide clear retention policies
- FTC February 2026 safe harbor: age verification data collection allowed solely for age determination

Implementation:

- Present age verification dialog before first social feature interaction
- Store age-verified flag (not date of birth) in user record
- Block social features for unverified users
- No personal data collection before age verification completes

4.2 Location Data as Sensitive PII

Location data receives heightened protection under every modern privacy framework:

Law/Agency	Classification	Key Requirement
CCPA/CPRA	Sensitive Personal Information	Purpose limitation, risk assessments, opt-out rights
Oregon	Protected (1,750ft precision ban)	Cannot sell/share precise location data
Maryland	Protected (sale banned)	Cannot monetize location data at all
COPPA 2025	Personal Information	Parental consent required for children
FTC enforcement	Essentially non-anonymizable	4 timestamped points identify 95% of individuals
GDPR	Sensitive data	Heightened consent, fines up to 4% global revenue

Our obligations:

- Geo-room membership is ephemeral (in-memory only, never persisted to database)
- No location history stored server-side for any user
- Geo-room auto-join requires explicit user consent (not default-on)
- Location data used only for room assignment, then discarded

4.3 FTC "Anonymous" / "No Tracking" Claims

FTC position (reaffirmed 2024-2026):

- Hashing does not make data anonymous — hashed/pseudonymized data is still identifiable
- Device UUIDs are personal data (explicitly under 2025 COPPA amendments)
- Location data is never truly anonymous (4 points = 95% identification)
- NGL Labs fined $4.5M in 2026 for false anonymity claims

Our compliance:

- Never claim "anonymous" or "no tracking" in any user-facing material
- Use "pseudonymous" terminology throughout
- Disclose in privacy policy exactly what we collect and retain
- Minimize collection: no device IDs stored, no IP logging, no location history

4.4 Section 230 (Communications Decency Act)

Current status: In effect but under legislative threat. Provides platform immunity for user-generated content.

Our protections:

- We are not liable for user comments/messages (platform, not publisher)
- Good-faith moderation decisions are protected
- Section 230 does NOT protect against: federal crimes, IP violations, ECPA violations

Preparing for post-230 world:

- Document all moderation policies clearly
- Apply moderation consistently across all users
- Do not algorithmically amplify or endorse user content
- Maintain audit trail of all moderation actions

4.5 Business Defamation on POI Comments

- Protected opinion ("food was terrible") cannot be sued
- False factual claims ("has cockroaches" when it doesn't) = potentially defamatory
- Section 230 protects us as platform, but businesses can **subpoena us to identify commenters**
- If commenter is Tier 0 (pseudonymous, no email), we have nothing to produce — legal strength
- If commenter is Tier 1-2 (has email), email may be disclosed under court order
- Terms of Service MUST disclose this possibility to users
- Consumer Review Fairness Act: we CANNOT suppress legitimate negative reviews

4.6 State Privacy Law Landscape (2026)

Twenty states now have comprehensive privacy laws. Key considerations:

- Indiana, Kentucky, Rhode Island laws effective January 1, 2026
- Connecticut, Arkansas, Utah new provisions effective July 1, 2026
- 2026 is described as "the most aggressive enforcement climate in U.S. privacy history"
- State AG multi-jurisdictional collaborations are now commonplace
- Compliance strategy must satisfy the strictest requirements (Maryland/Oregon for location data)

4.7 KOSA (Kids Online Safety Act)

Status: NOT YET LAW. Reintroduced May 2025 (S.1748), pending in Congress.

If enacted: duty of care for platforms regarding minors (under 17), FTC + state AG enforcement power, focus on platform design choices.

Our posture: Age gate already handles this. Building child-safety features now positions ahead of likely requirements.

4.8 CAN-SPAM / Notifications

- CAN-SPAM applies to email only — if we send emails, must include opt-out, physical address, honest subject
- Push notifications governed by platform policies (Google Play), not CAN-SPAM — require opt-in
- If we ever add SMS (2FA), TCPA requires prior express consent

---

5. Technical Security Requirements

5.1 Authentication

Component	Standard	Specification
Access tokens	JWT	15-minute expiry, EdDSA or ES256 signing
Refresh tokens	Opaque random	30-day expiry, stored as hash in DB
Refresh rotation	Mandatory	Each use issues new token, reuse = revoke entire family
Password hashing	Argon2id	19 MiB memory, 2 iterations, 1 parallelism (OWASP first choice)
Google Sign-In	Credential Manager API	Legacy GoogleSignInClient is deprecated
Android token storage	DataStore + Tink + Keystore	EncryptedSharedPreferences is deprecated

5.2 Transport Security

- **TLS 1.2 minimum, TLS 1.3 preferred** on all connections
- **WebSocket connections must use `wss://`** — never `ws://`
- Forward secrecy (ECDHE key exchange) on all connections
- Android Network Security Config: disallow cleartext traffic

- Consider certificate pinning for proxy server connection (with backup pin and rotation plan)
- Validate `Origin` header on WebSocket upgrade to prevent Cross-Site WebSocket Hijacking

5.3 Encryption at Rest

Data	Method	Key Management
User emails	AES-256-GCM field encryption	Application-managed key, stored outside DB
OAuth IDs	One-way SHA-256 hash	N/A (not reversible)
Passwords	Argon2id hash	N/A (not reversible)
Database backups	Encrypted volumes (LUKS)	System-level key management
Shared database files	AES-256 at rest	Application-managed key

5.4 Input Validation & Injection Prevention

- **SQL injection:** Parameterized queries exclusively (`$1, $2` placeholders in `pg` library). Never interpolate user input into SQL strings. Non-negotiable.
- **XSS:** Strip or encode all HTML tags from chat messages and POI comments before storage and display. Use `sanitize-html` or equivalent server-side.
- **WebSocket payloads:** Validate and sanitize all incoming Socket.IO messages before processing or broadcasting.
- **Content length limits:** 2,000 chars for comments, configurable for chat messages, 1MB max Socket.IO message.

5.5 JWT Security Checklist

- [ ] Strict algorithm whitelisting (never trust `alg` header from token)
- [ ] Reject `alg: none` tokens
- [ ] Always verify signatures (no skip path)
- [ ] Use 256+ bit random secret for HMAC or asymmetric keys (EdDSA/ES256)
- [ ] Short access token expiry (15 minutes)
- [ ] Refresh token rotation with family-based revocation
- [ ] Token blacklist for logout/revocation

5.6 OAuth 2.0 Security

- PKCE mandatory for all mobile OAuth flows (`S256` code challenge method)
- Short-lived authorization codes (one-time use, 60-second expiry)
- Use Android App Links (verified deep links) instead of custom URI schemes
- Use AppAuth library for Android — do not build custom OAuth implementation
- Whitelist exact redirect URIs (no wildcards)

5.7 Rate Limiting

Layer	Strategy	Limits
Connection	Max connections per user	Configurable, start at 3

Chat messages	Token bucket per user	20 messages/minute
POI comments	Sliding window per user	5 comments/5 minutes
Reports	Sliding window per user	3 reports/hour
API endpoints	Sliding window per endpoint	Configurable
New accounts	Escalating limits	10 comments in first 24 hours
Duplicate content	Content hash within time window	Block identical messages within 60s

5.8 File/Database Sharing Security

- Schema validation: strict validation against expected table/column structure before import
- Dangerous object check: reject SQLite files containing triggers or views
- Integrity check: `PRAGMA integrity_check` and `PRAGMA quick_check`
- Open read-only with `trusted_schema = OFF` and `mmap_size = 0`
- Row count limit: 1M rows per table maximum
- File size limit: 50MB per file, 100MB total quota per user
- Content-addressable storage: SHA-256 hash for deduplication
- Virus scanning: ClamAV for uploaded files (optional, recommended for production)
- Content moderation: text fields in shared databases pass through same moderation pipeline as chat

---

6. Architecture Constraints

6.1 Communication Model

```
┌──────────────┐      HTTPS + wss://       ┌──────────────────────┐
│  Android App │ ◄────────────────────────► │  Cache Proxy (Node.js)│
│              │      TLS 1.3              │  Port 3000           │
│  - No P2P    │                           │                      │
│  - No IPs    │                           │  ┌────────────────┐  │
│  - TLS only  │                           │  │ Content Filter  │  │
│              │                           │  │ (every message) │  │
└──────────────┘                           │  └────────┬───────┘  │
                                           │           │          │
                                           │  ┌────────▼────────┐  │
                                           │  │ PostgreSQL      │  │
                                           │  │ (encrypted PII) │  │
                                           │  └────────────────┘  │
                                           └──────────────────────┘
```

6.2 Message Flow (every message)

1. User A sends message via Socket.IO over TLS
2. Server receives — strips ALL client metadata (IP, headers, device info)
3. Rate limit check (per-user token bucket)
4. Content moderation: instant blocklist regex check
5. If passes: store in DB with server-generated timestamp, broadcast to room

6. If blocked: reject with generic error, log for review
7. Async: Perspective API toxicity analysis on delivered messages (flag, don't block)
8. User B receives: display_name + content + server_timestamp ONLY

6.3 Real-Time Technology

- **Socket.IO v4** on existing Express server (shares HTTP server)
- Android client: `socket.io-client-java` with WebSocket transport only (skip HTTP long-polling)
- Heartbeat: 25s interval, 20s timeout (Socket.IO defaults)
- Reconnection: automatic with exponential backoff (1s → 30s max)
- Auth: JWT passed in handshake `auth` object, validated on connection
- Future scaling: Redis pub/sub via `@socket.io/redis-adapter` (zero code changes, add only when needed)

6.4 Message Persistence

Async batch writes to PostgreSQL — real-time delivery first, DB write eventual:

- Buffer: 50 messages OR 2 seconds (whichever first) → bulk INSERT
- Monthly range partitioning on `sent_at` column
- Partition benefits: recent queries only scan current partition; old partitions can be dropped instantly
- Materialized views for aggregate counts (comment counts per POI, room member counts), refreshed every 5 minutes

---

7. Content Moderation Policy

Content moderation operates at two levels: **automated** (every message, before delivery) and **human** (room-level moderators + platform-level Product Support). All chat content is censored for bad content before anyone sees it.

7.1 Automated Content Censorship (Every Message, Pre-Delivery)

Every message passes through the automated pipeline before it reaches any user. No exceptions.

Stage	Method	Timing	Action on Trigger
1	**Rate limiting**	Synchronous	Reject message, notify sender "slow down"
2	**Duplicate detection**	Synchronous	Block if identical content within 60s
3	**Regex/keyword blocklist**	Synchronous (pre-delivery)	Block message, sender sees "message not sent — content violation"
4	**Content length / format**	Synchronous	Reject oversized or malformed messages
5	**Perspective API toxicity**	Asynchronous (post-delivery)	If score > 0.85: auto-flag for Room Mod review queue
6	**Pattern escalation**	Asynchronous	If user triggers 3+ blocks in 1 hour: auto-flag to Product Support

The blocklist covers: slurs, hate speech, explicit sexual content, doxxing patterns (phone/SSN/address

regex), spam patterns, known abuse phrases. Maintained by Dev/Product Support, updated regularly.

7.2 Human Moderation Chain

```
AUTOMATED FILTER (catches obvious bad content before delivery)
       |
       ▼
ROOM MODERATOR (first human line — handles room-level issues)
  ├── Delete offensive messages
  ├── Mute disruptive users (1h, 6h, 24h, 72h)
  ├── Kick users (removed, can rejoin)
  ├── Ban users (removed, CANNOT rejoin room)
  └── Flag to Product Support if issue is beyond room scope
       |
       ▼
PRODUCT SUPPORT (platform-level — handles escalations + cross-room issues)
  ├── Review flagged content and escalated reports
  ├── Platform-ban users across ALL rooms
  ├── Block IPs from the service
  ├── Terminate accounts permanently
  ├── Document ALL interactions with users
  └── Escalate to Owner for legal/infrastructure issues
       |
       ▼
OWNER (final authority — legal, infrastructure, critical decisions)
```

7.3 Room-Level Moderation Actions

These actions are available to **Room Administrators** and **Room Moderators** within their room only.

Action	Who Can Do It	Effect	Duration	Reversible
Delete message	Room Admin, Room Mod	Message replaced with "[message removed]"	Permanent	No
Mute user	Room Admin, Room Mod	User cannot send messages in this room	1h, 6h, 24h, or 72h (configurable)	Auto-expires
Kick user	Room Admin, Room Mod	User removed from room immediately	Instant (user can rejoin)	N/A
Ban user	Room Admin, Room Mod	User removed, **cannot rejoin this room**	Permanent until Admin lifts	Room Admin can unban
Promote to Moderator	Room Admin only	Member gains moderation powers	Until demoted	Room Admin can demote
Demote Moderator	Room Admin only	Moderator becomes regular member	Immediate	Can re-promote
Flag to Support	Room Admin, Room Mod	Escalates user/content to Product Support	N/A	N/A

7.4 Platform-Level Moderation Actions

These actions are available to **Dev/Product Support** and **Owner** only. They affect the user across the entire platform.

Action	Effect	Scope	Documentation Required
Platform ban	All social features disabled, all rooms disconnected	Entire platform	Yes — `support_interactions` entry required
IP block	Connection rejected at server level	Entire platform	Yes — `support_interactions` entry required
Account termination	Account permanently deleted, all content orphaned	Entire platform	Yes — `support_interactions` entry required
Shadow ban	User sees own content, nobody else does (across all rooms)	Entire platform	Yes — `support_interactions` entry required
Content purge	Remove all content from a specific user across all rooms	Entire platform	Yes — `support_interactions` entry required
Override room decision	Reverse a Room Admin/Mod action (unban, unmute, etc.)	Specific room	Yes — `support_interactions` entry required

Every platform-level action MUST be documented in the `support_interactions` table with staff ID, target user, action, reason, and full details. This is non-negotiable — it's the audit trail.

7.5 Room Ban Enforcement (Cannot Rejoin)

When a user is banned from a room:

1. Immediate disconnect from room's Socket.IO channel
2. Record written to `room_bans` table: room_id, user_id, banned_by, reason, timestamp
3. On every future `join_room` request, server checks `room_bans` → **denied if banned**
4. Banned user sees: "You have been banned from this room"
5. Ban is permanent unless Room Administrator explicitly lifts it via unban action
6. Banned user can still use all other rooms and platform features normally

```
CREATE TABLE room_bans (
    room_id     UUID NOT NULL REFERENCES chat_rooms(id) ON DELETE CASCADE,
    user_id     UUID NOT NULL REFERENCES users(id) ON DELETE CASCADE,
    banned_by   UUID NOT NULL REFERENCES users(id),
    reason      TEXT,
    created_at  TIMESTAMPTZ NOT NULL DEFAULT NOW(),
    lifted_at   TIMESTAMPTZ,            -- NULL = still active
    lifted_by   UUID REFERENCES users(id),
    PRIMARY KEY (room_id, user_id)
);
```

7.6 Mute Enforcement

When a user is muted in a room:

1. Record written to `room_memberships.muted_until` with expiry timestamp
2. Server rejects messages from muted users: "You are muted for X hours"
3. Muted user can still read messages, they just cannot send
4. Mute auto-expires at the set time — no manual action needed
5. Room Admin/Mod can unmute early if desired

6. Mute durations: 1 hour, 6 hours, 24 hours, 72 hours (Room Admin/Mod picks)

7.7 Moderation Audit Trail

Every moderation action at every level is logged. Two separate tables for the two domains:

Room-level actions → `moderation_log` table:

```
CREATE TABLE moderation_log (
    id              BIGINT GENERATED ALWAYS AS IDENTITY PRIMARY KEY,
    room_id         UUID NOT NULL REFERENCES chat_rooms(id),
    moderator_id    UUID NOT NULL REFERENCES users(id),
    action          VARCHAR(50) NOT NULL,   -- 'delete_message', 'mute', 'kick', 'ban',
'unban', 'promote_mod', 'demote_mod'
    target_user_id  UUID REFERENCES users(id),
    target_message_id BIGINT,               -- for message deletions
    reason          TEXT,
    duration_hours  INTEGER,                -- for mutes
    content_snapshot TEXT,                   -- preserved copy of deleted content
    created_at      TIMESTAMPTZ NOT NULL DEFAULT NOW()
);
```

Platform-level actions → `support_interactions` table (see Section 3.6)

Both tables are **append-only — records are never deleted or modified**.

7.8 Perspective API Integration

- Google Perspective API (free tier) for toxicity scoring
- Scores: TOXICITY, SEVERE_TOXICITY, INSULT, THREAT
- Threshold: flag for Room Mod review at > 0.85 (do NOT auto-block — reduces false positives)
- Non-blocking: analysis runs async after message delivery
- Auto-escalation: if $3+$ flags in 1 hour for same user → auto-flag to Product Support
- Env var: `PERSPECTIVE_API_KEY` (optional — system works without it using stages 1-4 only)

7.9 Content Censorship Scope

Content censorship applies to ALL user-generated content across the platform:

Content Type	Automated Filter	Room-Level Moderation	Platform-Level Moderation
Chat messages	Yes (pre-delivery)	Yes (delete, mute, kick, ban)	Yes (platform ban, purge)
POI comments	Yes (pre-save)	N/A (not room-scoped)	Yes (delete, platform ban)
Room names/ descriptions	Yes (on creation)	Room Admin can edit	Product Support can edit/ remove
Display names	Yes (on registration)	N/A	Product Support can force rename
Shared database metadata	Yes (on upload)	N/A	Product Support can remove

No user-generated text enters the system without passing through the automated content filter.

8. Data Retention & Deletion

8.1 Retention Periods

Data Type	Retention	Justification
Chat messages	Indefinite (until user deletes or room archived)	User expectation of persistent chat history
Deleted messages	90 days soft-delete, then hard-delete	Appeals window
POI comments	Indefinite (until user deletes)	Ongoing community value
User accounts	Until user requests deletion	User-controlled
Room-level moderation logs	2 years	Audit compliance
Support interactions	**Indefinite (never deleted)**	Legal audit trail — all staff-user contact
Room bans	Indefinite (until lifted by Room Admin)	Enforcement — banned users cannot rejoin
IP blocks	Until expiry or manual removal	Platform security
User reports	2 years after resolution	Audit compliance + pattern detection
Moderation blocklist	Indefinite	Operational necessity
Geo-room membership	Ephemeral (in-memory only)	Privacy — never persisted

8.2 User Deletion Process

When a user requests account deletion (`POST /auth/delete`):

Step	Action	Timeline
1	Confirm deletion request (email if Tier 1+)	Immediate
2	Soft-delete user record	Within 24 hours
3	Replace display_name with "[deleted user]" on all content	Within 24 hours
4	Delete encrypted email, OAuth hash	Within 24 hours
5	Hard-delete user record	Within 45 days (CCPA) / 30 days (GDPR)
6	Orphaned content remains with "[deleted user]" attribution	Permanent
7	Confirmation sent (if email was on file)	After completion

8.3 Content Deletion

- Chat messages: hard delete from DB, other users see "[message removed]"
- POI comments: hard delete, show "[deleted]" placeholder with rating preserved (anonymized)
- Shared databases: remove contributor attribution or anonymize; if sole contributor, remove database
- Deletion cascades must complete within 45 days of request

8.4 Law Enforcement Obligations

- **Preservation requests:** Must retain specified user data pending formal legal process. Failure = spoliation claims.
- **Subpoenas** (lowest standard): non-content data — account info, timestamps
- **Court orders** (intermediate): some metadata
- **Warrants** (highest): content of communications
- **What we can produce for Tier 0 users:** display_name, server-generated UUID, timestamps. No email, no device info, no IP.
- **What we can produce for Tier 1-2:** above + decrypted email (requires our encryption key)
- Internal procedure: all law enforcement requests go through root/god only

---

9. Location Data Governance

9.1 Principles

- Location data is the most sensitive data we handle — treated as toxic by default
- Minimize collection, minimize retention, minimize sharing
- No location history stored server-side for any user tier
- Geo-room assignment is the ONLY social feature that processes location

9.2 Geo-Room Privacy Controls

Control	Implementation
Opt-in only	Geo-rooms not joined by default; user must explicitly enable community features
Coarse precision	Geohash precision 4 (~39km x 20km) for city rooms — reveals only metro area
Ephemeral membership	Room assignment stored in-memory only, never written to database
Delayed updates	Room membership updated every 5 minutes, not on every GPS fix
No presence broadcast	Other users never see that a specific person is in a geo-room
No location forwarding	User's coordinates never sent to other users, only used for room hash calculation
Room names only	UI shows "Beverly" or "Boston" — never coordinates or precise location

9.3 Geohash Room Strategy

Precision	Cell Size	Room Type
4 chars	~39km x 20km	City / metro area
6 chars	~1.2km x 0.6km	Neighborhood (future)

- Users join center cell + 8 neighbors (9 rooms total) to handle boundary cases
- UI displays only primary room name
- Room creation is on-demand (first user to enter a geohash creates the room)
- Rooms auto-archive after 90 days of no messages

10. Required Legal Documents

These documents MUST be completed before any social feature ships. COPPA compliance deadline is **April 22, 2026**.

10.1 Documents Needed

Document	Purpose	Priority
Privacy Policy	What we collect, retention, deletion rights, CCPA/GDPR disclosures	CRITICAL — before any social feature
Terms of Service	User conduct, content licensing, moderation rights, dispute resolution	CRITICAL — before any social feature
Age Gate	COPPA compliance — verify 13+ before social feature access	CRITICAL — deadline April 22, 2026
Content Policy	What's allowed in chat/comments, consequences for violations	HIGH — before chat launches
DMCA Takedown Policy	Copyright infringement procedure for user-generated content	MEDIUM — before public launch
Law Enforcement Response Policy	Internal procedures for subpoenas and preservation requests	MEDIUM — before significant user base

10.2 Privacy Policy Must Disclose

- We collect: server-generated user ID, display name, message content, comment content
- We collect (Tier 1+): encrypted email for account recovery only
- We do NOT collect: IP addresses, device identifiers, location history, real names
- We do NOT sell personal information
- We do NOT share personal information with third parties (except under court order)
- Approximate location is used for geo-room assignment only (ephemeral, not stored)
- Users can request deletion of all personal data within 45 days
- Users can request export of their data

10.3 Terms of Service Must Include

- User conduct rules (no harassment, hate speech, illegal content, doxxing)
- Content licensing (users retain ownership, grant us license to display/store/moderate)
- Moderation rights (our right to remove content, suspend accounts)
- Disclaimer of liability for user-generated content
- Age restriction (13+, COPPA compliance)
- Limitation of liability
- Dispute resolution / arbitration clause
- DMCA takedown procedure
- Consumer Review Fairness Act compliance (cannot suppress legitimate reviews)
- Disclosure: court orders may compel us to produce account recovery information (email) for Tier 1-2

users
- Pseudonymity is not guaranteed against legal process

---

11. Phase Plan

Phase	Feature	Legal Prerequisites	Technical Dependencies	Effort
0	Age gate + Privacy Policy + ToS	COPPA deadline April 22, 2026	None	Low
1	User identity (pseudonymous accounts, JWT auth)	Privacy Policy must be live	Phase 0	Medium
2	POI comments + ratings	Content Policy, Section 230	Phase 1	Medium
3	Chat rooms (global + geo + custom)	Full ToS, moderation system	Phase 1 + Phase 4 concurrent	High
4	Content moderation (blocklist + reporting + Perspective API)	Moderation audit trail	Phase 1	Medium
5	Shared databases (community upload/download)	File validation, quota mgmt	Phase 1	Medium
6	Google Sign-In + account linking (Tier 0→1→2)	OAuth security review	Phase 1	Low-Medium

11.1 Phase 0 — Legal Foundation (URGENT: deadline April 22, 2026)

- Draft and publish Privacy Policy
- Draft and publish Terms of Service
- Implement age gate dialog (before any social feature access)
- Store age-verified flag (not date of birth) in user record
- Block social features for unverified users

11.2 Phase 1 — User Identity

- `users` table with tiered identity (Section 12)
- JWT access token (15min) + opaque refresh token (30d) with rotation
- `POST /auth/register` — create pseudonymous account
- `POST /auth/login` — email/password login (Tier 1+)
- `POST /auth/refresh` — token rotation
- `POST /auth/delete` — account deletion cascade
- Argon2id password hashing
- Android: DataStore + Tink token storage

11.3 Phase 2 — POI Comments

- `poi_comments` table + `comment_votes` table

- `GET /comments/:osm_type/:osm_id` — fetch comments for a POI
- `POST /comments/:osm_type/:osm_id` — add comment (rate limited)
- `POST /comments/:id/vote` — upvote/downvote
- `DELETE /comments/:id` — delete own comment
- Community section in POI detail dialog
- Word filter on submission

11.4 Phase 3 — Chat Rooms

- `chat_rooms` + `room_memberships` + `messages` tables (monthly partitioned)
- Socket.IO v4 integration on existing Express server
- Global room (always exists, all users)
- Geo rooms (auto-created by geohash, opt-in, ephemeral membership)
- Custom rooms (created by Tier 1+ users, public or invite-only)
- Room admin/moderator role hierarchy
- Message delivery: server-mediated, metadata-stripped, content-filtered

11.5 Phase 4 — Content Moderation

- `moderation_blocklist` table (regex + literal patterns)
- `reports` table (user flagging)
- `moderation_log` table (audit trail)
- Synchronous blocklist filter on all messages/comments
- Async Perspective API toxicity scoring
- Shadow ban implementation
- Rate limiting per-user per-action

11.6 Phase 5 — Shared Databases

- `shared_databases` table
- Upload validation pipeline (schema check, integrity check, danger check, size limit)
- Content-addressable storage (SHA-256 dedup)
- Per-user upload quotas
- Community browse/download interface
- ClamAV scanning (optional)

11.7 Phase 6 — OAuth Account Linking

- Google Sign-In via Credential Manager API
- `POST /auth/link-oauth` — upgrade Tier 0/1 to Tier 2
- Account recovery flow
- Token migration (preserve all existing data)

---

12. Database Schema Reference

12.1 Users

```
CREATE TABLE users (
    id              UUID PRIMARY KEY DEFAULT gen_random_uuid(),

    -- Identity
    identity_tier   VARCHAR(20) NOT NULL DEFAULT 'pseudonymous',  -- pseudonymous,
recoverable, oauth_linked
    platform_role   VARCHAR(20) NOT NULL DEFAULT 'user',          -- user, support, owner
    display_name    VARCHAR(50) NOT NULL,

    -- PII (encrypted/hashed, platform-level access only)
    email_encrypted BYTEA,                  -- AES-256-GCM, Tier 1+ only
    password_hash   TEXT,                   -- Argon2id
    oauth_provider  VARCHAR(20),
    oauth_id_hash   VARCHAR(128),           -- SHA-256 hashed

    -- Platform-level moderation (Dev/Product Support + Owner only)
    is_banned       BOOLEAN NOT NULL DEFAULT FALSE,
    is_shadow_banned BOOLEAN NOT NULL DEFAULT FALSE,
    ban_reason      TEXT,
    ban_expires_at  TIMESTAMPTZ,
    banned_by       UUID REFERENCES users(id),

    -- COPPA
    age_verified    BOOLEAN NOT NULL DEFAULT FALSE,

    created_at      TIMESTAMPTZ NOT NULL DEFAULT NOW()
);

-- platform_role values:
--   'user'    = regular user (default) — no platform-level privileges
--   'support' = Dev/Product Support — superuser access via admin panel, must log all
interactions
--   'owner'   = System owner — full access including encryption keys and infrastructure
```

12.2 Auth Lookup (for login by email)

```
CREATE TABLE auth_lookup (
    email_hash  VARCHAR(64) PRIMARY KEY,    -- SHA-256 of lowercase email
    user_id     UUID NOT NULL REFERENCES users(id) ON DELETE CASCADE
);
```

12.3 Refresh Tokens

```
CREATE TABLE refresh_tokens (
    id          BIGINT GENERATED ALWAYS AS IDENTITY PRIMARY KEY,
    user_id     UUID NOT NULL REFERENCES users(id) ON DELETE CASCADE,
    token_hash  VARCHAR(64) NOT NULL UNIQUE,
    family_id   UUID NOT NULL,              -- for rotation-based revocation
    expires_at  TIMESTAMPTZ NOT NULL,
    revoked_at  TIMESTAMPTZ,
    created_at  TIMESTAMPTZ NOT NULL DEFAULT NOW()
);
```

12.4 Chat Rooms

```
CREATE TABLE chat_rooms (
    id              UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    room_type       VARCHAR(20) NOT NULL,   -- global, geo_city, geo_neighborhood, custom
    name            VARCHAR(200) NOT NULL,
    description     TEXT,
    created_by      UUID REFERENCES users(id),
    is_archived     BOOLEAN NOT NULL DEFAULT FALSE,
    member_count    INTEGER NOT NULL DEFAULT 0,
    last_message_at TIMESTAMPTZ,
    created_at      TIMESTAMPTZ NOT NULL DEFAULT NOW()
);
```

12.5 Room Memberships

```
CREATE TABLE room_memberships (
    room_id     UUID NOT NULL REFERENCES chat_rooms(id) ON DELETE CASCADE,
    user_id     UUID NOT NULL REFERENCES users(id) ON DELETE CASCADE,
    role        VARCHAR(20) NOT NULL DEFAULT 'member',  -- member, moderator, admin, owner
    joined_at   TIMESTAMPTZ NOT NULL DEFAULT NOW(),
    muted_until TIMESTAMPTZ,
    PRIMARY KEY (room_id, user_id)
);
```

12.6 Messages (Monthly Partitioned)

```
CREATE TABLE messages (
    id          BIGINT GENERATED ALWAYS AS IDENTITY,
    room_id     UUID NOT NULL,
    user_id     UUID NOT NULL,
    content     TEXT NOT NULL,
    reply_to_id BIGINT,
    is_deleted  BOOLEAN NOT NULL DEFAULT FALSE,
    deleted_by  UUID,
    deleted_at  TIMESTAMPTZ,
    sent_at     TIMESTAMPTZ NOT NULL DEFAULT NOW()
) PARTITION BY RANGE (sent_at);
```

12.7 POI Comments

```
CREATE TABLE poi_comments (
    id          BIGINT GENERATED ALWAYS AS IDENTITY PRIMARY KEY,
    osm_type    VARCHAR(10) NOT NULL,
    osm_id      BIGINT NOT NULL,
    user_id     UUID NOT NULL REFERENCES users(id),
    parent_id   BIGINT REFERENCES poi_comments(id),
    content     TEXT NOT NULL CHECK (length(content) <= 2000),
    rating      SMALLINT CHECK (rating BETWEEN 1 AND 5),
    upvotes     INTEGER NOT NULL DEFAULT 0,
    downvotes   INTEGER NOT NULL DEFAULT 0,
    is_deleted  BOOLEAN NOT NULL DEFAULT FALSE,
    created_at  TIMESTAMPTZ NOT NULL DEFAULT NOW()
);
```

12.8 Comment Votes

```
CREATE TABLE comment_votes (
    comment_id  BIGINT NOT NULL REFERENCES poi_comments(id) ON DELETE CASCADE,
    user_id     UUID NOT NULL REFERENCES users(id),
    vote        SMALLINT NOT NULL CHECK (vote IN (-1, 1)),
    created_at  TIMESTAMPTZ NOT NULL DEFAULT NOW(),
    PRIMARY KEY (comment_id, user_id)
);
```

12.9 Room Bans

```
CREATE TABLE room_bans (
    room_id     UUID NOT NULL REFERENCES chat_rooms(id) ON DELETE CASCADE,
    user_id     UUID NOT NULL REFERENCES users(id) ON DELETE CASCADE,
    banned_by   UUID NOT NULL REFERENCES users(id),
    reason      TEXT,
    created_at  TIMESTAMPTZ NOT NULL DEFAULT NOW(),
    lifted_at   TIMESTAMPTZ,            -- NULL = still active, set when Admin unbans
    lifted_by   UUID REFERENCES users(id),
    PRIMARY KEY (room_id, user_id)
);

CREATE INDEX idx_room_bans_active ON room_bans (room_id) WHERE lifted_at IS NULL;
```

12.10 IP Blocks (Platform-Level)

```
CREATE TABLE ip_blocks (
    id          BIGINT GENERATED ALWAYS AS IDENTITY PRIMARY KEY,
    ip_address  INET NOT NULL,
    blocked_by  UUID NOT NULL REFERENCES users(id),  -- must be support/owner
    reason      TEXT NOT NULL,
    expires_at  TIMESTAMPTZ,            -- NULL = permanent
    created_at  TIMESTAMPTZ NOT NULL DEFAULT NOW()
);

CREATE INDEX idx_ip_blocks_active ON ip_blocks (ip_address) WHERE expires_at IS NULL OR
expires_at > NOW();
```

12.11 Moderation — Content Filtering

```
CREATE TABLE moderation_blocklist (
    id          SERIAL PRIMARY KEY,
    pattern     TEXT NOT NULL,
    is_regex    BOOLEAN NOT NULL DEFAULT FALSE,
    severity    VARCHAR(20) NOT NULL DEFAULT 'block',   -- 'block', 'flag', 'warn'
    category    VARCHAR(50),            -- 'profanity', 'slur', 'spam', 'pii', 'threat'
    is_active   BOOLEAN NOT NULL DEFAULT TRUE,
    added_by    UUID REFERENCES users(id),  -- support/owner who added it
    created_at  TIMESTAMPTZ NOT NULL DEFAULT NOW()
);
```

12.12 Moderation — User Reports

```
CREATE TABLE reports (
    id              BIGINT GENERATED ALWAYS AS IDENTITY PRIMARY KEY,
    reporter_id     UUID NOT NULL REFERENCES users(id),
    target_type     VARCHAR(20) NOT NULL,   -- 'message', 'comment', 'user', 'room',
'database'
    target_id       TEXT NOT NULL,
    room_id         UUID REFERENCES chat_rooms(id),  -- room context if applicable
    reason          VARCHAR(50) NOT NULL,   -- 'spam', 'harassment', 'hate_speech',
'nsfw', 'doxxing', 'illegal'
    details         TEXT,
    status          VARCHAR(20) NOT NULL DEFAULT 'pending',  -- pending, reviewing,
resolved, dismissed
    -- Resolution (by Room Mod, Product Support, or Owner)
    resolved_by     UUID REFERENCES users(id),
    action_taken    VARCHAR(50),            -- 'none', 'delete_content', 'mute',
'room_ban', 'platform_ban', 'ip_block', 'terminate'
    resolution_note TEXT,
    resolved_at     TIMESTAMPTZ,
    created_at      TIMESTAMPTZ NOT NULL DEFAULT NOW()
);

CREATE INDEX idx_reports_pending ON reports (status, created_at) WHERE status = 'pending';
CREATE INDEX idx_reports_room ON reports (room_id) WHERE room_id IS NOT NULL;
```

12.13 Moderation — Room-Level Audit Log (append-only)

```
CREATE TABLE moderation_log (
    id                BIGINT GENERATED ALWAYS AS IDENTITY PRIMARY KEY,
    room_id           UUID NOT NULL REFERENCES chat_rooms(id),
    moderator_id      UUID NOT NULL REFERENCES users(id),
    action            VARCHAR(50) NOT NULL,   -- 'delete_message', 'mute', 'unmute',
'kick', 'ban', 'unban', 'promote_mod', 'demote_mod'
    target_user_id    UUID REFERENCES users(id),
    target_message_id BIGINT,                 -- for message deletions
    reason            TEXT,
    duration_hours    INTEGER,                -- for mutes (1, 6, 24, 72)
    content_snapshot  TEXT,                   -- preserved copy of deleted content
    created_at        TIMESTAMPTZ NOT NULL DEFAULT NOW()
);

CREATE INDEX idx_mod_log_room ON moderation_log (room_id, created_at DESC);
```

12.14 Moderation — Platform-Level Support Interactions (append-only)

```
CREATE TABLE support_interactions (
    id              BIGINT GENERATED ALWAYS AS IDENTITY PRIMARY KEY,
    staff_user_id   UUID NOT NULL REFERENCES users(id),  -- must be support/owner
    target_user_id  UUID NOT NULL REFERENCES users(id),
    action          VARCHAR(50) NOT NULL,   -- 'review', 'warn', 'platform_ban', 'unban',
'ip_block', 'shadow_ban',
                                            -- 'terminate', 'force_rename',
'content_purge', 'override_room_action', 'contact'
    reason          TEXT NOT NULL,
    details         TEXT,                   -- full description of the interaction
    room_id         UUID REFERENCES chat_rooms(id),  -- if action relates to specific room
    created_at      TIMESTAMPTZ NOT NULL DEFAULT NOW()
```

```
);

-- APPEND-ONLY: no UPDATE or DELETE ever. This is the legal audit trail.
CREATE INDEX idx_support_target ON support_interactions (target_user_id, created_at DESC);
CREATE INDEX idx_support_staff ON support_interactions (staff_user_id, created_at DESC);
```

12.15 Shared Databases

```
CREATE TABLE shared_databases (
    id              UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    uploaded_by     UUID NOT NULL REFERENCES users(id),
    name            VARCHAR(200) NOT NULL,
    description     TEXT,
    category        VARCHAR(50) NOT NULL,
    file_hash       VARCHAR(64) NOT NULL UNIQUE,
    file_size_bytes BIGINT NOT NULL,
    file_path       TEXT NOT NULL,
    is_approved     BOOLEAN NOT NULL DEFAULT FALSE,
    download_count  INTEGER NOT NULL DEFAULT 0,
    created_at      TIMESTAMPTZ NOT NULL DEFAULT NOW()
);
```

---

13. Risk Register

#	Risk	Severity	Likelihood	Mitigation
1	FTC enforcement for false "anonymous" claims	**CRITICAL**	High if we use the word	Never claim anonymous; use "pseudonymous"
2	COPPA violation (no age gate)	**CRITICAL**	High without age gate	Age gate before social features; deadline April 22, 2026
3	Location data mishandling (20 state laws)	**HIGH**	Medium	Ephemeral geo-room membership, no location history, opt-in only
4	Subpoena for user identity (defamation case)	**MEDIUM**	Medium at scale	Tier 0 users have no email to produce; ToS discloses court order risk
5	Section 230 repeal	**MEDIUM**	Uncertain	Document moderation policies, consistent enforcement, audit trail
6	JWT token theft	**MEDIUM**	Low with proper impl	15-min expiry, refresh rotation, family-based revocation
7	Content moderation failure (harassment, CSAM)	**HIGH**	Medium at scale	Multi-tier moderation, user reporting, audit trail, blocklists
8	Data deletion request cascade failure	**MEDIUM**	Medium	Automated deletion pipeline, 45-day SLA tracking
9	SQL injection via chat/comments	**HIGH**	Low with parameterized queries	Parameterized queries only, no string interpolation, input validation
10	WebSocket DoS	**MEDIUM**	Medium	Per-user connection limits, message rate limits, idle timeouts

11	Shared database malware	**LOW**	Low	Schema validation, read-only open, trusted_schema OFF, ClamAV
12	KOSA enactment	**LOW**	Uncertain	Age gate already covers this; monitor legislation

Appendix A: Technology Stack for Social Layer

Component	Technology	Reason
Real-time transport	Socket.IO v4	Built-in rooms, reconnection, Express integration
Auth tokens	JWT (EdDSA/ES256) + opaque refresh	Stateless access, revocable refresh
Password hashing	Argon2id	OWASP first choice, memory-hard
Google Sign-In	Credential Manager API	Current standard (legacy deprecated)
Android token storage	DataStore + Tink + Keystore	Current standard (ESP deprecated)
Message partitioning	PostgreSQL monthly range	Efficient queries, easy cleanup
Toxicity detection	Google Perspective API (free)	Industry standard, async flagging
File scanning	ClamAV	Free, self-hosted
Deduplication	SHA-256 content-addressable storage	Exact dedup, simple
Future scaling	Redis pub/sub + Socket.IO adapter	Zero code changes when needed

Appendix B: npm Dependencies (New)

```
socket.io           — WebSocket server with rooms
argon2              — Password hashing (Argon2id)
jsonwebtoken        — JWT creation and verification
google-auth-library — Google ID token verification
sanitize-html       — HTML/XSS sanitization for user content
ngeohash            — Geohash encoding for geo-rooms
```

Appendix C: Android Dependencies (New)

```
io.socket:socket.io-client:2.x       — Socket.IO client
androidx.credentials:credentials       — Credential Manager (Google Sign-In)
com.google.crypto.tink:tink-android   — Encryption for token storage
androidx.datastore:datastore-preferences — Token storage
```

LocationMapApp — Pathway to Commercial Launch

Author: Dean Maurice Ellis **Date:** March 4, 2026 **Status:** Reference document — commercialization roadmap **Version:** 2.0 — Lawyer-ready edition

---

How to Use This Document

This document is designed to be handed directly to an attorney who has never seen the app. It is organized in three parts:

- **Part A (Sections 1–4):** Read this first. It explains what the product is, how it makes money, what data it touches, and where the legal risks are. A lawyer can read Part A in 15 minutes and understand the full picture.
- **Part B (Sections 5–17):** Deep legal analysis. Each section covers a specific area of law or compliance. The attorney should focus on the sections most relevant to their expertise and flag anything that needs immediate attention.
- **Part C (Sections 18–27):** Implementation details — moderation systems, cloud infrastructure, cost projections, a risk matrix, specific questions for the attorney, and a master checklist. This is the execution plan.

If you are a lawyer reading this for the first time, start with Sections 1–4, then skip to Section 26 (Questions for the Attorney) to see exactly what we need from you.

Table of Contents

Part A — What the Lawyer Needs to Know

1. Product Description
2. Revenue Model & Freemium Design
3. Data Flow Description
4. Executive Summary of Legal Risks

Part B — Legal Analysis

1. Finding the Right Attorney
2. Business Entity & Insurance
3. Intellectual Property Protection
4. User Content Liability — Your Biggest Legal Risk
5. Privacy Law Compliance
6. Third-Party API & Data Licensing
7. Third-Party Dependency Inventory
8. Ad Network Compliance

9. In-App Purchase & Google Play Billing
10. Tax Considerations
11. Social Media Integration
12. Safety Data Liability & Disclaimers
13. Competitor & Comparable Analysis

Part C — Implementation & Execution

1. Content Moderation System
2. Required Legal Documents
3. Google Play Store Requirements
4. User Account Management & Law Enforcement
5. APK Protection & Obfuscation
6. Cloud Deployment
7. Cost Summary & Timeline
8. Risk Matrix with Probability & Impact
9. Specific Questions for the Attorney
10. Master Checklist

Sources

PART A — What the Lawyer Needs to Know

---

1. Product Description

1.1 What Is LocationMapApp?

LocationMapApp is an Android mobile application that displays an interactive map centered on the user's GPS location. It aggregates data from multiple public and third-party sources to show nearby points of interest (POIs), real-time transit, live aircraft positions, weather conditions, aviation restrictions, and safety zones — all in a single map view.

The app also includes social features: users can post comments and star ratings on any POI (restaurants, parks, transit stops, etc.) and participate in real-time chat rooms.

Think of it as: Google Maps meets Flightradar24 meets Yelp, with geofencing and aviation safety data layered in.

1.2 Key Features

Feature	Description
POI Map	211,000+ points of interest from OpenStreetMap across 17 categories (food, transit, shopping, health, education, etc.) with 153 subtypes. Displayed based on current viewport.
Fuzzy Search	Users search for "coffee" or "sushi" and get distance-sorted results with cuisine-aware matching. "Filter and Map" mode zooms to show matching results on the map.

Real-Time Transit	Live positions of MBTA buses, subway trains, and commuter rail (Boston metro area).
Aircraft Tracking	Live aircraft positions from OpenSky Network with follow mode, flight path trails, and ICAO24 identification.
Weather	Current conditions, radar imagery, METAR aviation weather, and NWS alerts.
Webcams	Live webcam images from Windy Webcams API.
Geofencing	5 live zone types (TFRs, flood zones, speed cameras, school zones, railroad crossings) with 220,000+ zones loaded from downloadable SQLite databases. Alerts when entering/exiting zones.
Social — Comments & Ratings	Users post star ratings and text comments on any POI. Other users can upvote/downvote.
Social — Chat	Real-time chat rooms via Socket.IO. Users create rooms, join a global room, or chat in location-specific rooms.

1.3 Technology Stack

Component	Technology
Mobile app	Android (Kotlin), distributed as APK via Google Play Store
Map engine	osmdroid (open-source OpenStreetMap renderer)
Backend server	Node.js / Express running a cache proxy that sits between the app and external APIs
Database	PostgreSQL (211K POIs, user accounts, comments, chat messages)
Real-time	Socket.IO (WebSocket-based) for chat
Authentication	Device-bonded registration (no email/password required), JWT tokens, Argon2id password hashing
Geofence engine	JTS (Java Topology Suite) with R-tree spatial indexing, running on-device

1.4 Target Audience

Segment	Use Case
Everyday users	Finding restaurants, coffee shops, transit stops, gas stations near their location
Transit commuters	Tracking live bus/train positions for the Boston MBTA system
Aviation enthusiasts	Tracking aircraft, viewing TFRs, following flights
Tech-savvy users	Power users who want a single app combining maps, transit, weather, and aviation
Content creators / influencers	Reviewing and rating local businesses, building a following through the social layer

1.5 Current Development Status

- **Stage:** Pre-launch. Fully functional on developer devices. Not yet on the Google Play Store.

- **Version:** v1.5.57 (131 source files, actively developed since 2025)
- **Testing:** 103 automated tests passing across 3 test suites
- **Social layer:** Implemented (auth, comments, ratings, voting, chat) but not yet tested at scale with real users
- **Infrastructure:** Running locally on developer's home network (10.0.0.4:3000). Must migrate to cloud before launch.

1.6 Geographic Scope

- **Launch market:** Boston, Massachusetts, USA (transit features are MBTA-specific)
- **Expansion plan:** US-wide first (POI/weather/aircraft/geofence features work nationally), then international
- **International considerations:** POI data from OpenStreetMap is global; transit would require new API integrations per city/country

---

2. Revenue Model & Freemium Design

2.1 Business Model: Freemium with Ads

The app uses a freemium model: free to download and use, supported by advertising, with a paid tier that removes ads and unlocks premium features.

	Free Tier	Paid Tier
Price	$0 (ad-supported)	$2.99–$4.99/month or $24.99–$39.99/year
Ads	Google AdMob banner and interstitial ads	No ads
POI map	Full access	Full access
Search	Full access	Full access
Transit	Full access	Full access
Aircraft	Full access	Full access
Weather	Full access	Full access
Comments & ratings	Read + write	Read + write
Chat	Join rooms	Join + **create** rooms (room ownership)
Geofence databases	View zones on map	Download offline databases + **custom zones**
POI ownership	—	Claim/moderate POI pages (for business owners)
Profile badge	—	Premium badge displayed on comments/chat

2.2 Revenue Streams

Stream	Source	Expected Revenue

Advertising	Google AdMob (banner + interstitial)	$1–$5 eCPM × impressions
Subscriptions	Monthly/annual premium tier via Google Play Billing	$2.99–$4.99/month
Future: Promoted POIs	Businesses pay to highlight their POI on the map	Not yet designed

2.3 Google's Cut

Billing Method	Google's Commission	Developer Keeps
Google Play Billing (subscriptions, first $1M/year)	**15%**	85%
Google Play Billing (subscriptions, over $1M/year)	**30%**	70%
Alternative billing (post-Epic v. Google, US only)	**~11–26%** (reduced service fee)	74–89%

Note: As of January 28, 2026, Google can no longer require Google Play Billing exclusively for US users. Alternative billing is legally permitted but may still carry a reduced service fee.

2.4 Ad Revenue Estimates (Conservative)

Monthly Active Users	Daily Ad Impressions	eCPM	Monthly Ad Revenue
1,000	5,000	$2.00	~$300
5,000	25,000	$2.00	~$1,500
10,000	50,000	$2.50	~$3,750
50,000	250,000	$3.00	~$22,500

eCPM varies significantly by geography, ad format, and user demographics. Location-based apps tend to command higher eCPMs due to local targeting value.

2.5 Legal Implications of Freemium

- **Ads + location data:** Displaying ads while collecting GPS raises additional privacy requirements (see Section 12)
- **Subscription auto-renewal:** Must comply with state auto-renewal laws (CA, NY, etc.) — clear disclosure of renewal terms, easy cancellation
- **Free-to-paid conversion:** Cannot degrade the free tier to coerce upgrades (FTC unfair practices)
- **Refund policy:** Google Play handles refunds for the first 48 hours; your ToS should address refunds beyond that window
- **Ad-free promise:** If paid tier promises "no ads," you must deliver zero ads — no "sponsored content" loopholes without disclosure

---

3. Data Flow Description

3.1 What Data Is Collected

Data Type	Source	Stored Where	Retention

GPS coordinates	User's device	Transmitted to server for POI/transit queries; NOT persistently stored server-side	Session only
Device identifier	Android device hardware	Server database (`users` table)	Until account deletion
Username	User-chosen at registration	Server database	Until account deletion
Password hash	User-entered, hashed with Argon2id	Server database	Until account deletion
Comments & ratings	User-generated	Server database (`poi_comments` table)	Until user deletion request
Chat messages	User-generated	Server database (`messages` table)	90 days, then auto-deleted
POI search queries	User-entered	Server logs	90 days
IP addresses	Network connection	Server logs	90 days

3.2 Data Flow Diagram

```
┌──────────────────────────────────────────────────────────────────────────┐
│                          USER'S ANDROID DEVICE                           │
│                                                                          │
│  ┌──────────────┐     ┌──────────────┐     ┌──────────────────────┐     │
│  │ GPS Sensor   │────→│ LocationMap  │────→│ Geofence Engine (JTS) │     │
│  │ (on-device)  │     │ App (Kotlin) │     │ (on-device, offline)  │     │
│  └──────────────┘     └──────┬───────┘     └──────────────────────┘     │
│                              │                                           │
│                HTTPS (TLS 1.2+) requests                                 │
└──────────────────────────────┼──────────────────────────────────────────┘
                               │
                               ▼
┌──────────────────────────────────────────────────────────────────────────┐
│                     CACHE PROXY SERVER (Node.js)                         │
│                     (currently 10.0.0.4:3000)                            │
│                                                                          │
│  ┌──────────────┐     ┌──────────────┐     ┌──────────────────────┐     │
│  │  Express     │────→│  PostgreSQL  │     │  Socket.IO           │     │
│  │  REST API    │     │  Database    │     │  (real-time chat)    │     │
│  └──────┬───────┘     └──────────────┘     └──────────────────────┘     │
│         │                                                                │
│         │  Proxied requests (server-to-server)                           │
└─────────┼──────────────────────────────────────────────────────────────┘
          │
          ▼
┌──────────────────────────────────────────────────────────────────────────┐
│                       THIRD-PARTY APIs                                   │
│                                                                          │
│  ┌──────────────┐  ┌──────────┐  ┌─────────┐  ┌──────────────────┐      │
│  │ Overpass     │  │ OpenSky  │  │ NWS     │  │ MBTA / Windy /   │      │
│  │ (OSM POIs)   │  │ Network  │  │Weather  │  │ FAA / FEMA       │      │
│  └──────────────┘  └──────────┘  └─────────┘  └──────────────────┘      │
└──────────────────────────────────────────────────────────────────────────┘
```

3.3 What Users See About Each Other

Data	Visible to Other Users?	Context
Username	Yes	Displayed on comments, ratings, and chat messages
Star ratings	Yes	Displayed on POI detail pages
Comment text	Yes	Displayed on POI detail pages
Chat messages	Yes (within the room)	Displayed in chat rooms the user has joined
GPS location	**No**	Never shared with other users
Device identifier	**No**	Internal use only
IP address	**No**	Server logs only
Online/offline status	Partially (chat presence)	Visible in chat rooms while actively connected

3.4 What Third Parties Receive

Third Party	Data Sent	Why
Overpass API (OSM)	Bounding box coordinates (geographic area, not user identity)	Fetch POIs for the visible map area
OpenSky Network	Bounding box coordinates	Fetch aircraft positions in the visible area
NWS	Latitude/longitude (for weather station lookup)	Fetch weather for user's location
MBTA	None (public API, no location sent)	Fetch all active vehicle positions
Google AdMob	Device advertising ID, approximate location (if permitted), device info	Serve targeted advertisements
Google Play Billing	Payment info (handled by Google, not by us)	Process subscription payments

3.5 Data at Rest & Encryption

Component	Encryption at Rest	Encryption in Transit
PostgreSQL database	Not currently encrypted at rest (planned for cloud migration)	N/A (localhost) → TLS when cloud-hosted
Passwords	Argon2id hash (irreversible)	HTTPS/TLS
JWT tokens	Stored in Android SharedPreferences (device-encrypted by OS)	HTTPS/TLS
Geofence SQLite databases	Not encrypted (public data)	HTTPS for download
API traffic (app ↔ server)	N/A	HTTPS/TLS 1.2+

3.6 What We Do NOT Collect

- Email addresses (not required for registration)
- Phone numbers
- Contacts or address book
- Photos, camera, or microphone data
- Browsing history outside the app
- Persistent location history (GPS is used in real-time, not stored)
- Financial information (Google handles billing)

---

4. Executive Summary of Legal Risks

LocationMapApp has 5 categories of legal/technical exposure that must be addressed before commercial launch:

Risk Category	Severity	Likelihood	Primary Concern
User-Generated Content	CRITICAL	HIGH	POI comments/ratings = defamation, harassment, fake reviews targeting businesses
Safety Data Accuracy	HIGH	MEDIUM	TFRs, flood zones, speed cameras, school zones — someone relies on wrong data
Privacy / Location Data	HIGH	HIGH	GPS = "sensitive personal information" under 21+ state laws
Third-Party API Licensing	MEDIUM	HIGH	OpenSky requires a commercial license; OSM ODbL has share-alike obligations
Ad + Billing Compliance	MEDIUM	MEDIUM	AdMob + location data, COPPA + ads, subscription auto-renewal laws

This document covers every step from forming a business entity to deploying cloud infrastructure to protecting yourself from lawsuits.

How to Read This Document

- **If you are the developer (Dean):** Read everything. The master checklist in Section 27 is your execution plan.
- **If you are a lawyer:** Start here, then read Section 26 (Specific Questions for the Attorney) to see exactly what we need your help with. Sections 5–17 contain the detailed legal analysis. Sections 18–27 are implementation details you can skim.
- **If you are a potential business partner or investor:** Part A gives you the full product and business picture. Part B covers legal risk. Section 24 has the cost projections.

PART B — Legal Analysis

---

5. Finding the Right Attorney

5.1 Type of Attorney Needed

You need a **technology/startup attorney** with experience in:

Area	Why
Software / SaaS licensing	Third-party API licenses, open-source compliance (ODbL, EPL-2.0)
Privacy law	CCPA/CPRA, state privacy laws, COPPA, location data
Terms of Service / EULA	Drafting enforceable ToS, arbitration clauses, liability limitations
Intellectual property	Copyright, provisional patents, trademark
Content moderation / Section 230	User-generated content liability, DMCA, Take It Down Act
Mobile app / Play Store	Google Play policies, billing compliance

Ideal profile: A solo practitioner or small firm (2–10 attorneys) that specializes in tech startups and app developers. Large firms (BigLaw) are overkill and too expensive for a pre-revenue solo developer.

5.2 Where to Find One

Resource	Details
Massachusetts Bar Association Lawyer Referral Service	masslawhelp.com — request a referral for "technology law" or "intellectual property"
SCORE Boston	score.org — free mentorship program, often connected to startup-friendly attorneys who offer initial consultations at reduced rates
Boston tech meetups	New England Tech Meetup, Boston Startup Legal Clinic, Cambridge Innovation Center events — networking opportunities to find attorneys who work with solo developers
Avvo / Martindale-Hubbell	Online directories with ratings and reviews, filter by practice area (Technology, IP, Privacy) and location (Boston / MA)
Law school clinics	Suffolk University Law School, Northeastern Law, BC Law — some run technology law clinics that provide free or low-cost legal advice to startups
Volunteer Lawyers for the Arts (VLA)	If income-eligible, provides free legal services for creative/tech projects

5.3 What to Bring to the First Meeting

1. **This document** (COMMERCIALIZATION.md) — printed or as PDF
2. **A live demo of the app** on your phone or emulator
3. **Section 26 of this document** (Questions for the Attorney) — printed as the meeting agenda
4. **IP.md** — your intellectual property register (14 innovations)
5. **A list of all third-party API terms of use** you've reviewed (OpenSky, OSM, MBTA, Windy, NWS)
6. **Your projected launch timeline**

5.4 Budget Expectations

Service	Expected Cost	Notes

Initial consultation	$0–$300	Many startup attorneys offer a free or reduced-rate first meeting (30–60 min)
ToS + Privacy Policy review	$1,000–$3,000	Attorney reviews your generated drafts, not drafting from scratch
LLC formation guidance	$200–$500	Or DIY for $100 (Wyoming)
IP strategy session	$500–$1,000	Review of patent candidates, trademark search strategy
Full engagement (retainer)	$2,000–$5,000	Covers ToS, privacy policy, IP advice, and ongoing questions through launch

5.5 Red Flags When Choosing an Attorney

- **No tech experience** — if they've never reviewed a SaaS ToS or mobile app privacy policy, look elsewhere
- **Insists on BigLaw hourly rates** ($500+/hr) for a pre-revenue app — disproportionate to your stage
- **Unfamiliar with Section 230** — this is foundational for any app with user-generated content
- **Pushes unnecessary services** — you don't need a full patent prosecution ($15K+ per patent) before you have revenue
- **Can't explain CCPA in plain English** — privacy law knowledge is essential for a location-based app

5.6 Timing

- **Ideal:** Engage an attorney **3–6 months before** Play Store submission
- **Minimum:** Have ToS and Privacy Policy reviewed **before** any public user touches the app
- **The OpenSky license issue** (Section 10.3) is blocking — the attorney can help negotiate or advise on alternatives

---

6. Business Entity & Insurance

6.1 Recommended: Wyoming LLC

An LLC separates your personal assets (house, savings, vehicle) from business liability. If someone sues LocationMapApp, they sue the LLC — not you personally.

Factor	Wyoming LLC	Delaware LLC	Delaware C-Corp
Formation fee	$100	$90	$89
Annual fee	$60	$300+ franchise tax	$300+ franchise tax
State income tax	None	None (if no DE operations)	None (if no DE operations)
Privacy	Anonymous ownership	Public records	Public records
Best for	Solo bootstrapped apps	—	Venture capital fundraising
Can convert later	Yes → C-Corp if needed	—	—

Action: File a Wyoming LLC online. Cost: **$100** + $60/year.

Tax note: Once net income exceeds ~$60K/year, elect S-Corp tax treatment (IRS Form 2553) to save on self-employment tax. No new entity needed — the LLC can elect S-Corp status.

6.2 Required Insurance

Given that you display safety-critical aviation/geofence data, collect GPS, and host user-generated content, you need three types of coverage:

Coverage	What It Covers	Annual Cost
Tech E&O (Errors & Omissions)	Claims from software bugs, inaccurate TFR/geofence data, service failures	$500–$1,000
Cyber Liability	Data breaches, hacking, regulatory fines from privacy violations	$1,500–$2,500
General Liability	Bodily injury, property damage, advertising injury	$500–$1,000

Combined Tech E&O + Cyber policies are available from Hiscox, Hartford, Embroker, or Insureon. Expect **$1,300–$3,000/year** total.

This is **not optional** given that the app displays TFR boundaries that pilots or drone operators could rely on.

---

7. Intellectual Property Protection

7.1 Protection Strategy Overview

Protection	What It Covers	Cost	Timeline	DIY?
Copyright Registration	Source code, UI	$65 each	3–8 months	Yes
Provisional Patents	14 algorithms	$60 each (micro-entity)	Filed in days	Partially
Trademark	App name, brand	$350 per class	12–18 months	Risky alone
Trade Secrets	Server-side code	$0	Immediate	Yes
R8 Obfuscation	APK reverse engineering	$0	Immediate	Yes

7.2 Copyright Registration

File at copyright.gov before publishing to the Play Store.

- **Form:** Standard Application (single work)
- **Deposit:** First 25 + last 25 pages of source code (trade secrets may be redacted/blocked out)
- **Cost:** $65 per registration
- **Recommendation:** File separately for the Android app and the Node.js server code = **$130 total**
- **Benefit:** Enables statutory damages ($750–$150,000 per infringed work) and attorney's fees if registered before infringement occurs

7.3 Provisional Patents

Your IP.md identifies 14 potentially patentable algorithms. Not all will survive the Alice/Mayo test for software patents.

What passes Alice scrutiny (potentially patentable):

- Software that makes computers work better (faster processing, reduced memory)
- Novel technical solutions to technical problems with specific implementation steps
- Unique combinations of techniques producing a non-obvious result

What likely fails:

- "Do a known thing but on a computer"
- Generic data sorting, filtering, or display concepts

Recommended approach:

1. **File DIY provisionals for the top 3–6 strongest candidates** to secure priority dates
    - Cost: $60 each at micro-entity rate (< 4 prior patents, income < ~$230K)
    - Total: **$180–$360**
    - Write detailed descriptions with flowcharts — provisionals have no formal claims requirement
2. **Hire a patent attorney within 12 months** to convert the strongest 2–3 to non-provisionals
    - Attorney cost: $8,000–$15,000 per patent
    - USPTO non-provisional filing: $320 (micro-entity)
    - Total prosecution through issuance: $15,000–$30,000 per patent
    - Timeline to issuance: 2–4 years

Strongest candidates from your IP.md (based on technical novelty):

1. Adaptive Radius Cap-Retry Algorithm (#1)
2. JTS R-Tree Geofence Engine (#5) — 220K+ zones on mobile at real-time speed
3. Probe-Calibrate-Spiral Scanner (#2)

7.4 Trademark

Search USPTO TESS first to ensure your app name isn't already registered in Class 9 (software).

- **Cost:** $350/class (use pre-approved identification of goods to avoid $200 surcharge)
- **Timeline:** First examination ~4.7 months; total registration 12–18 months
- **Maintenance:** $650/class every 10 years

7.5 Trade Secrets

Your server-side code (server.js, proxy logic, fuzzy search keyword mappings, caching strategies, database schema) is never distributed to users. This makes it ideal for trade secret protection.

Required "reasonable efforts" to maintain secrecy:

Measure	Status
GitHub repository set to private	Check
MFA on all code repository access	Set up if not done
SSH keys for server access	Set up if not done

Secrets in environment variables (not committed)	Already done (.env gitignored)
IP.md identifies trade secrets	Already done
NDA template for any future contractors	Need to create
`CONFIDENTIAL` marking on sensitive documents	Add to server.js header

Cost: $0 for technical measures. $300–$800 for an attorney-drafted NDA template if you bring on contractors.

---

8. User Content Liability — Your Biggest Legal Risk

8.1 The Risk

Your app allows users to:

- Post **comments and star ratings on POIs** (businesses, schools, parks, etc.)
- Send **real-time chat messages** in rooms

This means a user could post a defamatory review of a restaurant, harass another user in chat, post fake reviews to damage a competitor, or share personal information about someone.

8.2 Section 230 Protection

47 U.S.C. Section 230(c)(1) protects you: "No provider or user of an interactive computer service shall be treated as the publisher or speaker of any information provided by another information content provider."

What this means: You are NOT liable for defamatory, false, or harmful content posted by users. This is the same legal shield that protects Yelp, Google Reviews, TripAdvisor, and Reddit.

What Section 230 does NOT protect against:

- Federal criminal law violations (CSAM — you MUST report, see Section 18.5)
- Intellectual property claims (handled by DMCA, see Section 8.4)
- Content YOU create or materially alter (if you edit a user's comment and change its meaning, you become the "content provider")
- The Take It Down Act (signed May 19, 2025 — see Section 8.3)

Section 230(c)(2) additionally protects your good-faith moderation decisions — you cannot be sued for choosing to remove content.

8.3 The Take It Down Act (Compliance Deadline: May 19, 2026)

This law requires platforms hosting user-generated content to:

- Establish a process for individuals to request removal of **non-consensual intimate images** (including AI-generated deepfakes)
- Remove such content within **48 hours** of a valid notice
- Make "reasonable efforts" to find and remove identical copies

You must comply before May 19, 2026.

8.4 DMCA Safe Harbor

To maintain protection from copyright infringement claims, you MUST:

1. **Register a DMCA Designated Agent** with the US Copyright Office
    - Online at copyright.gov/dmca-directory
    - Fee: **$6** — renew every 3 years
    - Publish agent contact info in your app/website
2. **Implement Notice-and-Takedown:**
    - Accept copyright takedown notices via email
    - Remove infringing content "expeditiously" (within 24 hours best practice)
    - Notify the content poster
    - Accept counter-notices; restore content in 10–14 days if no court action
3. **Adopt a Repeat Infringer Policy:**
    - Terminate accounts of repeat copyright infringers
    - Document this in your Terms of Service

8.5 How Yelp/Google/TripAdvisor Handle This

All major review platforms rely on the same three-pillar strategy:

1. **Section 230 immunity** — they are not the publisher of user reviews
2. **Robust Terms of Service** — users indemnify the platform; users warrant content is truthful
3. **Content moderation** — voluntary moderation in good faith (strengthens legal position)

They do NOT pre-screen reviews. They respond to court orders and subpoenas. They allow businesses to respond to reviews but not remove them unilaterally.

8.6 What You MUST Include in Terms of Service

These provisions create your legal shield for user-generated content:

1. **User content license grant** — users grant you a non-exclusive license to display/store their content
2. **User representations** — users warrant content is truthful, non-infringing, non-defamatory
3. **User indemnification** — users agree to hold you harmless from claims arising from their content
4. **Content removal rights** — you may remove any content at your sole discretion
5. **DMCA procedure** — designated agent contact and takedown process
6. **Repeat infringer policy** — account termination for repeat copyright violators
7. **Disclaimer** — you do not endorse, verify, or guarantee user-generated content
8. **Prohibited content list** — defamation, harassment, fraud, illegal content explicitly banned
9. **Arbitration clause with class action waiver** — forces individual arbitration instead of class action lawsuits (standard for Yelp, Google, etc.)
10. **Anti-SLAPP reference** — frivolous lawsuits may result in attorney fee liability (38 states + DC have anti-SLAPP laws)

---

9. Privacy Law Compliance

9.1 The Core Problem

GPS data = "Sensitive Personal Information" under virtually every US state privacy law. "Precise geolocation" is defined as data identifying a person's location within 1,850 feet (~564 meters). Your GPS data absolutely qualifies.

9.2 State Privacy Laws (21 States and Growing)

As of early 2026, 21+ states have comprehensive consumer privacy laws. Key ones:

State	Effective	Location Data Treatment	Key Provision
California (CCPA/CPRA)	Active	Sensitive PI — right to limit	Most comprehensive; applies if >$25M revenue OR 100K+ consumers
Virginia (VCDPA)	Jan 2023	Sensitive data — opt-in consent	Sale of geolocation data ban pending
Colorado (CPA)	Jul 2023	Sensitive data — opt-in consent	Universal opt-out mechanism required
Texas (TDPSA)	Jul 2024	Sensitive data	**Applies to ALL businesses (no revenue threshold)**
Connecticut	Jul 2023	Sensitive data	Geofencing restrictions near health clinics (2026)
Maryland	Oct 2025	Strict data minimization	Geofencing restrictions near sensitive locations

9.3 What You Must Do (All States)

Required user rights you must support:

Right	Deadline	Implementation
Right to Know/Access	45 days	`/db/user-export/:userId` endpoint → JSON download
Right to Delete	45 days	Anonymize/delete all PII; cascade to service providers
Right to Correct	45 days	Allow users to update their profile data
Right to Data Portability	45 days	Export in machine-readable format (JSON)
Right to Opt Out of Sale/Sharing	Immediate	"Do Not Sell" mechanism (if applicable)
Right to Limit Sensitive Data Use	Immediate	Limit location processing to service-necessary purposes

Practical implementation:

- Add an in-app privacy settings screen with: "Request My Data", "Delete My Account", "Data Usage"
- Build a `/db/user-export/:userId` endpoint that generates a JSON file with: profile info, all comments/ratings, chat messages, account metadata
- Build account deletion that: (1) disables account immediately, (2) anonymizes PII within 30 days, (3) changes comment/message author to "Deleted User", (4) preserves moderation/safety records for 2 years
- Document all retention periods in your privacy policy

9.4 COPPA (Children Under 13)

The FTC's amended COPPA Rule takes effect **April 22, 2026**.

Your app collects GPS data and uses device-bonded auth (persistent device identifier). Both are "personal information" under COPPA.

Recommended approach: Exclude under-13 users entirely.

- Implement an age gate at first launch / registration
- State in Terms of Service that the app is not intended for children under 13
- If you discover a user is under 13, delete their data immediately
- Do NOT implement verified parental consent (complex and expensive) — just exclude them

9.5 Recommended Data Retention Schedule

Data Type	Retention Period
GPS location data	Delete after session ends or within 30 days
User accounts	Retain until deletion request or 2 years inactivity
Comments/ratings	Retain until user deletion (soft-delete → hard-delete in 30 days)
Chat messages	90 days, then auto-delete
Server logs (including IPs)	90 days maximum
Authentication tokens	Delete upon expiration
Moderation/safety records	2 years (legal compliance)

9.6 Device-Bonded Auth: Privacy Implications

Advantages: Minimizes data collection (no email/password required). Supports data minimization principles.

Challenges:

- Device identifier IS personal information under CCPA (persistent identifier)
- Cannot require account creation for privacy requests — need alternate verification
- Cross-device: new phone = orphaned account data

Solution: Provide an in-app "Privacy Request" button that uses the existing device token for verification. Also provide an email address for users who lost device access.

9.7 GDPR (European Union) — Future Expansion

If you make the app available in EU countries (or if EU residents download it from the US Play Store), the General Data Protection Regulation applies.

GDPR Requirement	Your Status	Action Needed
Lawful basis for processing	Consent (GPS) + Legitimate interest (service operation)	Implement consent mechanism at first launch
Right to erasure ("right to be forgotten")	Partially built (account deletion flow)	Ensure complete data removal including backups within 30 days

Data Protection Impact Assessment (DPIA)	Not done	Required for large-scale processing of location data
Data Processing Agreements (DPA)	None	Need DPAs with every third-party that receives personal data (cloud host, AdMob, analytics)
Cookie/tracking consent	N/A (native app, no cookies)	AdMob SDK may use device identifiers — consent required
Data breach notification	No process	Must notify supervisory authority within 72 hours of discovering a breach
EU Representative	Not appointed	Required if no EU establishment but offering services to EU residents (Art. 27)
Cross-border data transfers	US servers	Need Standard Contractual Clauses (SCCs) or adequacy decision for EU→US transfers

Key GDPR penalties: Up to €20 million or 4% of global annual revenue, whichever is higher. However, enforcement against small US-based app developers is rare — regulators focus on large companies. The risk increases significantly if you actively market in the EU or accumulate substantial EU user data.

Recommendation: Do not actively market in the EU at launch. If EU downloads grow organically, implement GDPR compliance when EU users exceed 1,000 or when revenue justifies the cost.

9.8 UK GDPR — Future Expansion

Post-Brexit, the UK has its own version of GDPR (UK GDPR + Data Protection Act 2018). Requirements are nearly identical to EU GDPR with these differences:

- **Supervisory authority:** ICO (Information Commissioner's Office) instead of EU DPAs
- **UK Representative:** Required if targeting UK users (separate from EU Art. 27 representative)
- **Data transfers:** UK has its own adequacy framework; US-UK Data Bridge simplifies transfers
- **Penalties:** Up to £17.5 million or 4% of global revenue

Recommendation: Same as EU — defer until UK user base justifies compliance costs.

9.9 Other International Privacy Laws

Jurisdiction	Law	Key Difference from US	When to Worry
Canada	PIPEDA + provincial laws	Consent required for all collection; breach notification to Privacy Commissioner	If targeting Canadian users
Brazil	LGPD	Similar to GDPR; DPO required for certain processing	If targeting Brazilian users
Australia	Privacy Act 1988 (amended 2024)	Geolocation is "sensitive information"; strict consent requirements	If targeting Australian users
Japan	APPI	Cross-border transfer restrictions; consent for sensitive data	If targeting Japanese users
South Korea	PIPA	Among the strictest globally; separate consent for each purpose	Unlikely near-term

9.10 International Expansion Privacy Roadmap

Phase	Market	Privacy Actions Required	Estimated Cost
Launch	US only	CCPA/state laws, COPPA, age gate	$0 (built into app)
Phase 2	US + Canada	Add PIPEDA consent flows, breach notification to OPC	$500–$1,000 (attorney review)
Phase 3	US + Canada + EU/UK	GDPR compliance, DPIA, DPAs, EU/UK representatives, SCCs	$3,000–$8,000
Phase 4	Global	Per-country compliance review	$5,000–$15,000

Do not incur international privacy costs until you have revenue and users in those markets.

---

10. Third-Party API & Data Licensing

10.1 License Status Summary

Data Source	Commercial Use?	Action Required	Risk
OpenStreetMap (ODbL)	Yes, with obligations	Attribution + share-alike compliance	MEDIUM
OpenSky Network	**NO — requires commercial license**	**Contact contact@opensky-network.org**	**BLOCKING**
NWS Weather	Yes, free, public domain	Set proper User-Agent header	LOW
FAA TFR Data	Yes, free, public domain	Add accuracy disclaimers	LOW
FEMA Flood Data	Yes, free, public domain	Don't represent as "official"	LOW
MBTA API	Review MassDOT license agreement	Download and review PDF	MEDIUM
Windy Webcams	Free tier has limitations	Review if pro tier needed	LOW

10.2 OpenStreetMap ODbL — Critical Details

The ODbL **permits commercial use** but has a **share-alike clause** for Derivative Databases.

Your architecture:

- You import ~208K OSM POIs into PostgreSQL (`pois` table)
- You add your own categories/subtypes to those records
- Users add comments/ratings in separate tables (`poi_comments`)

Legal interpretation:

- Your `pois` table with OSM data + your modifications = likely a **Derivative Database** → must be shared under ODbL if requested
- Your `poi_comments`, `users`, `chat_rooms`, `messages` = **NOT derivative** → fully yours, not subject to ODbL
- The rendered map in the app = **Produced Work** → not subject to share-alike

Required actions:

1. Display OSM attribution on the map: "© **OpenStreetMap contributors**" with link to openstreetmap.org/copyright
2. Be prepared to share your modified POI database under ODbL if anyone requests it
3. Your user-generated content is NOT subject to ODbL share-alike

Note: ODbL does not prevent you from charging for your app or service. But anyone can redistribute the ODbL-licensed data for free.

10.3 OpenSky Network — COMMERCIAL LICENSE REQUIRED

This is a blocking issue. OpenSky's Terms of Use grant a license "solely for the purpose of non-profit research, non-profit education, or for government purposes."

Commercial use explicitly includes selling applications using the API.

Action: Email **contact@opensky-network.org** to negotiate a commercial license BEFORE launching. OpenSky is a Swiss non-profit — be prepared for potential licensing fees or restrictions.

Fallback options if OpenSky denies commercial access:

- ADS-B Exchange (commercial API available)
- FlightAware API (commercial tiers)
- ADSBHub
- Self-hosted ADS-B receiver (if targeting specific geography)

10.4 MBTA API

Usage requires acceptance of the MassDOT Developers License Agreement. Download the PDF from mbta.com/developers and review for commercial use provisions before launch.

10.5 Windy Webcams

Free tier limitations:

- Low-resolution images only
- Image URLs expire after 10 minutes
- Cannot be used solely in a paid portion of your app
- Attribution required: "Provided by Windy" with logo and link

If your app is free to download, the free tier may be sufficient. If you add paid features, review the Professional tier pricing at api.windy.com/webcams/pricing.

---

11. Third-Party Dependency Inventory

A complete audit of all third-party libraries used in the app and server. An attorney should review licenses flagged as **REVIEW** or **RISK**.

11.1 Android App Dependencies

Library	Version	License	Risk	Notes

androidx-core	1.12.0	Apache 2.0	LOW	Google's core Android library
appcompat	1.6.1	Apache 2.0	LOW	Backward-compatible Android UI
material	1.11.0	Apache 2.0	LOW	Google Material Design components
constraintlayout	2.1.4	Apache 2.0	LOW	Layout engine
lifecycle-viewmodel-ktx	2.7.0	Apache 2.0	LOW	Android lifecycle management
lifecycle-runtime-ktx	2.7.0	Apache 2.0	LOW	Android lifecycle management
activity-ktx	1.8.2	Apache 2.0	LOW	Android activity extensions
hilt-android	2.51	Apache 2.0	LOW	Dependency injection (Google/Dagger)
play-services-location	21.1.0	Proprietary (Google)	LOW	Google Play Services for GPS; requires Play Store distribution
osmdroid-android	6.1.18	Apache 2.0	LOW	OpenStreetMap map renderer
osmdroid-mapsforge	6.1.18	Apache 2.0	LOW	Offline map tile support
osmbonuspack	6.9.0	LGPL-3.0	**REVIEW**	Map overlay utilities; LGPL allows use in proprietary apps if dynamically linked (Android does this via Gradle)
retrofit	2.9.0	Apache 2.0	LOW	HTTP client for REST APIs
okhttp	4.12.0	Apache 2.0	LOW	HTTP networking library
gson	2.10.1	Apache 2.0	LOW	JSON serialization (Google)
kotlinx-coroutines-android	1.7.3	Apache 2.0	LOW	Kotlin async programming
kotlinx-coroutines-core	1.7.3	Apache 2.0	LOW	Kotlin async programming
room-runtime	2.6.1	Apache 2.0	LOW	SQLite database abstraction (Google)
jts-core	1.19.0	EPL-2.0	**REVIEW**	Java Topology Suite for geofencing; EPL-2.0 is weak copyleft — OK when used as a library (not modified and redistributed), which is our case
socket.io-client	2.1.0	MIT	LOW	WebSocket client for real-time chat
browser (Custom Tabs)	1.7.0	Apache 2.0	LOW	Chrome Custom Tabs for opening links
preference	1.2.1	Apache 2.0	LOW	Android settings/preferences UI

11.2 Node.js Server Dependencies

Library	Version	License	Risk	Notes
express	^4.21.0	MIT	LOW	Web server framework
pg	^8.13.0	MIT	LOW	PostgreSQL client

socket.io	^4.8.3	MIT	LOW	WebSocket server for real-time chat
jsonwebtoken	^9.0.3	MIT	LOW	JWT token generation/validation
argon2	^0.44.0	MIT	LOW	Password hashing
express-rate-limit	^7.5.1	MIT	LOW	API rate limiting
better-sqlite3	^11.10.0	MIT	LOW	SQLite for geofence database generation
cheerio	^1.0.0	MIT	LOW	HTML parsing (web scraping)
fast-xml-parser	^4.3.0	MIT	LOW	XML parsing for weather/aviation APIs
lzma-native	^8.0.6	MIT	LOW	Compression for database downloads
undici	^6.23.0	MIT	LOW	HTTP client (Node.js native replacement for node-fetch)
duck-duck-scrape	^2.2.5	MIT	**RISK**	DuckDuckGo search scraping library; **may violate DuckDuckGo's Terms of Service** — scraping without permission is a legal gray area

11.3 Flagged Dependencies — Attorney Review Recommended

Library	Issue	Recommendation
osmbonuspack (LGPL-3.0)	LGPL requires that users can re-link with a modified version of the library. Android's Gradle dependency system satisfies this — the user can swap the library by recompiling. No source code disclosure required.	**Low risk** — document in license notices that LGPL library is used as a dynamic dependency
jts-core (EPL-2.0)	Eclipse Public License 2.0 is weak copyleft. If you modify JTS source code, you must share modifications under EPL-2.0. If you only USE it as a library (our case), no obligations beyond attribution.	**Low risk** — add EPL-2.0 notice to About/Legal screen
duck-duck-scrape	This library scrapes DuckDuckGo search results, which likely violates DuckDuckGo's Terms of Service. If DuckDuckGo sends a cease-and-desist, you must comply.	**Medium risk** — evaluate whether this dependency is essential; consider replacing with a licensed search API

11.4 Hardcoded Secrets Audit

The following values are currently hardcoded or stored in environment variables that need to be secured before production:

Secret	Current Location	Action Needed
Proxy server IP (10.0.0.4:3000)	Hardcoded in Android app	Replace with domain name (api.yourdomain.com)
OpenSky client ID/secret	Environment variable (startup command)	Move to secrets manager or .env file (not committed)
JWT secret	Generated at runtime (openssl rand)	Use a persistent secret stored in secrets manager
Database password	Environment variable (startup command)	Move to secrets manager; change from current value

12. Ad Network Compliance

12.1 Google AdMob Overview

Google AdMob is the recommended ad network for Android apps. It integrates with Google Play Billing and provides banner ads, interstitial ads, and rewarded ads.

12.2 AdMob + Location Data

Displaying ads in a location-aware app creates specific compliance obligations:

Requirement	Details
Google's Consent Framework	Must implement Google's User Messaging Platform (UMP) SDK for consent management — required for personalized ads
Personalized vs. non-personalized ads	If user declines consent, serve only non-personalized ads (lower eCPM but legally compliant)
Location data and ads	AdMob can use device location for ad targeting if user consents; you MUST disclose this in your privacy policy
ATT (iOS) equivalent on Android	Android Privacy Sandbox is replacing GAID (Google Advertising ID) — implement Topics API for forward compatibility
Data Safety Section	Must declare AdMob's data collection in Google Play Data Safety form

12.3 COPPA and Ads

Critical: If any user under 13 could access your app (even with an age gate), you must:

- Tag ad requests as child-directed (`tagForChildDirectedTreatment`) if the user's age is unknown
- Disable personalized advertising for users who cannot consent
- NOT collect device advertising IDs from children

Your strategy (exclude under-13 entirely + age gate) avoids most COPPA ad complications. However, if a child lies about their age and you serve personalized ads, you could face FTC enforcement. The age gate provides a defense but is not bulletproof.

12.4 Ad Content Filtering

AdMob allows you to filter ad categories. For a map/safety app, consider blocking:

- Gambling ads
- Political ads
- Age-restricted content (alcohol, tobacco)
- Competitive mapping/navigation app ads (optional but strategic)

Configure these in the AdMob dashboard under "Blocking controls."

12.5 AdMob Implementation Requirements

Requirement	Status

AdMob account (Google account required)	Not created
AdMob SDK integration in Android app	Not implemented
UMP SDK for consent management	Not implemented
Ad unit IDs (banner, interstitial)	Not created
Privacy policy updated with ad data collection	Not done
Data Safety Section updated	Not done
Test ads during development (required by Google)	Not done

12.6 Revenue Expectations

AdMob pays on a net-60 basis (payment 60 days after the end of the earning month). Minimum payout threshold: $100.

Ad Format	Typical eCPM (US)	User Experience Impact
Banner (320×50)	$0.50–$2.00	Low — persistent small banner at bottom of screen
Interstitial (full-screen)	$4.00–$10.00	Medium — show between natural transitions (e.g., closing POI detail)
Rewarded video	$10.00–$20.00	Low — user opts in (e.g., "Watch ad to unlock feature")

Recommendation: Start with bottom banner + occasional interstitial (on natural transitions like closing the Find dialog). Do NOT interrupt map usage with interstitials — users will uninstall.

---

13. In-App Purchase & Google Play Billing

13.1 Google Play Billing Library

To sell subscriptions or one-time purchases inside the app, you must integrate the Google Play Billing Library.

Component	Version	Notes
billing (com.android.billingclient:billing-ktx)	7.x+	Add to app/build.gradle
Google Play Console	—	Set up in-app products and subscriptions

13.2 Subscription Tiers (Proposed)

Tier	Price	Billing Cycle	Features
Free	$0	—	Full app with ads
Premium Monthly	$2.99–$4.99	Monthly auto-renewal	No ads + premium features
Premium Annual	$24.99–$39.99	Annual auto-renewal	No ads + premium features (save ~30%)

13.3 Google's Revenue Share

Scenario	Google's Cut	You Keep
First $1M in annual revenue (Reduced Service Fee)	15%	85%
Over $1M annual	30%	70%
Alternative billing (post-Epic v. Google)	~11–26%	74–89%

The 15% reduced rate applies automatically for the first $1M/year in Play Store revenue through the Google Play Small Developer Program. You must opt in via the Play Console.

13.4 Post-Epic v. Google Landscape

The Epic v. Google verdict (December 2023) and subsequent injunction (effective October 2025) changed the rules:

- **Alternative billing:** Developers can use their own payment systems (Stripe, PayPal, etc.) or link to external websites for purchase
- **Alternative app stores:** Google must allow alternative Android app stores and sideloading
- **Reduced commission:** If using alternative billing, Google may charge a reduced service fee (4% less than standard rate)
- **User choice billing:** Google's own "User Choice Billing" pilot allows offering alternatives at checkout

Recommendation for launch: Use Google Play Billing exclusively at first (simplest integration, established trust). Evaluate alternative billing if monthly revenue exceeds $5,000 and the 15% commission becomes a significant cost.

13.5 Subscription Legal Requirements

Requirement	Law/Policy	Details
Clear pricing disclosure	FTC, state auto-renewal laws	Price, billing frequency, and renewal terms must be clearly stated before purchase
Easy cancellation	CA Auto-Renewal Law (ARL), FTC "Click-to-Cancel" Rule (2025)	Cancellation must be as easy as signup — cannot require calling a phone number
Free trial disclosure	FTC, Google Play policy	If offering a free trial, clearly state when billing begins and how to cancel
Refund policy	Google Play policy	Google handles refunds for first 48 hours; your ToS should state your policy beyond that
Price change notice	Google Play policy	Users must be notified and consent to price increases

13.6 Tax Implications of In-App Purchases

Google collects and remits sales tax in most US states for Play Store transactions. You do NOT need to collect sales tax yourself for Play Store sales. See Section 14 for full tax details.

---

14. Tax Considerations

14.1 Sales Tax (Marketplace Facilitator Laws)

Good news: Google is a "marketplace facilitator" in all US states that require sales tax collection. This means Google collects and remits sales tax on your behalf for all Google Play Store transactions (subscriptions, in-app purchases).

You do NOT need to:

- Register for sales tax permits in every state
- Collect sales tax from users
- File sales tax returns for Play Store revenue

You DO need to:

- Confirm this applies in your state (it does for MA)
- Keep records of Google's tax collection reports (available in Play Console)
- Be aware that if you sell outside the Play Store (e.g., web subscriptions, direct sales), you may need to collect sales tax yourself

14.2 Income Tax — Federal and State

Entity Type	Federal Tax	State Tax (MA)	Self-Employment Tax
Sole proprietor (no LLC)	Schedule C on personal return	MA income tax (5% flat) + nexus in WY ($0)	15.3% on net profit
Single-member LLC (default)	Same as sole proprietor (pass-through)	Same	15.3% on net profit
LLC with S-Corp election	Reasonable salary + distributions	Same	SE tax only on salary (not distributions)

14.3 S-Corp Election — When It Saves Money

Once net profit exceeds ~$60,000/year, an S-Corp election can save significant self-employment tax:

Net Profit	No S-Corp (SE Tax)	With S-Corp (SE Tax on $40K salary)	Annual Savings
$60,000	~$9,180	~$6,120	~$3,060
$100,000	~$15,300	~$6,120	~$9,180
$150,000	~$19,650*	~$6,120	~$13,530

*SE tax caps at the Social Security wage base (~$168,600 in 2026) for the 12.4% portion.

Action: File IRS Form 2553 when income justifies it. The LLC stays the same — S-Corp is just a tax election.

14.4 Estimated Quarterly Taxes

As a self-employed developer, you must make quarterly estimated tax payments if you expect to owe $1,000+ for the year:

Quarter	Due Date	What to Pay
Q1	April 15	25% of estimated annual tax
Q2	June 15	25% of estimated annual tax

Q3	September 15	25% of estimated annual tax
Q4	January 15 (next year)	25% of estimated annual tax

Failure to pay estimated taxes results in a penalty (currently ~8% annualized interest rate).

14.5 Business Expenses (Deductible)

All costs in this document are legitimate business expenses:

Expense	Deductible?	Category
Cloud hosting	Yes	Business operating expense
Insurance	Yes	Business insurance
Domain registration	Yes	Business operating expense
LLC formation/maintenance	Yes	Legal/professional services
Copyright/trademark filing fees	Yes	Legal/professional services
Attorney fees	Yes	Legal/professional services
CPA fees	Yes	Accounting
Home office (portion of rent/utilities)	Yes	Home office deduction (simplified: $5/sq ft, max 300 sq ft = $1,500)
Computer/phone used for development	Yes (partial)	Equipment (Section 179 or depreciation)
Google Play developer account ($25)	Yes	Business license/subscription
Internet service (business portion)	Yes (partial)	Utilities

14.6 International Tax

If you earn revenue from users in other countries:

- **Google handles withholding tax** for many countries via tax treaties
- **You report all worldwide income** on your US tax return
- **Foreign tax credits** may be available for taxes withheld by other countries
- **No action needed at launch** — Google's systems handle international tax collection and reporting

14.7 When to Hire a CPA

Hire a CPA (not just a tax preparer — a licensed Certified Public Accountant) when:

- Annual app revenue exceeds $10,000
- You're considering S-Corp election
- You need quarterly estimated tax calculations
- You want to maximize business deductions

Cost: $200–$500 for initial consultation; $300–$800/year for annual tax preparation for a small LLC.

---

15. Social Media Integration

15.1 Current Status

LocationMapApp does **not** currently integrate with social media platforms. Authentication is device-bonded (no social login). There is no sharing to Facebook, Twitter/X, Instagram, or other platforms.

15.2 Potential Future Integrations

Integration	Purpose	Privacy Implications
"Share to" button	Let users share a POI or comment to social media (generates a link/card)	Minimal — only shares public content the user explicitly chooses to share
Social login (Google, Apple, Facebook)	Alternative login method — reduces friction for users who don't want device-bonded auth	Receives user's name/email/profile photo from the provider; must disclose in privacy policy; must comply with each platform's API ToS
Deep links from social media	Someone clicks a shared POI link on Twitter and it opens the app	Minimal — standard mobile deep linking

15.3 Social Login — Legal Requirements

If you add social login in the future:

Platform	Key ToS Requirements	Data You Receive	Must Disclose
Google Sign-In	Must comply with Google API Services User Data Policy; limited use of scopes; cannot sell user data	Email, name, profile photo, Google ID	In privacy policy and Data Safety Section
Apple Sign In	Required if you offer any third-party login (App Store rule, not Play Store); "Hide My Email" relay option	Email (possibly relay), name, Apple ID	In privacy policy
Facebook Login	Must comply with Meta Platform Terms; annual Data Use Checkup; cannot use data for surveillance	Email, name, profile photo, Facebook ID	In privacy policy and data use disclosures

15.4 Content Sharing — Legal Considerations

If users can share app content (POI ratings, comments, map views) to social media:

- **User content on social platforms** — once shared, content is governed by that platform's ToS; you have no control over it
- **OSM attribution** — if a shared image includes the map, you should include "© OpenStreetMap contributors" in the shared content
- **Screenshot/image rights** — your ToS should clarify that users can share their own content but cannot share other users' content without permission
- **Link previews (Open Graph tags)** — if you create a web page for shared POIs, the preview card should not reveal the sharer's location

15.5 Recommendation

For launch: No social media integration. Keep it simple. Device-bonded auth is a privacy advantage — market it as a feature ("No email required, no social tracking").

Post-launch (when user demand is clear):

1. Add a "Share POI" button that generates a simple link (no personal data in the URL)
2. Consider Google Sign-In as an optional alternative login method
3. Do NOT require social login — always keep the device-bonded option

---

16. Safety Data Liability & Disclaimers

16.1 The Risk Scenarios

Scenario	Your Exposure
Pilot flies into a TFR that your app didn't show	Potential negligence claim
Driver gets a speed camera ticket at a location your app said had no camera	Low risk (driver's responsibility)
Someone builds in a flood zone your app didn't mark	Low risk (official FEMA maps govern)
Drone operator flies in a no-fly zone not in your DJI database	Potential negligence claim

16.2 Protection Strategy

Three layers of protection:

1. **Disclaimers** — In ToS, in-app, and on first use of safety features (see Section 19.2)
2. **Insurance** — Tech E&O covers claims from inaccurate data ($500–$1,000/year)
3. **"As Is" + Limitation of Liability** — Caps your exposure

Additional protection for aviation data:

- Consider a one-time acknowledgment dialog users must accept before viewing TFR/aircraft data
- Never describe TFR boundaries as "official" or "authoritative"
- Include data freshness timestamps on all safety overlays

16.3 Legal Precedent

Courts generally uphold "as is" disclaimers and limitation of liability clauses in consumer software. However, disclaimers may NOT protect against:

- Gross negligence (knowingly displaying wrong data)
- Willful misconduct
- Affirmative representations of accuracy that you cannot support

Rule: Never promise accuracy. Always disclaim. Always point users to official sources.

---

17. Competitor & Comparable Analysis

Understanding how comparable apps handle legal and business issues provides useful benchmarks for your attorney.

17.1 Competitor Comparison

App	Category	Revenue Model	Key Legal Approach	Relevance to LocationMapApp
Google Maps	Maps + reviews	Free (ad-supported) + Google One integration	Massive legal team; user reviews protected by Section 230; ToS includes arbitration + class action waiver; GDPR-compliant globally	Gold standard for map + review legal framework; your ToS should follow similar structure
Yelp	Business reviews	Freemium (free + ads; paid for business owners)	Heavy Section 230 reliance; sued ~2,000 times by businesses over reviews and always won; strong anti-SLAPP strategy	Most relevant comparable for your POI comments/ratings feature; proves the legal model works
Flightradar24	Aircraft tracking	Freemium ($1.49–$49.99/year premium tiers)	Licensed ADS-B data + community receivers; disclaimers on data accuracy; GDPR-compliant (Swedish company)	Direct comparable for your aircraft tracking feature; their data licensing model is what you need with OpenSky
Transit App	Real-time transit	Free + paid tier ("Transit Royale")	Licensed transit data from agencies; location data used only for transit; privacy-focused	Comparable for your MBTA transit feature; demonstrates transit API licensing approach
Waze	Maps + traffic + speed cameras	Free (ad-supported, owned by Google)	User-reported speed cameras/police — legal in all US states (1st Amendment); strong disclaimers on data accuracy	Comparable for speed camera/safety data; validates that crowdsourced safety data is legally defensible
AllTrails	Outdoor maps + reviews	Freemium ($35.99/year for AllTrails+)	User reviews + trail ratings; offline maps as premium feature; standard ToS + arbitration	Comparable revenue model (freemium with offline features as premium); similar review liability profile
RadarScope	Weather radar	Paid ($9.99 one-time + $9.99/year Pro)	Radar data from NWS (public domain); strong "not for safety-critical use" disclaimers	Comparable for weather/safety data disclaimers; good model for liability language
Aloft (formerly AirMap)	Drone airspace	Freemium (free + enterprise tiers)	FAA LAANC authorization integration; TFR/airspace data with strong disclaimers; B4UFLY partnership	Directly comparable for TFR/geofence features; their disclaimer language is a useful template

17.2 Key Takeaways for Your Attorney

1. **Section 230 works:** Yelp has won every review-related lawsuit using Section 230 + anti-SLAPP. Your comment/rating feature follows the same legal pattern.
2. **Safety data disclaimers are standard:** Waze, RadarScope, and Aloft all display safety-critical data with "informational only" disclaimers and have not faced successful negligence claims.
3. **Freemium with ads is proven:** Google Maps, Waze, and AllTrails all use freemium models with advertising. The legal framework is well-established.
4. **Aircraft tracking requires licensing:** Flightradar24 licenses data from multiple sources. Your OpenSky dependency must be resolved similarly.
5. **No comparable app has been successfully sued for inaccurate map data** when proper disclaimers were in place. The legal risk is real but manageable.

PART C — Implementation & Execution

---

18. Content Moderation System

18.1 Automated Moderation (Free Tools)

Service	Cost	What It Does	Latency
OpenAI Moderation API	**Free**	13 harmful content categories, 40 languages	~47ms
Google Perspective API	**Free**	Toxicity scoring (0–1 scale)	~108ms

Recommended: Use OpenAI Moderation as the primary filter on every comment and chat message before storing/broadcasting. Add Perspective API as a secondary quality scorer.

Integration in server.js:

```
async function moderateContent(text) {
    const response = await fetch('https://api.openai.com/v1/moderations', {
        method: 'POST',
        headers: {
            'Authorization': `Bearer ${process.env.OPENAI_API_KEY}`,
            'Content-Type': 'application/json'
        },
        body: JSON.stringify({ model: "omni-moderation-latest", input: text })
    });
    const result = await response.json();
    return result.results[0]; // { flagged: bool, categories: {...}, category_scores:
{...} }
}
```

18.2 Tiered Moderation System

```
TIER 1 — Auto-Block (score > 0.95 on any harmful category):
  → Reject content instantly, notify user, log for review

TIER 2 — Queue for Review (score 0.60-0.95):
  → Hold content, don't publish, add to moderation queue
  → Review once or twice daily (15-30 minutes)
```

```
TIER 3 — Auto-Approve (score < 0.60 on all categories):
  → Publish immediately, subject to community reports

TIER 4 — Community Reports:
  → 3+ reports on any content → moves to review queue
  → Reporter gets acknowledgment; reported user not notified
```

18.3 Community Reporting System

Every comment and chat message needs a "Report" button with these categories:

- Spam or advertising
- Hate speech or discrimination
- Harassment or bullying
- False or misleading information
- Personal information (doxxing)
- Sexually explicit content
- Dangerous or illegal activity
- Other (free text)

Database addition needed:

```
CREATE TABLE content_reports (
    id SERIAL PRIMARY KEY,
    reporter_user_id INTEGER REFERENCES users(id),
    content_type VARCHAR(20) NOT NULL,  -- 'comment', 'message'
    content_id INTEGER NOT NULL,
    reported_user_id INTEGER REFERENCES users(id),
    category VARCHAR(50) NOT NULL,
    description TEXT,
    status VARCHAR(20) DEFAULT 'pending',  -- pending, reviewed, actioned, dismissed
    moderator_notes TEXT,
    created_at TIMESTAMPTZ DEFAULT NOW(),
    reviewed_at TIMESTAMPTZ
);

CREATE TABLE moderation_actions (
    id SERIAL PRIMARY KEY,
    user_id INTEGER REFERENCES users(id),
    action_type VARCHAR(20) NOT NULL,  -- 'warning', 'suspension', 'ban'
    reason TEXT NOT NULL,
    duration_hours INTEGER,  -- NULL for permanent
    content_id INTEGER,
    content_type VARCHAR(20),
    created_at TIMESTAMPTZ DEFAULT NOW(),
    expires_at TIMESTAMPTZ,
    appeal_status VARCHAR(20) DEFAULT 'none'  -- none, pending, upheld, overturned
);
```

18.4 Handling Specific Content Types

Problem	Prevention	Response

Spam on POIs	Rate limit: 5 comments/user/hour, 20/day. Auto-flag URLs, all-caps	Shadow ban repeat spammers
Hate speech in chat	Real-time moderation API before Socket.IO broadcast	Auto-mute → 24h mute → permanent ban
Fake reviews	Require 24h account age. One review per user per POI	Flag statistically anomalous rating patterns
Doxxing	PII detection (regex for phone, SSN, email, address)	Auto-redact PII. 7-day suspension for intentional doxxing
Harassment	User blocking (blocked user's content hidden)	Warning → 3-day → 30-day → permanent ban

18.5 CSAM Detection — Federal Law Requirements (Non-Negotiable)

18 U.S.C. 2258A requires:

1. If you gain "actual knowledge" of CSAM on your platform, you **MUST** report to NCMEC within 24 hours
2. You **MUST NOT** destroy evidence
3. You **MUST NOT** notify the uploading user

Before launch:

- Register with NCMEC: email **espteam@ncmec.org**
- If you ever allow image uploads: integrate PhotoDNA (free for qualified platforms) for hash matching against known CSAM
- Since your app is currently text-only (comments + chat): monitor for URLs linking to CSAM

18.6 Moderation at Your Scale (< 10K Users)

Component	Cost
OpenAI Moderation API	Free
Perspective API	Free
Your daily review time	15–30 min/day
NCMEC registration	Free
Total additional cost	**$0**

When you reach 10K–50K users, consider a part-time community moderator ($15–$25/hr, 5–10 hrs/week).

---

19. Required Legal Documents

19.1 Document Checklist

Document	Required By	Generation Cost	Attorney Review

Terms of Service	Google Play, common law	$0–$50 (Termly/ TermsFeed)	$500–$1,500
Privacy Policy	Google Play, CCPA, 21+ state laws	$0–$50	$500–$1,500
Community Guidelines	Best practice	$0 (write yourself)	Optional
DMCA Policy	17 U.S.C. 512 (safe harbor)	$0 (write yourself)	Optional
EULA	Google Play (optional, they have a default)	$0–$50	Optional

Recommended approach: Generate drafts using Termly (free tier) or TermsFeed ($10–$50/document), then have an attorney review them for **$1,000–$3,000 total**. This is the best cost/quality balance.

19.2 Terms of Service Must-Haves (Specific to Your App)

Beyond the standard provisions in Section 8.6, your ToS MUST include:

Safety data disclaimer:

> *"The geofence, aviation, flood zone, speed camera, school zone, weather, and other safety-related data displayed in this application is provided for informational purposes only and is not guaranteed to be accurate, complete, current, or reliable. Users must not rely on this application as their sole source of safety-critical information."*

"As Is" disclaimer:

> *"This application is provided 'AS IS' and 'AS AVAILABLE' without warranty of any kind, express or implied, including warranties of merchantability, fitness for a particular purpose, accuracy, or non-infringement."*

Limitation of liability:

> *"In no event shall [Company] be liable for any indirect, incidental, special, consequential, or punitive damages resulting from your reliance on any data displayed in this application."*

Aviation-specific disclaimer:

> *"TFR data is for reference only. Pilots and drone operators must verify all restricted airspace through official FAA sources (tfr.faa.gov) before flight."*

Age gate:

> *"This application is intended for users aged 13 and older. By using this application, you represent that you are at least 13 years old."*

Arbitration clause:

> *Mandatory individual arbitration with class action waiver. This prevents class action lawsuits. Standard for Yelp, Google, Uber, etc.*

19.3 Privacy Policy Must-Haves

Your privacy policy must disclose:

1. **Data collected:** GPS coordinates (precise geolocation), device identifier, username, user-generated

content (comments, ratings, chat messages), usage data (POIs viewed, searches), IP addresses
2. **How data is used:** Provide mapping service, display nearby POIs, enable social features, geofence alerting, content moderation
3. **Third parties receiving data:** Your backend server, OpenSky Network, Overpass/OSM, NWS, MBTA, Windy, Google AdMob, law enforcement (when required)
4. **Retention periods:** Per the schedule in Section 9.5
5. **User rights:** Access, delete, correct, export, opt-out (per Section 9.3)
6. **Children's privacy:** Not intended for under-13; immediate deletion if discovered
7. **Security measures:** HTTPS/TLS, Argon2id password hashing, token-based auth
8. **Contact information:** Email for privacy requests
9. **Advertising data:** What AdMob collects, how to opt out of personalized ads (see Section 12)

---

20. Google Play Store Requirements

20.1 Required Before Submission

Requirement	Status	Action
Privacy Policy link	Need	Create and host
Data Safety Section	Need	Complete in Play Console
Prominent location disclosure	Need	In-app dialog on first GPS use
Background location justification	Check	Only if using background location
Content rating questionnaire	Need	Complete in Play Console
Target audience declaration	Need	Declare 13+
EULA (optional)	Google default available	Custom recommended

20.2 Prominent Location Disclosure (Required)

Google Play requires a prominent in-app disclosure for location access that:

- Is displayed during normal app usage (not buried in settings)
- Describes what data is collected (precise GPS coordinates)
- Explains how data is used (map display, nearby POIs, geofence alerts)
- Cannot only appear in the privacy policy or Terms of Service

Implementation: Show a dialog on first launch before requesting location permission.

20.3 Data Safety Section

You must accurately declare in the Play Console:

Data Type	Collected	Shared	Purpose
Precise location	Yes	Yes (with your server)	App functionality
Device ID	Yes	No	Authentication

User-generated content	Yes	Yes (displayed to other users)	Social features
Chat messages	Yes	Yes (displayed to chat room members)	Social features
Advertising data	Yes (if AdMob integrated)	Yes (with Google AdMob)	Advertising

20.4 Monetization Note (Post-Epic v. Google)

As of January 28, 2026, Google can no longer require Google Play Billing exclusively for US users. You may use alternative billing systems or link to external purchase pages. However, Google may apply a service fee on alternative billing transactions.

---

21. User Account Management & Law Enforcement

21.1 Account Discipline Escalation

```
Level 1 — Warning:
  First minor violation. Content removed + in-app notification.

Level 2 — Temporary Suspension (24 hours):
  Second minor or first moderate violation. Read-only access.

Level 3 — Extended Suspension (7-30 days):
  Repeated violations or serious violation. Account fully suspended.

Level 4 — Permanent Ban:
  Severe violation (CSAM, doxxing, credible threats) or 3+ suspensions.
  Device ID flagged to prevent re-registration.
```

21.2 Appeal Process

1. Include appeal instructions in every suspension/ban notification
2. Accept appeals via email (simplest for solo developer)
3. Commit to 7 business days review time
4. Re-examine original content, moderation scores, and appeal
5. Document all decisions (creates good-faith record)

21.3 Data Export & Deletion

On account deletion request:

1. Disable account immediately
2. Within 30 days: anonymize PII, change author to "Deleted User" on comments/messages
3. Preserve moderation/safety records for 2 years
4. Send deletion confirmation

On data export request:

- Generate JSON with: profile, all comments/ratings, chat messages, account metadata
- Deliver within 45 days (CCPA requirement)

21.4 Law Enforcement Requests

Prepare a procedure BEFORE you receive your first request.

Legal Process	Requires Judge?	What You Must Provide
Subpoena	No	Basic subscriber records: username, email, account creation date, login IPs
Court Order	Yes	Non-content: message headers, IP logs, session data
Search Warrant	Yes (probable cause)	Content: messages, comments, location history

Response procedure:

1. Verify legitimacy (case number, issuing court, valid contact)
2. Log the request
3. Consult an attorney for your first few requests ($500–$1,000 one-time consultation)
4. Produce only what's legally required — nothing more
5. Notify affected user unless gag order prevents it
6. You may seek cost reimbursement under 18 U.S.C. 2706

Proactive measures:

- Publish law enforcement guidelines on your website
- Minimize data retention — you can't be compelled to produce data you don't have
- Encrypt data at rest

---

22. APK Protection & Obfuscation

22.1 Enable R8 (Required for Release Builds)

In `app/build.gradle`:

```
android {
    buildTypes {
        release {
            isMinifyEnabled = true
            isShrinkResources = true
            proguardFiles(
                getDefaultProguardFile("proguard-android-optimize.txt"),
                "proguard-rules.pro"
            )
        }
    }
}
```

22.2 ProGuard Rules for Your Stack

```
# Hilt DI
-keep class dagger.hilt.** { *; }
```

```
# OkHttp
-dontwarn okhttp3.**
-keep class okhttp3.** { *; }

# osmdroid
-keep class org.osmdroid.** { *; }

# Socket.IO
-keep class io.socket.** { *; }

# JTS (geofence engine)
-keep class org.locationtech.jts.** { *; }

# Data models (JSON serialization)
-keep class com.yourpackage.data.model.** { *; }
```

22.3 Additional Protection (Optional)

- **String encryption** — encrypt API endpoint URLs and sensitive constants
- **Certificate pinning** — pin your server's SSL certificate in OkHttp to prevent MITM
- **Root/emulator detection** — detect rooted devices or emulators
- **Native code (JNI)** — move most sensitive algorithms to C/C++ via NDK (significantly harder to reverse engineer)

---

23. Cloud Deployment

23.1 What Needs to Move to the Cloud

Current Local Service	Cloud Replacement
Node.js proxy on 10.0.0.4:3000	Cloud-hosted Node.js service
PostgreSQL on localhost	Managed PostgreSQL
SQLite geofence databases (4 files, ~180MB total)	CDN / object storage
Hardcoded IP in Android app	Domain name (api.yourdomain.com)

23.2 Recommended Architecture: Budget vs. Production

Budget Path (~$10–$15/month) — Good for Launch

Component	Provider	Cost
Node.js + Express + Socket.IO	**Railway** (Hobby plan)	~$5–$8/month
PostgreSQL	**Neon** (free tier → Launch $19/mo)	$0–$19/month
SQLite file downloads	**Cloudflare R2**	~$0/month (zero egress fees)
Domain + SSL + CDN	**Cloudflare** (free plan)	~$1/month (domain only)
Monitoring	Grafana Cloud + UptimeRobot (free tiers)	$0

Production Path (~$20–$25/month) — More Control

Component	Provider	Cost
Node.js + Express + Socket.IO	**DigitalOcean Droplet** (1–2GB)	$6–$12/month
PostgreSQL	**DigitalOcean Managed DB**	$15/month
SQLite file downloads	**Cloudflare R2**	~$0/month
Domain + SSL + CDN	**Cloudflare** (free plan)	~$1/month
Monitoring	Grafana Cloud + UptimeRobot (free tiers)	$0

23.3 Scaling Estimates

Users	API Requests/Day	Concurrent WebSockets	Monthly Cost
100	~500	10	$6–$22
1,000	~5,000	50–100	$21–$28
10,000	~50,000	500–1,000	$55–$170

23.4 Socket.IO Scaling Warning

Socket.IO is the hardest part of your stack to scale horizontally:

- **Single server (0–5,000 users):** No issues. A 1–2GB VPS handles this fine.
- **Multiple servers (5,000+ users):** Requires sticky sessions at the load balancer AND `@socket.io/redis-adapter` so messages broadcast across instances. This adds a Redis dependency (~$5–$15/month more).
- **Do NOT use serverless** (Cloud Run, Lambda) for Socket.IO — persistent WebSocket connections are fundamentally incompatible with scale-to-zero.

23.5 Cloudflare R2 for Geofence Database Downloads

Your 4 SQLite databases (up to 45MB each, ~180MB total) are perfect for Cloudflare R2:

- Storage: $0.015/GB/month = ~$0.003/month for 180MB
- **Egress: FREE** — zero egress charges regardless of download volume
- Global CDN included automatically
- S3-compatible API for uploads

This is the clear winner over S3 ($0.09/GB egress), DigitalOcean Spaces ($5/month minimum), or serving files from your Node.js server.

23.6 Domain & SSL

- Register a domain through **Cloudflare Registrar** (at-cost pricing, no markup): ~$10–$12/year
- Point `api.yourdomain.com` to your cloud server
- SSL is free from all providers (Let's Encrypt, Railway auto-SSL, Cloudflare)
- Update the Android app to connect to `https://api.yourdomain.com` instead of `10.0.0.4:3000`

23.7 PostgreSQL Backups

Provider	Automated Backups	Retention	Point-in-Time Recovery
DigitalOcean Managed	Daily	7 days	Yes
Neon	Continuous	7–30 days	Yes (instant branching)
AWS RDS	Daily	Up to 35 days	Yes (5-min granularity)
Self-managed (VPS)	You set up pg_dump cron	You configure	Only with WAL archiving

If self-hosting PostgreSQL on a VPS, set up a daily `pg_dump` to Cloudflare R2:

```
# Cron: daily 3 AM backup to R2
0 3 * * * pg_dump -Fc locationmapapp | \
  aws s3 cp - s3://your-bucket/backups/db-$(date +\%Y\%m\%d).dump \
  --endpoint-url https://your-r2-endpoint
```

Keep 7 daily + 4 weekly + 3 monthly backups. Storage cost on R2: pennies/month.

---

24. Cost Summary & Timeline

24.1 Before Launch (Must-Have)

Item	Cost	Notes
Wyoming LLC formation	$100	+ $60/year maintenance
Copyright registration (2 works)	$130	Android app + server code
DMCA designated agent	$6	Renew every 3 years
Legal document generation	$0–$100	Termly/TermsFeed free tiers
Attorney review of ToS + Privacy Policy	$1,000–$3,000	Strongly recommended
Tech E&O + Cyber insurance	$1,300–$3,000/year	Non-optional given safety data
NCMEC registration	$0	Email espteam@ncmec.org
OpenAI API signup (moderation)	$0	Moderation endpoint is free
Content moderation integration	$0	Development time only
R8 obfuscation configuration	$0	Build config change
Cloud hosting (first month)	$10–$25	Railway or DigitalOcean
Domain registration	$10–$12/year	Cloudflare Registrar
Google Play developer account	$25	One-time fee
AdMob account setup	$0	Free to create
TOTAL (before launch)	**$2,581–$6,398**	

24.2 First 3 Months Post-Launch

Item	Cost	Notes

Trademark filing	$350–$850	Class 9 (software)
Provisional patents (top 3)	$180–$360	Micro-entity DIY
Cloud hosting (3 months)	$30–$75	Scales with users
CPA consultation	$200–$500	Tax setup, quarterly estimates, S-Corp advice
TOTAL (months 1–3)	**$760–$1,785**	

24.3 Year 1 Total

Item	Cost	Notes
Before-launch costs	$2,581–$6,398	One-time
Cloud hosting (12 months)	$120–$300	$10–$25/month
Insurance (annual)	$1,300–$3,000	Annual
Trademark	$350–$850	One-time
Provisionals	$180–$360	One-time
LLC maintenance	$60	Annual
Domain renewal	$12	Annual
CPA consultation	$200–$500	One-time
YEAR 1 TOTAL	**$4,803–$11,480**	

24.4 Revenue Projections vs. Costs

Monthly Active Users	Est. Monthly Ad Revenue	Est. Monthly Subscription Revenue (5% conversion)	Total Monthly	Annual	Profitable?
500	$150	$75	$225	$2,700	No (Year 1 costs: $4,803–$11,480)
2,000	$600	$300	$900	$10,800	Breakeven at low end
5,000	$1,500	$750	$2,250	$27,000	Yes
10,000	$3,750	$1,500	$5,250	$63,000	Yes — consider S-Corp election

Breakeven point: ~1,500–2,500 monthly active users (depending on cost choices).

24.5 If Pursuing Full Patents (Year 2+)

Item	Cost	Notes
Patent attorney (2–3 patents)	$30,000–$90,000	$15,000–$30,000 each
Trademark maintenance	$0 (not due yet)	Every 10 years

24.6 Monthly Recurring After Launch

Item	Monthly Cost
Cloud hosting	$10–$25
Insurance (amortized)	$108–$250
LLC maintenance (amortized)	$5
Domain (amortized)	$1
Content moderation tools	$0
Total recurring	**$124–$281/month**

---

25. Risk Matrix with Probability & Impact

This matrix scores each risk by **Probability** (how likely it is to happen) and **Impact** (how bad it would be if it did). Scores are 1–5 (1 = very low, 5 = very high). **Risk Score = Probability × Impact.**

#	Risk	Probability	Impact	Score	Mitigation	Status
1	**Defamatory user review → business sues you**	4	3	**12**	Section 230 + ToS indemnification + anti-SLAPP	ToS not yet drafted
2	**Privacy complaint (state AG or user)**	3	4	**12**	Privacy policy + data minimization + user rights endpoints	Not implemented
3	**OpenSky denies commercial license**	3	4	**12**	Negotiate; fallback to ADS-B Exchange or FlightAware	Not contacted
4	**Pilot/drone operator relies on inaccurate TFR data**	2	5	**10**	Disclaimers + insurance + "not for navigation" warnings	Disclaimers not implemented
5	**Data breach (database hacked)**	2	5	**10**	Encryption at rest + breach notification process + cyber insurance	DB not encrypted at rest
6	**COPPA violation (child uses app)**	2	5	**10**	Age gate + exclude under-13 + no data collection from children	Age gate not implemented
7	**Google Play Store rejection**	3	3	**9**	Complete all requirements in Section 20 before submission	Not submitted
8	**CSAM posted in chat/comments**	1	5	**5**	NCMEC registration + URL monitoring + moderation	NCMEC not registered
9	**Fake reviews / review manipulation**	4	2	**8**	Rate limiting + one review per user per POI + anomaly detection	Rate limiting partial
10	**OSM ODbL share-alike request**	2	2	**4**	Comply — share POI database under ODbL; user content is exempt	Attribution not added

11	**DuckDuckGo cease-and-desist (duck-duck-scrape)**	2	2	**4**	Remove dependency; replace with licensed search API	In use
12	**Take It Down Act non-compliance**	1	4	**4**	Implement 48-hour removal process before May 19, 2026	Not implemented
13	**Chat harassment / toxic community**	3	2	**6**	Moderation API + community reporting + ban escalation	Moderation not integrated
14	**Ad network compliance violation**	2	3	**6**	Implement UMP consent + COPPA ad tagging + proper Data Safety declaration	AdMob not integrated

Priority Actions (by risk score)

1. **Score 12 — Defamatory reviews:** Draft ToS with Section 230 provisions (Section 8.6)
2. **Score 12 — Privacy complaints:** Implement user data rights endpoints and privacy policy (Section 9.3)
3. **Score 12 — OpenSky license:** Contact OpenSky NOW — this blocks the entire launch
4. **Score 10 — Safety data liability:** Add disclaimers to TFR/geofence features (Section 16)
5. **Score 10 — Data breach:** Encrypt database at rest; establish breach notification process
6. **Score 10 — COPPA:** Implement age gate at registration

---

26. Specific Questions for the Attorney

These are the questions we need answered before launch. They are organized by priority tier. **This section is your meeting agenda.**

Tier 1 — Must Answer Before Launch

#	Question	Context	Reference
1	**Is a Wyoming LLC sufficient for a solo developer in Massachusetts, or should I form in MA?**	Wyoming offers privacy and low fees, but MA is where I live and operate. Do I need to register as a foreign LLC in MA?	Section 6.1
2	**Are my Terms of Service provisions adequate for Section 230 protection?**	I have 10 specific provisions listed. Do they need any changes?	Section 8.6
3	**Is my privacy policy compliant with CCPA, Texas TDPSA, and the other state laws?**	Texas has no revenue threshold — it applies to everyone. My app collects GPS.	Section 9.2
4	**Is my age gate (self-declaration of 13+) sufficient for COPPA, or do I need additional protections?**	FTC has been increasing COPPA enforcement. My app collects GPS and device IDs. The amended rule takes effect April 22, 2026.	Section 9.4
5	**Can you review the OpenSky Network Terms of Use and advise on my commercial licensing options?**	OpenSky restricts commercial use. I need a commercial license or must switch to an alternative. Can you draft or review the licensing request email?	Section 10.3

6	**Is the ODbL share-alike obligation for my POI database a business risk?**	My POI table derived from OSM may be a "Derivative Database" under ODbL. Anyone can request it. Does this undermine my business model?	Section 10.2
7	**What insurance coverage limits do you recommend given that I display TFR/safety data?**	I display aviation TFR boundaries, flood zones, speed cameras, and school zones. Pilots and drone operators might rely on this data.	Section 6.2, Section 16

Tier 2 — Should Answer Before Launch

#	Question	Context	Reference
8	**Should I register copyrights before or after Play Store submission?**	Copyright registration before infringement enables statutory damages. But I want to get to market. What's the risk of waiting?	Section 7.2
9	**Which 3 of my 14 patent candidates should I file provisionals for first?**	I've identified the top 3 (Adaptive Radius, JTS R-Tree Engine, Probe-Calibrate-Spiral). Do you agree with these priorities?	Section 7.3
10	**Is the arbitration clause with class action waiver enforceable in Massachusetts?**	Most app companies use this, but enforceability varies by state.	Section 8.6
11	**Do I need a DMCA agent before launch, or only when the first takedown request arrives?**	The $6 registration is easy, but is it legally required before launch or only upon receiving a complaint?	Section 8.4
12	**Is the duck-duck-scrape library a legal risk I should eliminate now?**	It scrapes DuckDuckGo results without permission. Should I replace it before launch?	Section 11.3
13	**What disclaimers do I need for advertising alongside location data?**	AdMob + GPS creates specific disclosure requirements. What exactly do I need to disclose?	Section 12

Tier 3 — Can Address Post-Launch

#	Question	Context	Reference
14	**When should I implement GDPR compliance?**	I'm launching US-only, but EU residents might download the app. At what point does GDPR enforcement become a realistic risk?	Section 9.7
15	**Should I pursue the trademark myself or hire you to do it?**	Trademark filing is straightforward but mistakes are costly ($350 per filing). Is DIY reasonable?	Section 7.4
16	**Do I need a separate NDA template, or can the contractor provisions in my ToS suffice?**	I might bring on a part-time moderator or developer.	Section 7.5
17	**At what revenue level should I elect S-Corp status, and should you or my CPA advise on this?**	The threshold is ~$60K net profit, but timing and "reasonable salary" determination matter.	Section 14.3

---

27. Master Checklist

Phase 1: Legal Foundation (Before Launch)

- [ ] **Find and engage a technology attorney** (Section 5)
- [ ] Form Wyoming LLC ($100)
- [ ] Register as foreign LLC in MA if attorney advises (Section 26, Q1)
- [ ] Obtain EIN from IRS (free, online, immediate)
- [ ] Open a business bank account (separate from personal)
- [ ] Obtain Tech E&O + Cyber Liability insurance ($1,300–$3,000/year)
- [ ] Register copyright for Android app and server code ($130)
- [ ] Register DMCA designated agent ($6)
- [ ] Generate Terms of Service (Termly/TermsFeed)
- [ ] Generate Privacy Policy (Termly/TermsFeed)
- [ ] Write Community Guidelines
- [ ] Write DMCA Policy / Copyright Policy
- [ ] **Have attorney review ToS + Privacy Policy ($1,000–$3,000)**
- [ ] Register with NCMEC (espteam@ncmec.org)
- [ ] Implement age gate (13+ minimum)

Phase 2: API Licensing (Before Launch — BLOCKING)

- [ ] **Contact OpenSky Network for commercial license (contact@opensky-network.org)**
- [ ] Review MassDOT Developers License Agreement (MBTA)
- [ ] Review Windy Webcams free tier vs. professional tier
- [ ] Add OSM attribution to map view ("© OpenStreetMap contributors")
- [ ] Add NWS/FAA/FEMA attribution where appropriate

Phase 3: Technical Infrastructure (Before Launch)

- [ ] Set up cloud hosting (Railway or DigitalOcean)
- [ ] Set up managed PostgreSQL
- [ ] Set up Cloudflare R2 for geofence database downloads
- [ ] Register domain and configure DNS/SSL
- [ ] Update Android app to use domain instead of 10.0.0.4
- [ ] Enable R8 obfuscation in release build
- [ ] Add ProGuard rules for your dependencies
- [ ] Set up PostgreSQL backups (managed or pg_dump cron)
- [ ] Set up monitoring (Grafana Cloud + UptimeRobot)
- [ ] Move all hardcoded secrets to environment variables or secrets manager
- [ ] Evaluate removing `duck-duck-scrape` dependency (Section 11.3)

Phase 4: Content Moderation (Before Launch)

- [ ] Integrate OpenAI Moderation API into server.js
- [ ] Implement tiered moderation (auto-block / queue / approve)
- [ ] Build content reporting/flagging system (UI + database)

- [ ] Build moderation action tracking (warnings, suspensions, bans)
- [ ] Implement user blocking
- [ ] Add rate limiting on content creation (already partially done)
- [ ] Implement appeal mechanism (email-based)

Phase 5: Privacy & Compliance (Before Launch)

- [ ] Implement prominent in-app location disclosure dialog
- [ ] Build user data export endpoint
- [ ] Build account deletion/anonymization flow
- [ ] Implement data retention auto-cleanup (90-day chat/logs)
- [ ] Add safety data disclaimers (TFR, geofence, weather)
- [ ] Add aviation-specific acknowledgment dialog
- [ ] Complete Google Play Data Safety section

Phase 6: Monetization Setup (Before Launch)

- [ ] Create Google Play developer account ($25)
- [ ] Create AdMob account and ad unit IDs
- [ ] Integrate AdMob SDK into Android app
- [ ] Implement UMP consent dialog for personalized ads
- [ ] Integrate Google Play Billing Library for subscriptions
- [ ] Create subscription products in Play Console
- [ ] Test billing flows with test accounts

Phase 7: Google Play Submission

- [ ] Complete content rating questionnaire
- [ ] Declare target audience (13+)
- [ ] Link Privacy Policy in Play Console
- [ ] Prepare store listing (screenshots, description)
- [ ] Build signed release APK with R8 enabled
- [ ] Submit for review

Phase 8: Post-Launch (First 3 Months)

- [ ] File trademark application ($350–$850)
- [ ] File provisional patents for top 3 algorithms ($180–$360)
- [ ] Monitor moderation queue daily (15–30 min)
- [ ] Publish first transparency report (quarterly)
- [ ] Monitor cloud costs and scale as needed
- [ ] Schedule CPA consultation ($200–$500)
- [ ] Set up quarterly estimated tax payments

Phase 9: Compliance Deadlines

- [ ] **April 22, 2026:** COPPA amended rule compliance
- [ ] **May 19, 2026:** Take It Down Act compliance (48-hour removal process)
- [ ] **Ongoing:** Respond to privacy requests within 45 days
- [ ] **Every 3 years:** Renew DMCA agent registration

Phase 10: Future Growth (When Revenue Justifies)

- [ ] GDPR compliance (when EU users exceed 1,000)
- [ ] UK GDPR compliance (when UK users are significant)
- [ ] Canadian PIPEDA compliance (if expanding to Canada)
- [ ] Social login integration (Google Sign-In as optional)
- [ ] Content sharing ("Share POI" button)
- [ ] Full patent prosecution ($15K–$30K per patent)

Sources

Legal

- 47 U.S.C. Section 230 — Platform immunity
- 17 U.S.C. Section 512 — DMCA safe harbor
- 18 U.S.C. 2258A — CSAM reporting
- Take It Down Act (S.146) — Signed May 19, 2025
- CCPA/CPRA Text — California privacy law
- COPPA Amended Rule
- IAPP State Privacy Law Tracker
- USPTO Fee Schedule

Privacy — International

- GDPR Full Text — EU General Data Protection Regulation
- UK GDPR / Data Protection Act 2018 — ICO guidance
- US-UK Data Bridge — UK adequacy framework
- PIPEDA — Canadian privacy law
- LGPD (Brazil) — Brazilian data protection

Data Licensing

- OpenStreetMap Copyright
- ODbL License FAQ
- OpenSky Terms of Use
- NWS API Documentation
- MBTA Developers
- Windy Webcams API Terms

Advertising & Billing

- Google AdMob Documentation
- Google UMP SDK (Consent)
- Google Play Billing Library
- Google Play Small Developer Program
- Epic v. Google Injunction
- FTC Click-to-Cancel Rule

Tax

- IRS Form 2553 (S-Corp Election)
- IRS Estimated Tax Payments
- Google Play Marketplace Facilitator Tax

Cloud & Infrastructure

- Railway Pricing
- DigitalOcean Pricing
- Cloudflare R2 Pricing
- Neon PostgreSQL Pricing

Content Moderation

- OpenAI Moderation API
- Google Perspective API
- NCMEC CyberTipline

IP Protection

- US Copyright Office Registration
- USPTO Trademark Center
- DMCA Agent Directory

Competitor Reference

- Yelp Terms of Service
- Flightradar24 Terms & Conditions
- Waze Terms of Use
- AllTrails Terms of Service

LocationMapApp v1.5 — Comprehensive Design Review

Version: v1.5.49 | **Date:** 2026-03-03 | **Branch:** master **Build:** 51 sessions of iterative development (v1.5.0 through v1.5.49)

TABLE OF CONTENTS

1. Executive Summary
2. System Architecture
3. Build Environment & Dependencies
4. Version History & Feature Cross-Reference
5. Android Application Layer
    - 5.1 MainActivity.kt
    - 5.2 MainViewModel.kt
    - 5.3 MarkerIconHelper.kt
    - 5.4 StatusLineManager.kt
    - 5.5 AppBarMenuManager.kt
    - 5.6 MenuEventListener.kt
    - 5.7 PoiCategories.kt
    - 5.8 GeofenceEngine.kt
    - 5.9 WeatherIconHelper.kt
6. Data Layer
    - 6.1 Data Models (Models.kt)
    - 6.2 Repository Specifications (9 repositories)
    - 6.3 Dependency Injection (AppModule.kt)
7. Cache Proxy Server
    - 7.1 Infrastructure & Caching
    - 7.2 Complete Endpoint Reference (40+ endpoints)
    - 7.3 OpenSky Rate Limiter
    - 7.4 Overpass Queue System
8. Database Layer
    - 8.1 PostgreSQL Schema
    - 8.2 Geofence Database Schema (SQLite)
    - 8.3 Build Scripts
9. Debug & Testing Infrastructure

    - 9.1 Debug HTTP Server
    - 9.2 Debug Endpoints (24 endpoints)
    - 9.3 Test Harness Scripts

10. XML Layouts & Resources
11. Map Interaction Model
12. External API Routing Table
13. Project State (STATE.md)
14. Full Changelog
15. Known Issues & Future Work

---

1. EXECUTIVE SUMMARY

LocationMapApp is a feature-rich Android mapping application built for real-time tracking and discovery of points of interest (POIs), public transit vehicles, aircraft, weather conditions, webcams, and geofence zones. The system consists of three tightly integrated components:

1. **Android App** (Kotlin/Hilt/osmdroid) — Map rendering, GPS tracking, marker management, dialogs, social layer
2. **Cache Proxy** (Node.js/Express/Socket.IO, port 3000) — Transparent caching, rate limiting, fair queuing, API aggregation, auth, real-time chat
3. **PostgreSQL Database** — Permanent POI storage (180,059 POIs, auto-imported every 15min), aircraft sighting history (500+ sightings), social tables (users, comments, chat)

The app communicates with 10+ external APIs through the proxy, which manages caching (15-second to 365-day TTLs), OpenSky rate limiting (4,000 req/day), Overpass fair queuing (per-client round-robin), data enrichment (website resolution, weather compositing), JWT authentication, and real-time messaging via Socket.IO.

Key Metrics:

- ~11,500 lines of Kotlin across 13 main classes
- ~3,700 lines of JavaScript (proxy server.js)
- 50+ proxy endpoints, 24 debug endpoints
- 17 POI categories with 127 subtypes
- 8 geofence zone types with 220,657+ downloadable zones
- 103 automated test cases (0 failures as of 2026-03-01)
- 58 custom vector drawable icons
- Social layer: auth, POI comments with ratings, real-time chat (Socket.IO)

---

2. SYSTEM ARCHITECTURE

```
+------------------+        +-------------------+        +-------------------+
|   Android App    |  HTTP  |   Cache Proxy     |  HTTP  |  External APIs    |
|  (Kotlin/Hilt)   | -----> | (Node.js:3000)    | -----> |  Overpass, NWS,   |
|  osmdroid map    |  WS    |  In-memory cache  |        |  OpenSky, MBTA,   |
|  12 repositories |        |  Disk persistence |        |  Windy, FAA, FEMA, |
```

```
|  Debug :8085     |          |  Fair queuing     |          |  Aviation Weather, |
+------------------+          |  Rate limiting    |          |  Photon geocoder   |
                              |  JWT auth         |          +--------------------+
                              |  Socket.IO chat   |
                              +--------+----------+
                                       |
                              +--------v----------+
                              |    PostgreSQL     |
                              |  locationmapapp   |
                              |  - pois (180,059) |
                              |  - aircraft_sightings|
                              |  - 8 social tables |
                              +--------------------+
```

Data Flow:

- App → Proxy (10.0.0.4:3000) → External APIs
- Exception: MBTA vehicles/stations/predictions go direct to api-v3.mbta.com
- Exception: Radar tiles go direct to Iowa State Mesonet

---

3. BUILD ENVIRONMENT & DEPENDENCIES

3.1 Build Configuration

Setting	Value
Compile SDK	35
Min SDK	26 (Android 8.0 Oreo)
Target SDK	35 (Android 15)
Java Compatibility	17
Kotlin jvmTarget	17
Java Runtime	JBR 21.0.9 (JetBrains Runtime, bundled with Android Studio)
JBR Path	`/home/witchdoctor/AndroidStudio/android-studio/jbr`
Version Code	5
Version Name	1.5.0

Build Command:

```
JAVA_HOME=/home/witchdoctor/AndroidStudio/android-studio/jbr ./gradlew assembleDebug
```

3.2 Android Dependencies

Category	Dependency	Version
Core	androidx.core:core-ktx	1.12.0
	androidx.appcompat:appcompat	1.6.1
	com.google.android.material:material	1.11.0

	androidx.constraintlayout	2.1.4
	androidx.lifecycle:lifecycle-viewmodel-ktx	2.7.0
	androidx.lifecycle:lifecycle-runtime-ktx	2.7.0
	androidx.activity:activity-ktx	1.8.2
DI	com.google.dagger:hilt-android	2.51
	com.google.dagger:hilt-compiler (KSP)	2.51
Location	com.google.android.gms:play-services-location	21.1.0
Map	org.osmdroid:osmdroid-android	6.1.18
	org.osmdroid:osmdroid-mapsforge	6.1.18
	com.github.MKergall:osmbonuspack	6.9.0
Network	com.squareup.retrofit2:retrofit	2.9.0
	com.squareup.retrofit2:converter-gson	2.9.0
	com.squareup.okhttp3:okhttp	4.12.0
	com.squareup.okhttp3:logging-interceptor	4.12.0
Async	org.jetbrains.kotlinx:kotlinx-coroutines-android	1.7.3
Database	androidx.room:room-runtime	2.6.1
Browser	androidx.browser:browser	1.7.0
JSON	com.google.code.gson:gson	2.10.1
Spatial	org.locationtech.jts:jts-core	1.19.0
Preferences	androidx.preference:preference-ktx	1.2.1
Socket.IO	io.socket:socket.io-client	2.1.0

3.3 Proxy Dependencies (package.json)

Dependency	Version	Purpose
express	4.21.0	HTTP server framework
pg	8.13.0	PostgreSQL client
undici	6.23.0	HTTP fetch
cheerio	1.0.0	HTML/XML parsing (FAA TFR scraping)
duck-duck-scrape	2.2.5	DuckDuckGo search (website resolution)
fast-xml-parser	4.3.0	AIXM XML parsing (TFR details)
better-sqlite3	11.10.0	SQLite for geofence databases
lzma-native	8.0.6	XZ decompression (ExCam cameras)
argon2	latest	Password hashing (social auth)
jsonwebtoken	latest	JWT access/refresh tokens

socket.io	latest	Real-time chat messaging
express-rate-limit	^7.5.1	API rate limiting (auth, comments, rooms)

3.4 Proxy Startup

```
cd cache-proxy && DATABASE_URL=postgres://witchdoctor:fuckers123@localhost/locationmapapp
\
  JWT_SECRET=$(openssl rand -hex 32) \
  OPENSKY_CLIENT_ID=deanmauriceellis-api-client \
  OPENSKY_CLIENT_SECRET=6m3uBQ5HXwSzJeLemRJK12G8Ux4L5veR node server.js
```

3.5 Android Manifest

Permissions: ACCESS_FINE_LOCATION, ACCESS_COARSE_LOCATION, INTERNET, ACCESS_NETWORK_STATE, WRITE_EXTERNAL_STORAGE (maxSdk 28), READ_EXTERNAL_STORAGE (maxSdk 32)

Activities: MainActivity (singleTop, launcher), DebugLogActivity

Content Provider: FileProvider for geofence database export (authority: `com.example.locationmapapp.fileprovider`, path: `geofence_databases/`)

Cleartext Traffic: Enabled (proxy on local network)

---

4. VERSION HISTORY & FEATURE CROSS-REFERENCE

This table maps every feature to the version it was introduced, its key files, and current status.

v1.5.0 — 2026-02-27 — Foundation

Feature	Key Files	Status
Cache proxy server	`cache-proxy/server.js`	Active
Vehicle follow mode	`MainActivity.kt`	Active
Cache-only POI display on scroll	`PlacesRepository.kt`, `server.js`	Active
Manual location mode (long-press)	`MainActivity.kt`	Active
NWS NEXRAD radar (Iowa State)	`MainActivity.kt`	Active
5dp colored POI dots	`MarkerIconHelper.kt`	Active
365-day Overpass cache TTL	`server.js`	Active

v1.5.1 — 2026-02-27 — Adaptive Radius

Feature	Key Files	Status
Adaptive POI search radius	`server.js`, `PlacesRepository.kt`	Active
Per-grid-cell radius hints	`radius-hints.json`	Active
GET/POST /radius-hint endpoints	`server.js`	Active

v1.5.2 — 2026-02-28 — PostgreSQL

Feature	Key Files	Status
PostgreSQL POI database	`schema.sql`, `server.js`	Active (180,059 POIs, auto-import)
JSONB tags with GIN index	`schema.sql`	Active
POI import script	`import-pois.js`	Active

v1.5.3 — 2026-02-28 — 16 POI Categories

Feature	Key Files	Status
16 POI categories (was 6)	`PoiCategories.kt`, `menu_poi.xml`	Updated to 17 in v1.5.43
Submenu refinement dialogs	`AppBarMenuManager.kt`	Active
Central category config	`PoiCategories.kt`	Active
Rich METAR station markers	`MarkerIconHelper.kt`, `WeatherRepository.kt`	Active
Layer-aware POI LiveData	`MainViewModel.kt`	Active

v1.5.4 — 2026-02-28 — Vehicle Arrows & METAR

Feature	Key Files	Status
Vehicle direction arrows	`MarkerIconHelper.kt`	Active
Human-readable METAR tap info	`MainActivity.kt`	Active
Deferred METAR restore	`MainActivity.kt`	Active

v1.5.5 — 2026-02-28 — Aircraft Tracking

Feature	Key Files	Status
Aircraft tracking (OpenSky)	`AircraftRepository.kt`, `server.js`	Active
Altitude-colored airplane icons	`MarkerIconHelper.kt`	Active
Configurable refresh (30s-5min)	`AppBarMenuManager.kt`	Active
Zoom >= 10 guard	`MainActivity.kt`	Active
Proxy /aircraft endpoint	`server.js`	Active (15s TTL)

v1.5.6 — 2026-02-28 — Aircraft Follow

Feature	Key Files	Status
Aircraft follow mode (icao24 tracking)	`MainActivity.kt`, `AircraftRepository.kt`	Active
Enhanced aircraft markers (callsign, vert rate)	`MarkerIconHelper.kt`	Active
SPI emergency indicator	`MarkerIconHelper.kt`	Active
Cached POI bbox display	`server.js` (`/pois/bbox`)	Active

v1.5.7 — 2026-02-28 — Auto-Follow & POI Labels

Feature	Key Files	Status
Auto-follow aircraft (POI Builder)	`MainActivity.kt`	Active
POI labels at zoom >= 18	`MarkerIconHelper.kt` (`labeledDot()`)	Active
20-min aircraft rotation	`MainActivity.kt`	Active

v1.5.8 — 2026-02-28 — DB Queries & OpenSky Auth

Feature	Key Files	Status
6 PostgreSQL POI endpoints	`server.js` (`/db/pois/*`)	Active (now 8)
Aircraft sightings database	`server.js`, `schema.sql`	Active (501+ sightings)
OpenSky OAuth2 (4,000 req/day)	`server.js`	Active
Smart auto-follow	`MainActivity.kt`	Active

v1.5.9 — 2026-02-28 — Viewport-Only POIs

Feature	Key Files	Status
Viewport-only POI markers (~100-400)	`MainActivity.kt`	Active
LRU icon cache (max 500)	`MarkerIconHelper.kt`	Active

v1.5.10 — 2026-02-28 — Webcams

Feature	Key Files	Status
Webcam layer (Windy API, 18 categories)	`WebcamRepository.kt`, `server.js`	Active
Webcam preview + live player	`MainActivity.kt`	Active

v1.5.11 — 2026-02-28 — Rate Limiter

Feature	Key Files	Status
OpenSky rate limiter (exponential backoff)	`server.js`	Active
Stale cache fallback	`server.js`	Active
Dedicated Air menu	`menu_aircraft.xml`	Active

v1.5.12 — 2026-02-28 — Vehicle Staleness

Feature	Key Files	Status
Vehicle staleness detection (>2 min)	`MainActivity.kt`	Active
Dedicated Air toolbar button	`menu_main_toolbar.xml`	Active

v1.5.13 — 2026-02-28 — Populate Scanner v1

Feature	Key Files	Status
Populate POIs (spiral grid scanner)	`MainActivity.kt`	Superseded by v1.5.16
X-Cache header on Overpass	`server.js`	Active
PopulateSearchResult model	`Models.kt`	Active

v1.5.14 — 2026-02-28 — Populate v1 Tuning

Feature	Key Files	Status
30s fixed pacing	`MainActivity.kt`	Active
Cap detection & cell subdivision	`MainActivity.kt`	Superseded by v1.5.16
Zoom-14 scan view	`MainActivity.kt`	Active

v1.5.15 — 2026-02-28 — Cap Retry & Fuzzy Hints

Feature	Key Files	Status
Auto-retry on 500-element cap	`PlacesRepository.kt`	Active
20km fuzzy radius hints	`server.js`, `PlacesRepository.kt`	Active
MIN_RADIUS 100m	`server.js`, `PlacesRepository.kt`	Active

v1.5.16 — 2026-02-28 — Populate v2

Feature	Key Files	Status
Probe-calibrate-subdivide scanner	`MainActivity.kt`	Active
Recursive 3x3 subdivision	`MainActivity.kt`	Active
Narrative populate banner	`MainActivity.kt`	Active
Overpass request queue (serialized, 10s gap)	`server.js`	Active
Per-client fair queuing	`server.js`	Active
Error radius immunity (504/429 don't shrink)	`server.js`	Active

v1.5.17 — 2026-02-28 — Train Stations

Feature	Key Files	Status
~270 train station markers	`MbtaRepository.kt`, `MainActivity.kt`	Active
Arrival board dialog	`MainActivity.kt`	Active
Trip schedule dialog	`MainActivity.kt`	Active
MbtaStop, MbtaPrediction, MbtaTripScheduleEntry models	`Models.kt`	Active

v1.5.18 — 2026-02-28 — Debug HTTP Server

Feature	Key Files	Status

Debug HTTP server (port 8085)	`DebugHttpServer.kt`, `DebugEndpoints.kt`	Active (24 endpoints)
19 initial debug endpoints	`DebugEndpoints.kt`	Active (expanded to 24)
Lifecycle-aware endpoint registration	`DebugHttpServer.kt`	Active

v1.5.19 — 2026-03-01 — Bus Stops

Feature	Key Files	Status
~7,900 bus stop markers	`MbtaRepository.kt`, `MainActivity.kt`	Active
Zoom >= 15 guard for bus stops	`MainActivity.kt`	Active
Vehicle detail dialog	`MainActivity.kt`	Active

v1.5.20 — 2026-03-01 — Bus Stops via Proxy

Feature	Key Files	Status
Bus stops routed through proxy cache	`server.js` (`/mbta/bus-stops`)	Active (24h TTL)

v1.5.21 — 2026-03-01 — Debug API Expansion

Feature	Key Files	Status
/vehicles, /stations, /bus-stops endpoints	`DebugEndpoints.kt`	Active
relatedObject on all markers	`DebugEndpoints.kt`	Active
test-app.sh (30+ tests)	`test-app.sh`	Active

v1.5.22 — 2026-03-01 — Test Harness

Feature	Key Files	Status
overnight-test.sh (6-8hr harness)	`overnight-test.sh`	Active
morning-transit-test.sh	`morning-transit-test.sh`	Active
run-full-test-suite.sh	`run-full-test-suite.sh`	Active
103 PASS, 0 FAIL	—	Verified 2026-03-01

v1.5.23 — 2026-03-01 — Aircraft DB & Fuzzy Search

Feature	Key Files	Status
4 aircraft DB endpoints	`server.js` (`/db/aircraft/*`)	Active
Fuzzy search (abbreviation expansion)	`DebugEndpoints.kt`	Active
Bbox snapping (0.01° / 0.1°)	`server.js`	Active

v1.5.24 — 2026-03-01 — Flight Trail

Feature	Key Files	Status

Aircraft flight path visualization	`MainActivity.kt`, `AircraftRepository.kt`	Active
Altitude-colored polyline trail	`MainActivity.kt`	Active
DB history + live path (1000-point cap)	`AircraftRepository.kt`	Active

v1.5.25 — 2026-03-01 — Legend & Zoom Guards

Feature	Key Files	Status
Legend dialog (7 sections)	`MainActivity.kt`	Active (moved to Utility)
Transit zoom guard (zoom <= 10 hides)	`MainActivity.kt`	Active
Long-press auto-zoom to 14	`MainActivity.kt`	Updated to zoom 18 in v1.5.48

v1.5.26 — 2026-03-01 — Find Dialog

Feature	Key Files	Status
Find dialog (category grid -> results)	`MainActivity.kt`, `FindRepository.kt`	Active
/db/pois/counts and /db/pois/find endpoints	`server.js`	Active
FindRepository with client cache	`FindRepository.kt`	Active
Long-press filter mode	`MainActivity.kt`	Active

v1.5.27 — 2026-03-01 — POI Detail Dialog

Feature	Key Files	Status
POI Detail dialog (info + actions)	`MainActivity.kt`	Active
Website resolution (3-tier waterfall)	`server.js` (`/pois/website`)	Active
In-app WebView for websites	`MainActivity.kt`	Active
Directions/Call/Reviews/Map buttons	`MainActivity.kt`	Active

v1.5.28 — 2026-03-01 — Silent Fill & 23 Subtypes

Feature	Key Files	Status
Silent background POI fill	`MainActivity.kt`	Active
23 new POI subtypes	`PoiCategories.kt`	Active (expanded to 46+ in v1.5.43)

v1.5.29 — 2026-03-01 — Labeled Vehicles

Feature	Key Files	Status
Labeled vehicle markers at zoom >= 18	`MarkerIconHelper.kt` (`labeledVehicle()`)	Active

v1.5.30 — 2026-03-01 — Smart GPS

Feature	Key Files	Status

Dead zone filtering (100m)	`MainActivity.kt`	Active
Speed-adaptive polling (10s/60s)	`MainActivity.kt`	Active
3km POI fetch threshold	`MainActivity.kt`	Active

v1.5.31 — 2026-03-01 — Icon Toolbar & GoTo

Feature	Key Files	Status
Icon toolbar (8 icons)	`menu_main_toolbar.xml`	Superseded by v1.5.40
Go to Location dialog	`MainActivity.kt`, `GeocodingRepository.kt`	Active

v1.5.32 — 2026-03-02 — Geocode Autocomplete

Feature	Key Files	Status
Photon geocoder via proxy /geocode	`server.js`, `GeocodingRepository.kt`	Active
500ms debounce, US-only bbox	`server.js`	Active

v1.5.33 — 2026-03-02 — Idle Populate & Delta Cache

Feature	Key Files	Status
Idle auto-populate (60s stationarity)	`MainActivity.kt`	Updated to 5min in v1.5.41
X-Client-ID header	`PlacesRepository.kt`	Active
Covering cache, content hash delta	`server.js`	Active

v1.5.34 — 2026-03-02 — Weather Dialog

Feature	Key Files	Status
Rich weather dialog	`MainActivity.kt`, `WeatherRepository.kt`	Active
Composite /weather endpoint (5 NWS calls)	`server.js`	Active
22 weather vector icons	`res/drawable/ic_wx_*.xml`	Active
WeatherIconHelper.kt	`WeatherIconHelper.kt`	Active

v1.5.35 — 2026-03-02 — TFR Geofence System

Feature	Key Files	Status
GeofenceEngine (JTS R-tree)	`GeofenceEngine.kt`	Active
TFR polygon overlays (FAA data)	`TfrRepository.kt`, `server.js`	Active
Entry/proximity/exit alerting	`GeofenceEngine.kt`	Active
Severity-colored Alerts icon	`MainActivity.kt`	Active
/tfrs proxy endpoint (AIXM parser)	`server.js`	Active

v1.5.36 — 2026-03-02 — 4 Additional Zone Types

Feature	Key Files	Status
Speed cameras (Overpass, 200m circle)	`GeofenceRepository.kt`, `server.js`	Active
School zones (Overpass, polygon/300m)	`GeofenceRepository.kt`, `server.js`	Active
Flood zones (FEMA NFHL ArcGIS)	`GeofenceRepository.kt`, `server.js`	Active
Railroad crossings (Overpass, 100m)	`GeofenceRepository.kt`, `server.js`	Active

v1.5.37 — 2026-03-02 — Downloadable DB Infrastructure

Feature	Key Files	Status
GeofenceDatabaseRepository	`GeofenceDatabaseRepository.kt`	Active
Database Manager dialog	`MainActivity.kt`	Active
Military bases database (1,944 zones)	`build-military.js`	Active
Catalog + download endpoints	`server.js`	Active

v1.5.38 — 2026-03-02 — 3 More Databases

Feature	Key Files	Status
ExCam cameras (109,500 zones)	`build-excam.js`	Active
NCES schools (101,390 zones)	`build-nces.js`	Active
DJI no-fly zones (7,823 zones)	`build-dji-nofly.js`	Active
4 databases, 220,657 total zones	`catalog.json`	Active

v1.5.39 — 2026-03-02 — Database Import & Export

Feature	Key Files	Status
Import SQLite .db (SAF picker)	`GeofenceDatabaseRepository.kt`	Active
Import CSV (config dialog + parser)	`GeofenceDatabaseRepository.kt`	Active
Export via share intent (FileProvider)	`GeofenceDatabaseRepository.kt`	Active
Local-only database display	`GeofenceDatabaseRepository.kt`	Active

v1.5.40 — 2026-03-02 — Slim Toolbar Redesign

Feature	Key Files	Status
Slim toolbar (40dp) + status line (24dp)	`toolbar_two_row.xml`, `StatusLineManager.kt`	Active
Grid dropdown (2x4 PopupWindow)	`grid_dropdown_panel.xml`, `AppBarMenuManager.kt`	Active
7-priority StatusLineManager	`StatusLineManager.kt`	Active

v1.5.41 — 2026-03-02 — Idle Populate Improvements

Feature	Key Files	Status
5-min GPS stationarity threshold	`MainActivity.kt`	Active
Touch-to-stop idle populate	`MainActivity.kt`	Active
State preservation (resume from last point)	`MainActivity.kt`	Active
Long-press fetches weather + alerts	`MainActivity.kt`	Active

v1.5.42 — 2026-03-02 — 10km Probe Populate

Feature	Key Files	Status
10km probe populate (expanding spiral)	`MainActivity.kt`	Active
estimateFillRadius()	`MainActivity.kt`	Active
panOnly mode for placeScanningMarker	`MainActivity.kt`	Active
POI display zoom guard lowered to 10	`MainActivity.kt`	Active
5000-marker count guard	`MainActivity.kt`	Active

v1.5.43 — 2026-03-02 — Train ETA & POI Expansion

Feature	Key Files	Status
Train next-stop ETA badge	`MbtaRepository.kt`, `MarkerIconHelper.kt`	Active
enrichWithNextStopEta() (batch predictions)	`MbtaRepository.kt`	Active
17th POI category (Offices & Services)	`PoiCategories.kt`	Active
46 new subtypes across 9 categories	`PoiCategories.kt`	Active
Find dialog radius-scoped counts (10km)	`FindRepository.kt`, `server.js`	Active
Find dialog auto-fit cell heights	`MainActivity.kt`	Active
Fixed: 10km probe zoom (panMap = false)	`MainActivity.kt`	Fixed
Fixed: GoTo stops 10km probe	`MainActivity.kt`	Fixed

v1.5.44 — 2026-03-03 — Share, Dark Mode, Favorites, Search, Animated Radar

Feature	Key Files	Status
Share POI (5th action button)	`MainActivity.kt`	Active
Dark mode (CartoDB Dark Matter tiles)	`AppBarMenuManager.kt`, `MainActivity.kt`	Active
Favorites (star in POI detail, Favorites cell in Find)	`FavoritesManager.kt`, `MainActivity.kt`	Active
Text search in Find dialog	`FindRepository.kt`, `MainActivity.kt`	Active
Animated radar (7-frame NEXRAD loop)	`MainActivity.kt`	Active

v1.5.45 — 2026-03-03 — Social Layer (Auth, Comments, Chat)

Feature	Key Files	Status
Auth system (Argon2id + JWT)	`AuthRepository.kt`, `server.js`	Active
POI Comments (ratings, votes, soft-delete)	`CommentRepository.kt`, `server.js`	Active
Real-time chat (Socket.IO)	`ChatRepository.kt`, `server.js`	Active
Grid dropdown 3×4 (12 buttons)	`grid_dropdown_panel.xml`, `AppBarMenuManager.kt`	Active
Profile dialog	`MainActivity.kt`	Active
8 social DB tables	`create-social-tables.sh`	Active

v1.5.46 — 2026-03-03 — POI Click-Through & Device-Bonded Auth

Feature	Key Files	Status
POI marker tap → detail dialog	`MainActivity.kt`	Active
Device-bonded auth (register-only, no login/logout)	`AuthRepository.kt`, `server.js`	Active
PlaceResult.id "type:id" format	`PlacesRepository.kt`, `MainViewModel.kt`	Active

v1.5.47 — 2026-03-03 — Security Hardening

Feature	Key Files	Status
Server-side sanitization (sanitizeText/sanitizeMultiline)	`server.js`	Active
Rate limiting (express-rate-limit)	`server.js`	Active
Login lockout (5 fails → 15min)	`server.js`	Active
Client-side InputFilter.LengthFilter	`MainActivity.kt`	Active
Comment character counter	`MainActivity.kt`	Active

v1.5.48 — 2026-03-03 — Startup/Behavior Tuning

Feature	Key Files	Status
Default zoom 14 → 18	`MainActivity.kt`	Active
Radar transparency 70% → 35%	`MainActivity.kt`	Active
Idle populate POI density guard (≥100 → skip)	`MainActivity.kt`, `MainViewModel.kt`	Active

v1.5.49 — 2026-03-03 — Automated POI DB Import

Feature	Key Files	Status
Delta POI import (every 15min)	`server.js`	Active
POST /db/import (manual trigger)	`server.js`	Active
GET /db/import/status	`server.js`	Active
dbImport in /cache/stats	`server.js`	Active

5. ANDROID APPLICATION LAYER

5.1 MainActivity.kt

File: `app/src/main/java/com/example/locationmapapp/ui/MainActivity.kt` **Lines:** ~8,500 | **Introduced:** v1.5.0

The single Activity manages all UI: map, markers, dialogs, toolbar, and user interactions. Implements `MenuEventListener` interface.

Initialization Sequence

onCreate():

1. Initialize DebugHttpServer on port 8085
2. Configure OSMDroid (Mapnik tiles, multi-touch, zoom 3-19)
3. Inflate ActivityMainBinding (slim toolbar + status line + grid dropdown)
4. Create AppBarMenuManager, StatusLineManager
5. Call setupMap(), buildFabSpeedDial(), observeViewModel()
6. Request location permission
7. Handle debug intents (lat/lon/zoom/enable/disable)

onStart():

1. Set populate state to OFF
2. Restore radar overlay + refresh scheduler
3. Restore MBTA transit layers
4. Defer POI, METAR, Aircraft, Webcam, Geofence restore until GPS fix

GPS Location Handling

- **Adaptive interval:** 10s if speed > 20 mph, else 60s
- **100m dead zone:** Ignore GPS jitter < 100m
- **Idle timer:** 10 min stationary → startIdlePopulate() (skips if ≥100 POIs within 10km)
- **Initial center:** First fix zooms to 18 (street-level default)
- **Weather fetch:** Every 30 min (or on first fix)
- **Geofence check:** If zones loaded, checkPosition(lat, lon, bearing)
- **3km POI threshold:** Trigger cached POI load if moved > 3km (1 min cooldown)
- **Speed guard:** Skip API calls if speed > 20 mph

POI Populate System (4 modes)

Mode	Trigger	Behavior	Version
Populate Scanner	Utility menu	Probe-calibrate-spiral, 30s pacing, 3x3 recursive subdivision	v1.5.16
10km Probe	Utility menu	Expanding spiral of 10km wide probes, pan without zoom	v1.5.42

Idle Auto-Populate	5 min GPS stationary	Same as scanner but 45s delays, touch-to-stop, state preserving	v1.5.33/ v1.5.41
Silent Fill	Startup, long-press, GPS move	Single Overpass query, no UI (unless debug mode)	v1.5.28

Vehicle Following

Type	Tracking	Refresh	Tolerance	Trail
Aircraft	Global ICAO24	10s	3-strike	Altitude-colored polyline, DB history + live
Train	Vehicle ID	60s (30-300s)	Standard	Position trail
Subway	Vehicle ID	60s (30-300s)	Standard	Position trail
Bus	Vehicle ID	60s (30-300s)	Standard	Position trail
Auto-Follow	Random >10k ft	20-min rotation	Smart switching	Same as aircraft

Dialog Systems

Dialog	Trigger	Content	Version
Weather	Weather icon tap	Current + 48hr hourly + 7-day + alerts	v1.5.34
Find	Grid > Find	Category grid → subtype grid → distance-sorted results	v1.5.26
POI Detail	Find result tap or POI marker tap	Info rows, website, comments, star/favorite, Directions/Call/Reviews/Map/Share	v1.5.27/v1.5.44/ v1.5.46
GoTo	Grid > Go To	Geocoding autocomplete, tappable results	v1.5.31
Arrival Board	Station/stop tap	Real-time predictions, 30s auto-refresh	v1.5.17
Trip Schedule	Arrival row tap	Full itinerary, platform codes	v1.5.17
Vehicle Detail	Vehicle marker tap	Route, status, speed + Follow/Route/Arrivals buttons	v1.5.19
Webcam Preview	Webcam marker tap	400x224 image + View Live button	v1.5.10
METAR Detail	METAR marker tap	Decoded wind, sky, visibility, altimeter	v1.5.4
Legend	Utility > Legend	7 sections explaining all marker types	v1.5.25
DB Manager	Alerts > Zone Databases	Catalog, download/delete, import/export	v1.5.37
Register	Grid > Social	Display name, email, password (device-bonded)	v1.5.45
Profile	Grid > Profile	Avatar, display name, role badge, user ID	v1.5.45
Chat Rooms	Grid > Chat	Room list, member counts, + New button	v1.5.45
Chat Room	Room list tap	Message bubbles, send bar, back arrow	v1.5.45

Add Comment	POI detail > + Add	5-star rating selector, text input, char counter	v1.5.45

Map Scroll/Zoom Handlers

- Schedule aircraft reload, bus stop reload, POI cache load, webcam reload, geofence reload
- Hide transit markers when zoom <= 10
- Toggle POI labels at zoom >= 18
- Toggle vehicle labels at zoom >= 18
- POI display guard: zoom >= 10, max 5000 markers

5.2 MainViewModel.kt

File: `app/src/main/java/com/example/locationmapapp/ui/MainViewModel.kt` **Lines:** ~900 | **Introduced:** v1.5.0

Hilt-injected ViewModel connecting 12 repositories to 22+ LiveData fields.

Injected Dependencies

LocationManager, PlacesRepository, WeatherRepository, MbtaRepository, AircraftRepository, WebcamRepository, FindRepository, TfrRepository, GeofenceRepository, GeofenceDatabaseRepository, AuthRepository, CommentRepository, ChatRepository

LiveData Fields (22+)

Category	Field	Type
Location	currentLocation	LocationUpdate
	locationMode	LocationMode (GPS/MANUAL)
POI	places	Pair<String, List>
Transit	mbtaTrains	List
	mbtaSubway	List
	mbtaBuses	List
	mbtaStations	List
	mbtaBusStops	List
Aircraft	aircraft	List
	followedAircraft	AircraftState?
Weather	metars	List
	weatherAlerts	List
	weatherData	WeatherData?
	radarRefreshTick	Long
Webcams	webcams	List
Find	findCounts	FindCounts?

Geofences	geofenceAlerts	List
Social	authState	AuthState?
	comments	List
	chatRooms	List
	importResult	ImportResult?
Error	error	String

Public Methods (~60)

Location: onPermissionGranted(), restartLocationUpdates(), requestLastKnownLocation(), toggleLocationMode(), setManualLocation()

POI: searchPoisAt(), searchPoisFromCache(), loadCachedPoisForBbox(), populateSearchAt()

Transit: fetchMbtaTrains/Subway/Buses/Stations/BusStops(), clearMbta*(), fetchPredictionsDirectly(), fetchTripScheduleDirectly()

Weather: fetchWeatherAlerts(), fetchWeather(), fetchWeatherDirectly(), loadMetars()

Aircraft: loadAircraft(), loadFollowedAircraft(), clearFollowedAircraft(), fetchFlightHistoryDirectly()

Webcams: loadWebcams(), clearWebcams(), refreshRadar()

Find: loadFindCounts(lat, lon), findNearbyDirectly(), fetchPoiWebsiteDirectly()

Geofences: loadTfrs/Cameras/Schools/FloodZones/Crossings(), checkGeofences(), rebuildGeofenceIndex(), fetchGeofenceCatalog(), downloadGeofenceDatabase(), importGeofenceDatabase(), importCsvAsGeofenceDatabase(), deleteGeofenceDatabase(), loadDatabaseZonesForVisibleArea()

Social: register(), login(), refreshToken(), logout(), getProfile(), fetchComments(), postComment(), voteComment(), deleteComment(), fetchRooms(), createRoom(), sendMessage(), fetchNearbyPoiCount(), searchPoisByName()

5.3 MarkerIconHelper.kt

File: `app/src/main/java/com/example/locationmapapp/ui/MarkerIconHelper.kt` **Lines:** 680 | **Introduced:** v1.5.0

Singleton object that rasterizes VectorDrawables into tinted BitmapDrawables with LRU caching (max 500 entries).

Icon Rendering Methods

Method	Purpose	Output	Version
`forCategory(ctx, category, sizeDp)`	POI icon by category name	BitmapDrawable	v1.5.0
`get(ctx, resId, sizeDp, tintColor)`	Icon by resource ID	BitmapDrawable	v1.5.0
`dot(ctx, category)`	5dp colored circle (low zoom)	BitmapDrawable	v1.5.0
`labeledDot(ctx, category, name)`	Category + dot + name (zoom >= 18)	BitmapDrawable	v1.5.7

`withArrow(ctx, resId, sizeDp, tint, bearing)`	Icon + rotated direction arrow	BitmapDrawable	v1.5.4
`labeledVehicle(ctx, ..., nextStopMinutes)`	Complex vehicle marker with ETA	Pair<BitmapDrawable, anchorY>	v1.5.29/ v1.5.43
`aircraftMarker(ctx, heading, tint, callsign, vertRate, spi)`	Rotated airplane + callsign	BitmapDrawable	v1.5.6
`stationIcon(ctx, tintColor)`	26dp train station	BitmapDrawable	v1.5.17
`busStopIcon(ctx, tintColor)`	20dp bus stop sign	BitmapDrawable	v1.5.19
`clearCache()`	Flush LRU	void	v1.5.9

labeledVehicle Layout (zoom >= 18)

```
┌──────────────────────┐
| → Stop Name          |  (status pill, tintColor bg)
├──────────────────────┤
|  ↑ arrow             |  (rotated to bearing)
| [icon]    [3m]       |  (icon center + ETA badge right)
| [25 mph]             |  (speed badge left)
├──────────────────────┤
| R1 · To Downtown     |  (route pill, white bg)
└──────────────────────┘
```

The ETA badge (e.g., "3m") was added in v1.5.43 — colored pill rendered to the right of the train icon.

Category Color Map (30+ mappings)

Category	Color	Hex
Food & Drink	Deep Orange	#BF360C
Fuel & Charging	Orange	#E65100
Civic & Gov	Navy	#1A237E
Parks & Rec	Green	#2E7D32
Shopping	Amber	#F57F17
Healthcare	Red	#D32F2F
Education	Brown	#5D4037
Lodging	Purple	#7B1FA2
Parking	Blue Gray	#455A64
Finance	Teal	#00695C
Worship	Dark Brown	#4E342E
Tourism	Orange	#FF6F00
Emergency	Dark Red	#B71C1C
Auto Services	Dark Gray	#37474F
Entertainment	Cyan	#00838F

Offices	Blue Gray	#546E7A
Default	Purple	#6A1B9A

5.4 StatusLineManager.kt

File: `app/src/main/java/com/example/locationmapapp/ui/StatusLineManager.kt` **Lines:** 105 | **Introduced:** v1.5.40

Priority-based text display in the 24dp status line below the toolbar. Highest priority wins; lower priorities queue and display when higher ones clear.

Priority Levels

Level	Name	Example Text
0	GPS_IDLE	"42.3601, -71.0589 * 25 mph * 68F Mostly Cloudy"
1	SILENT_FILL	"Filling POIs..."
2	IDLE_POPULATE	"Idle scan: ring 2, 45 POIs"
3	POPULATE	"Scanning ring 3, cell 5/8, 120 POIs"
4	AIRCRAFT_FOLLOW	"UAL456 FL350 450kt"
5	VEHICLE_FOLLOW	"Fitchburg Line -> North Station"
6	GEOFENCE_ALERT	"ENTERING: TFR P-049 Washington DC"

API

- `set(priority, text, onClick?)` — Set/update a priority level
- `set(priority, text, bgColor, textColor, onClick?)` — With custom colors (geofence alerts)
- `clear(priority)` — Remove priority, fall back to next highest
- `updateIdle(lat, lon, speedMph, tempF, description)` — GPS_IDLE convenience
- `currentText()` / `currentPriority()` — For debug endpoint

5.5 AppBarMenuManager.kt

File: `app/src/main/java/com/example/locationmapapp/ui/menu/AppBarMenuManager.kt` **Lines:** 808 | **Introduced:** v1.5.0 (redesigned v1.5.40)

Manages the slim toolbar, grid dropdown, and all sub-menus. Handles SharedPreferences persistence for toggles and frequencies.

Grid Dropdown (3×4)

Row 1	Row 2	Row 3
Transit	POI	Social
Webcams	Utility	Chat
Aircraft	Find	Profile

Radar	Go To	Legend

Sub-Menu Systems

Menu	Items	Key Prefs
Transit	Stations, Bus Stops, Trains (+ freq), Subway (+ freq), Buses (+ freq), Alerts (+ freq)	PREF_MBTA_*
Cameras	Webcams toggle, Category filter (18 types)	PREF_WEBCAMS_ON
Aircraft	Display toggle, Frequency (30-300s), Auto-Follow	PREF_AIRCRAFT_*
Radar	Radar toggle, Visibility (0-100%), Frequency (5-15min), METAR, METAR freq	PREF_RADAR_*
POI	All On + 17 categories (each with subtype dialogs)	poi_*on*, *poi*_subtypes
Utility	Record GPS, Build Story, Analyze, Anomalies, Email GPX, Populate, 10km Probe, Fill Probe, Debug Log, GPS Mode, Silent Fill Debug, Legend	PREF_RECORD_GPS, PREF_GPS_MODE
Alerts	TFR/Camera/School/Flood/Crossing overlays, Sound, Distance (1-20 NM), DB Manager	PREF_*_OVERLAY

50+ preference keys stored in `app_bar_menu_prefs` SharedPreferences.

5.6 MenuEventListener.kt

File: `app/src/main/java/com/example/locationmapapp/ui/menu/MenuEventListener.kt` **Lines:** 225 | **Introduced:** v1.5.0

Interface with 45+ named callbacks — every toggle, slider, and action has its own method. No generic "onAction(String)" fallback.

Callback Groups

Group	Count	Key Methods
Weather	6	onWeatherRequested, onMetarDisplayToggled, onAircraftDisplayToggled, etc.
Transit	10	onMbtaStationsToggled, onMbtaTrainsToggled, onMbtaTrainsFrequencyChanged, etc.
Cameras	2	onWebcamToggled, onWebcamCategoriesChanged
Radar	3	onRadarToggled, onRadarVisibilityChanged, onRadarFrequencyChanged
POI	1	onPoiLayerToggled(layerId, enabled)
Utility	11	onPopulatePoisToggled, onProbe10kmRequested, onGpsRecordingToggled, etc.
Alerts	8	onTfrOverlayToggled, onCameraOverlayToggled, onAlertDistanceChanged, etc.
Social	3	onSocialRequested, onChatRequested, onProfileRequested
Dark Mode	1	onDarkModeToggled
Radar Anim	2	onRadarAnimateToggled, onRadarAnimSpeedChanged
Find	3	onFindRequested, onLegendRequested, onGoToLocationRequested

PoiLayerId Constants (17)

FOOD_DRINK, FUEL_CHARGING, TRANSIT, CIVIC, PARKS_REC, SHOPPING, HEALTHCARE, EDUCATION, LODGING, PARKING, FINANCE, WORSHIP, TOURISM_HISTORY, EMERGENCY, AUTO_SERVICES, ENTERTAINMENT, OFFICES

5.7 PoiCategories.kt

File: `app/src/main/java/com/example/locationmapapp/ui/menu/PoiCategories.kt` **Lines:** 366 | **Introduced:** v1.5.3 (expanded v1.5.28, v1.5.43)

Central configuration for all 17 POI categories and their subtypes. Single source of truth used by menus, markers, Find dialog, and Legend.

All 17 Categories

#	Category	Subtypes	Color	Key Tags
1	Food & Drink	12	#BF360C	restaurant, fast_food, cafe, bar, pub, ice_cream, bakery, pastry, confectionery, alcohol, deli, marketplace
2	Fuel & Charging	2	#E65100	fuel, charging_station
3	Transit	4	#0277BD	station, bus_station, bicycle_rental, ferry_terminal
4	Civic & Gov	7	#1A237E	townhall, courthouse, post_office, post_box, government, community_centre, social_facility
5	Parks & Rec	14	#2E7D32	park, nature_reserve, playground, pitch, track, recreation_ground, pool, dog_park, garden, picnic_site, shelter, fountain, water, toilets
6	Shopping	22	#F57F17	supermarket, convenience, mall, department_store, clothes, shoes, jewelry, hairdresser, beauty, books, gift, florist, furniture, hardware, mobile_phone, optician, chemist, laundry, dry_cleaning, variety_store, tobacco, storage_rental
7	Healthcare	7	#D32F2F	hospital, pharmacy, clinic, dentist, doctors, veterinary, nursing_home
8	Education	6	#5D4037	school, library, college, university, childcare, kindergarten
9	Lodging	6	#7B1FA2	hotel, motel, hostel, camp_site, guest_house, caravan_site
10	Parking	0	#455A64	parking
11	Finance	2	#00695C	bank, atm
12	Places of Worship	0	#4E342E	place_of_worship
13	Tourism & History	12	#FF6F00	museum, attraction, viewpoint, memorial, monument, artwork, gallery, information, cemetery, historic, ruins, maritime
14	Emergency Svc	2	#B71C1C	police, fire_station
15	Auto Services	6	#37474F	car_repair, car_wash, car_rental, tyres, car, car_parts

16	Entertainment	15	#00838F	fitness_centre, sports_centre, golf_course, marina, stadium, theatre, cinema, nightclub, events_venue, arts_centre, studio, dance, amusement_arcade, ice_rink, bowling_alley
17	Offices & Services	5	#546E7A	company, estate_agent, lawyer, insurance, tax_advisor

---

5.8 GeofenceEngine.kt

File: `app/src/main/java/com/example/locationmapapp/util/GeofenceEngine.kt` **Lines:** 282 | **Introduced:** v1.5.35

JTS-based spatial geofence engine with STRtree (Sort-Tile-Recursive R-tree) for fast spatial indexing.

Zone Types & Alert Severity

Zone Type	Entry	Proximity	Source	Version
TFR	CRITICAL	WARNING	FAA tfr.faa.gov	v1.5.35
SPEED_CAMERA	WARNING	WARNING	Overpass / ExCam DB	v1.5.36/v1.5.38
SCHOOL_ZONE	WARNING	WARNING	Overpass / NCES DB	v1.5.36/v1.5.38
FLOOD_ZONE	WARNING	INFO	FEMA NFHL ArcGIS	v1.5.36
RAILROAD_CROSSING	WARNING	WARNING	Overpass	v1.5.36
MILITARY_BASE	CRITICAL	WARNING	NTAD ArcGIS DB	v1.5.37
NO_FLY_ZONE	CRITICAL	WARNING	DJI NFZDB	v1.5.38
CUSTOM	WARNING	WARNING	User import	v1.5.39

Detection Logic (checkPosition)

1. **Expand search envelope** by proximity threshold (default 5 NM)
2. **Query R-tree** for candidate zones
3. For each candidate:
    - **School zone time filter:** Weekdays 7-9 AM or 2-4 PM only
    - **Altitude filter:** Skip if known altitude outside floor/ceiling
    - **Point-in-polygon test** (JTS)
    - **Entry alert:** Inside + not in activeZones + not on cooldown (10 min)
    - **Proximity alert:** Outside + within threshold + heading toward (+-60 deg) + not on cooldown (5 min)
4. **Exit alert:** Was in activeZones, now outside (INFO severity)

Constants

Constant	Value	Purpose
PROXIMITY_COOLDOWN_MS	5 min	Min time between proximity alerts for same zone
ENTRY_COOLDOWN_MS	10 min	Min time between entry alerts for same zone

BEARING_WINDOW_DEG	60 deg	+/- heading toward zone to trigger proximity
proximityThresholdNm	5.0 NM	Default proximity detection distance

---

5.9 WeatherIconHelper.kt

File: `app/src/main/java/com/example/locationmapapp/ui/WeatherIconHelper.kt` **Introduced:** v1.5.34

Maps NWS icon codes to 22 custom vector drawable icons. Handles day/night variants and fallback to default icon.

---

6. DATA LAYER

6.1 Data Models (Models.kt)

File: `app/src/main/java/com/example/locationmapapp/data/model/Models.kt`

Transit Models

Model	Fields	Notes
MbtaVehicle	id, label, routeId, routeName, tripId, headsign, stopId, stopName, lat, lon, bearing, speedMps, currentStatus, updatedAt, routeType, nextStopMinutes	nextStopMinutes added v1.5.43; computed speedMph, speedDisplay
MbtaVehicleStatus	INCOMING_AT, STOPPED_AT, IN_TRANSIT_TO, UNKNOWN	Enum with display strings
MbtaStop	id, name, lat, lon, routeIds	Parent station grouping
MbtaPrediction	id, routeId, routeName, tripId, headsign, arrivalTime, departureTime, directionId, status, vehicleId	v1.5.17
MbtaTripScheduleEntry	stopId, stopName, stopSequence, arrivalTime, departureTime, platformCode	v1.5.17

Aircraft Models

Model	Fields	Notes
AircraftState	icao24, callsign, originCountry, lat, lon, baroAltitude, onGround, velocity, track, verticalRate, geoAltitude, squawk, spi, positionSource, category	18 state vector fields
FlightPathPoint	lat, lon, altitudeMeters, timestamp	v1.5.24

Weather Models

Model	Fields	Notes
WeatherData	location, current, hourly, daily, alerts, fetchedAt	Composite, v1.5.34
CurrentConditions	temperature, humidity, windSpeed, windDirection, windChill, heatIndex, dewpoint, description, iconCode, isDaytime, visibility, barometer	

HourlyForecast	time, temperature, windSpeed, windDirection, precipProbability, shortForecast, iconCode, isDaytime	
DailyForecast	name, isDaytime, temperature, windSpeed, shortForecast, detailedForecast, iconCode, precipProbability	
WeatherAlert	id, event, headline, description, severity, urgency, instruction, effective, expires, areaDesc	
MetarStation	stationId, name, lat, lon, rawMetar, tempC, dewpointC, windDirDeg, windSpeedKt, windGustKt, visibilityMiles, altimeterInHg, slpMb, flightCategory, skyCover, wxString	v1.5.3

POI Models

Model	Fields	Notes
PlaceResult	id, name, lat, lon, category, address, phone, website, openingHours	
PopulateSearchResult	results, cacheHit, gridKey, radiusM, capped, poiNew, poiKnown	v1.5.13
FindResult	id, type, name, lat, lon, category, distanceM, tags, address, cuisine, phone, openingHours	v1.5.26
FindCounts	counts (Map<String,Int>), total	v1.5.26
FindResponse	results, totalInRange, scopeM	v1.5.26
PoiWebsite	url, source, phone, hours, address	v1.5.27

Geofence Models

Model	Fields	Notes
TfrZone	id, notam, type, description, effectiveDate, expireDate, shapes, facility, state, zoneType, metadata	v1.5.35
TfrShape	type, points, floorAltFt, ceilingAltFt, radiusNm	Points in GeoJSON [lon,lat]
GeofenceDatabaseInfo	id, name, description, version, zoneType, zoneCount, fileSize, updatedAt, source, license, installed, installedVersion	v1.5.37
GeofenceAlert	zoneId, zoneName, alertType, severity, distanceNm, timestamp, description, zoneType	v1.5.35
AlertSeverity	INFO(0), WARNING(1), CRITICAL(2), EMERGENCY(3)	Enum
ZoneType	TFR, SPEED_CAMERA, SCHOOL_ZONE, FLOOD_ZONE, RAILROAD_CROSSING, MILITARY_BASE, NO_FLY_ZONE, CUSTOM	Enum

Other Models

Model	Fields	Notes
Webcam	id, title, lat, lon, categories, previewUrl, thumbnailUrl, playerUrl, detailUrl, status, lastUpdated	v1.5.10

6.2 Repository Specifications

All repositories use OkHttp3 with 15s connect / 30s read timeouts (except GeofenceDatabaseRepository: 120s read).

MbtaRepository (v1.5.0)

Direct API: `https://api-v3.mbta.com` | **API Key:** `d2dbf0064a5a4e80b9384fea24c43c9b`

Method	Returns	Notes
fetchCommuterRailVehicles()	List	route_type = 2, enriched with ETA (v1.5.43)
fetchSubwayVehicles()	List	route_type = 0 + 1
fetchBusVehicles()	List	route_type = 3
fetchStations()	List	Subway + CR, deduped by parent station
fetchPredictions(stopId)	List	Real-time arrivals
fetchTripSchedule(tripId)	List	Full itinerary
fetchBusStops()	List	~7,900 stops via proxy
enrichWithNextStopEta(vehicles)	List	Batch predictions for all trips (v1.5.43)

AircraftRepository (v1.5.5)

Proxy: `http://10.0.0.4:3000`

Method	Returns	Notes
fetchAircraft(s, w, n, e)	List	OpenSky bbox query
fetchAircraftByIcao(icao24)	AircraftState?	Global single-aircraft query
fetchFlightHistory(icao24)	List	DB flight history (v1.5.24)

PlacesRepository (v1.5.0)

Proxy: `http://10.0.0.4:3000/overpass`

Method	Returns	Notes
searchPois(center, categories)	List	Adaptive radius with cap-retry
searchPoisCacheOnly(center, categories)	List	Cache-only, returns [] if miss
searchPoisForPopulate(center, categories, radiusOverride)	PopulateSearchResult	Returns cache hit flag + new/known counts
fetchCachedPoisInBbox(s, w, n, e)	List	Proxy POI cache bbox query

Adaptive Radius: Fetch hint → execute query → if capped (>=500 results) → halve radius and retry → post feedback.

FindRepository (v1.5.26)

Proxy: `http://10.0.0.4:3000/db/pois/*`

Method	Returns	Notes

fetchCounts(lat, lon, radiusM)	FindCounts?	10-min client cache, 500m move invalidation (v1.5.43)
findNearby(lat, lon, categories, limit, offset)	FindResponse?	Distance-sorted
fetchWebsite(osmType, osmId, name, lat, lon)	PoiWebsite?	3-tier waterfall (v1.5.27)

WeatherRepository (v1.5.0)

Proxy: `http://10.0.0.4:3000`

Method	Returns	Notes
fetchAlerts()	List	All US alerts
fetchWeather(lat, lon)	WeatherData	Composite: current + hourly + daily + alerts (v1.5.34)
fetchMetars(s, w, n, e)	List	Aviation weather

WebcamRepository (v1.5.10)

Method	Returns	Notes
fetchWebcams(s, w, n, e, categories)	List	Windy API via proxy

TfrRepository (v1.5.35)

Method	Returns	Notes
fetchTfrs(s, w, n, e)	List	FAA TFR data via proxy

GeofenceRepository (v1.5.36)

Method	Returns	Notes
fetchCameras(s, w, n, e)	List	200m circles
fetchSchools(s, w, n, e)	List	Polygon or 300m circles
fetchFloodZones(s, w, n, e)	List	FEMA polygons
fetchCrossings(s, w, n, e)	List	100m circles

GeofenceDatabaseRepository (v1.5.37)

Method	Returns	Notes
fetchCatalog()	List	Remote + local-only
downloadDatabase(id, onProgress)	Boolean	Download + save
deleteDatabase(id)	Boolean	Remove file
loadZonesFromDatabaseInBbox(id, s, w, n, e)	List	Spatial query
importSqliteDatabase(uri, overwriteId)	Pair<Boolean, String>	SAF import (v1.5.39)
importCsvAsDatabase(uri, ...)	Pair<Boolean, String>	CSV import (v1.5.39)

getDatabaseFile(id)	File?	For export (v1.5.39)
validateDatabase(dbPath)	String?	Schema validation

AuthRepository (v1.5.45)

Proxy: `http://10.0.0.4:3000/auth/*`

Method	Returns	Notes
register(displayName, email, password)	AuthTokens?	Device-bonded registration
login(email, password)	AuthTokens?	Deprecated — device-bonded model
refreshToken()	AuthTokens?	Auto-refresh on 401
logout()	Boolean	Server-side token revocation
getProfile()	UserProfile?	Current user info

Token storage in SharedPreferences (`auth_prefs`). Auto-refresh interceptor on 401 responses.

CommentRepository (v1.5.45)

Proxy: `http://10.0.0.4:3000/comments/*`

Method	Returns	Notes
fetchComments(osmType, osmId)	List	With author names, ratings, votes
postComment(osmType, osmId, content, rating)	Comment?	Requires auth
voteComment(commentId, direction)	VoteResult?	Upvote/downvote
deleteComment(commentId)	Boolean	Soft delete (own or support/owner)

ChatRepository (v1.5.45)

Proxy: `http://10.0.0.4:3000/chat/*` + `ws://10.0.0.4:3000` (Socket.IO)

Method	Returns	Notes
fetchRooms()	List	REST, includes member counts
createRoom(name, description)	ChatRoom?	REST
fetchMessages(roomId, limit, before)	List	REST, paginated
connect(token)	Unit	Socket.IO with JWT auth
disconnect()	Unit	
joinRoom(roomId)	Unit	Socket.IO event
sendMessage(roomId, content)	Unit	Socket.IO event

Real-time events: `new_message`, `user_typing`. Connect-before-join pattern with suspendCancellableCoroutine.

6.3 Dependency Injection (AppModule.kt)

All repositories provided as `@Singleton` via Hilt. PlacesRepository and GeofenceDatabaseRepository require

```
@ApplicationContext.
```

---

7. CACHE PROXY SERVER

File: `cache-proxy/server.js` (~3,700 lines) | **Port:** 3000

7.1 Infrastructure

Three Caches with Disk Persistence

Cache	File	Purpose	Debounce
General cache	`cache-data.json`	API response cache (key -> data + headers + timestamp)	2s
Radius hints	`radius-hints.json`	Adaptive search radius per grid cell ("lat3:lon3" -> radius)	2s
POI cache	`poi-cache.json`	Individual OSM elements deduped by type:id	2s

Bbox Snapping

API	Precision	Grid Size	Purpose
METAR, Webcams	0.01 deg	~1.1 km	Reduce cache misses from scrolling
Aircraft	0.1 deg	~11 km	Coarser for high-frequency data

Content Hash Delta Detection

MD5 of sorted `type:id` pairs from Overpass responses — skips POI cache update when data unchanged.

7.2 Complete Endpoint Reference

POI & Overpass Endpoints

Method	Path	TTL	Upstream
POST	/overpass	365 days	overpass-api.de (serialized, fair queue)
GET	/pois/stats	—	In-memory
GET	/pois/export	—	In-memory
GET	/pois/bbox?s=&w=&n=&e=	—	In-memory
GET	/poi/:type/:id	—	In-memory
GET	/radius-hint?lat=&lon=	—	In-memory
POST	/radius-hint	—	Updates in-memory
GET	/radius-hints	—	In-memory

PostgreSQL POI Endpoints (require DATABASE_URL)

Method	Path	Parameters	Notes
GET	/db/pois/search	q, category, s/w/n/e, lat/lon/radius, tag, limit, offset	ILIKE + Haversine

GET	/db/pois/nearby	lat, lon, radius (1000m), category, limit	Bbox pre-filter + Haversine sort
GET	/db/poi/:type/:id	—	Single POI
GET	/db/pois/stats	—	5 parallel queries
GET	/db/pois/categories	—	Category breakdown
GET	/db/pois/coverage	resolution (1-4)	Geographic grid
GET	/db/pois/counts	lat, lon, radius	10-min server cache (global only)
GET	/db/pois/find	lat, lon, categories, limit, offset	Auto-expand 50km -> 200km
GET	/pois/website	osm_type, osm_id, name, lat, lon	3-tier waterfall

PostgreSQL Aircraft Endpoints

Method	Path	Parameters	Notes
GET	/db/aircraft/search	q, icao24, callsign, country, s/w/n/e, since, until	Filtered search
GET	/db/aircraft/recent	limit	Deduped by icao24
GET	/db/aircraft/stats	—	Totals, altitude distribution
GET	/db/aircraft/:icao24	—	Full history + flight path

External API Proxies

Method	Path	TTL	Upstream API
GET	/aircraft?bbox= or ?icao24=	15s	OpenSky Network (rate limited)
GET	/metar?bbox=	1 hr	aviationweather.gov
GET	/webcams?s=&w=&n=&e=	10 min	Windy Webcams API v3
GET	/earthquakes	2 hr	USGS
GET	/nws-alerts	1 hr	NWS
GET	/weather?lat=&lon=	5min-24h	NWS composite (5 calls)
GET	/geocode?q=&limit=	24 hr	Photon/OSM
GET	/mbta/bus-stops	24 hr	MBTA API v3
GET	/tfrs?bbox=	5-10 min	FAA tfr.faa.gov (HTML + AIXM XML)
GET	/cameras?bbox=	24 hr	Overpass (speed cameras)
GET	/schools?bbox=	24 hr	Overpass (schools)
GET	/flood-zones?bbox=	30 days	FEMA NFHL ArcGIS
GET	/crossings?bbox=	7 days	Overpass (railway crossings)

POI DB Import Endpoints (v1.5.49)

Method	Path	Parameters	Notes
POST	/db/import	—	Manual trigger, returns { upserted, skipped, totalInDb, elapsed }
GET	/db/import/status	—	lastImportTime, running, pendingDelta, cacheSize, interval, stats

Auto-import: initial full import 30s after startup, then delta every 15 minutes. Only imports POIs updated since last successful run. Batches of 500 with per-batch transactions.

Auth Endpoints (v1.5.45)

Method	Path	Purpose
POST	/auth/register	Create account (Argon2id + JWT)
POST	/auth/login	Login (deprecated — device-bonded)
POST	/auth/refresh	Refresh tokens (365d lifetime)
POST	/auth/logout	Revoke refresh token
GET	/auth/me	Current user profile
GET	/auth/debug/users	All users (requires auth + owner/support role)

Comment Endpoints (v1.5.45)

Method	Path	Purpose
GET	/comments/:osm_type/:osm_id	Fetch comments for a POI
POST	/comments/:osm_type/:osm_id	Post comment with rating (requires auth)
POST	/comments/:id/vote	Upvote/downvote (requires auth)
DELETE	/comments/:id	Soft delete (own or support/owner)

Chat Endpoints (v1.5.45)

Method	Path	Purpose
GET	/chat/rooms	List all rooms with member counts
POST	/chat/rooms	Create new room (requires auth)
GET	/chat/rooms/:id/messages	Message history (paginated)
WS	Socket.IO	join_room, leave_room, send_message, typing events

Geofence & Admin Endpoints

Method	Path	Purpose
GET	/geofences/catalog	Database catalog (enriched with file sizes)
GET	/geofences/database/:id/download	SQLite file download
GET	/cache/stats	Cache performance + OpenSky rate + DB import stats
POST	/cache/clear	Clear all caches + disk files

7.3 OpenSky Rate Limiter

Setting	Value
Daily limit	4,000 (authenticated) / 100 (anonymous)
Safety margin	90% = 3,600 effective
Min interval	~24s between upstream requests
Backoff on 429	10s -> 20s -> 40s -> 80s -> 160s -> 300s cap
Stale fallback	Returns expired cache with X-Cache: STALE
Account	DeanMauriceEllis, client credentials flow

7.4 Overpass Queue System

Setting	Value
Min upstream interval	10s
Per-client queue cap	5 requests
Fair scheduling	Round-robin across clients
Cache-only mode	X-Cache-Only: true, merges 3x3 grid neighbors
Content dedup	MD5 hash of sorted element IDs
Covering cache	Checks 2x and 4x radius cached results

---

8. DATABASE LAYER

8.1 PostgreSQL Schema

Database: `locationmapapp` | **User:** `witchdoctor` | **Tables owned by:** `postgres`

pois table (180,059 rows — auto-imported every 15min)

Column	Type	Notes
osm_type	TEXT	PK part 1 (node/way/relation)
osm_id	BIGINT	PK part 2
lat, lon	DOUBLE PRECISION	
name	TEXT	Nullable
category	TEXT	e.g., "amenity=restaurant"
tags	JSONB	Full OSM tags (GIN indexed)
first_seen, last_seen	TIMESTAMPTZ	

Indexes: category, name (partial), tags (GIN), (lat,lon), (category,lat,lon)

aircraft_sightings table (501+ rows)

Column	Type	Notes
id	SERIAL	PK
icao24	TEXT	Aircraft identifier
callsign, origin_country	TEXT	
first_seen, last_seen	TIMESTAMPTZ	
first/last_lat/lon/altitude/heading	DOUBLE PRECISION	
last_velocity, last_vertical_rate	DOUBLE PRECISION	m/s
squawk	TEXT	
on_ground	BOOLEAN	

Sighting logic: 5-min gap = new row. 195 unique aircraft as of 2026-03-01.

Social Tables (v1.5.45, 8 tables)

Table	Purpose
users	User accounts (UUID PK, display_name, role, created_at)
auth_lookup	Email → user mapping (Argon2id password hash)
refresh_tokens	JWT refresh tokens (family-based rotation, 365d lifetime)
poi_comments	Comments on POIs (content, rating 1-5, soft delete)
comment_votes	Upvote/downvote tracking (user + comment, direction)
chat_rooms	Chat rooms (name, description, type, created_by)
room_memberships	User ↔ room join tracking
messages	Chat messages (content, author, room, timestamp)

All granted to `witchdoctor` user. DDL runs as `sudo -u postgres bash create-social-tables.sh`.

Security hardening (v1.5.47): sanitizeText/sanitizeMultiline on all text inputs, rate limiting (auth 10/15min, comments 10/1min, rooms 5/1hr, Socket.IO 30/60s), login lockout (5 fails → 15min), JSON body limit 16kb.

8.2 Geofence SQLite Schema

Shared across all 4 downloadable databases + user imports:

Table	Purpose
db_meta	Key-value metadata (id, name, version, zone_type, zone_count, etc.)
zones	Zone definitions with geometry (polygon or circle) + bbox index

4 Pre-Built Databases (220,657 total zones):

Database	Zones	Source	Build Script
military-bases.db	1,944	HIFLD/NTAD ArcGIS	build-military.js

excam-cameras.db	109,500	WzSabre XZ/NDJSON	build-excam.js
nces-schools.db	101,390	NCES EDGE ArcGIS	build-nces.js
dji-nofly.db	7,823	DJI NFZDB CSV	build-dji-nofly.js

8.3 Build Scripts

All in `cache-proxy/geofence-databases/`:

Script	Source	Fetch Method	Output
build-military.js	ArcGIS NTAD Military Bases	Paginated GeoJSON (200/batch)	Polygons
build-excam.js	wzsabre.rocks cameras.download	XZ decompression + NDJSON	200m circles
build-nces.js	NCES EDGE ArcGIS MapServer	Paginated JSON (1000/batch)	300m circles
build-dji-nofly.js	GitHub DJI NFZDB CSV	CSV download + parse	Variable circles

All scripts auto-update `catalog.json` with final zone count, file size, and date.

POI Import (Automated — v1.5.49): Server.js runs delta imports every 15 minutes (only POIs updated since last successful run). Initial full import 30s after startup. Manual trigger: `POST /db/import` or standalone `node import-pois.js`.

Category derivation: amenity > shop > tourism > leisure > historic > office. UPSERTs into pois table (ON CONFLICT osm_type, osm_id).

---

9. DEBUG & TESTING INFRASTRUCTURE

9.1 Debug HTTP Server

File: `app/src/main/java/com/example/locationmapapp/util/DebugHttpServer.kt` **Port:** 8085 | **Introduced:** v1.5.18

Minimal embedded HTTP/1.0 server running on `Dispatchers.IO`. CORS enabled. Lifecycle-aware (start in onCreate, stop in onDestroy).

Access: `adb forward tcp:8085 tcp:8085 && curl localhost:8085/state | jq .`

9.2 Debug Endpoints (24)

File: `app/src/main/java/com/example/locationmapapp/util/DebugEndpoints.kt`

Endpoint	Description	Version
GET /	List all endpoints	v1.5.18
GET /state	Map center, zoom, bounds, marker counts, follow state, statusLine	v1.5.18
GET /logs?tail=&filter=&level=	Debug log entries (filtered)	v1.5.18
GET /logs/clear	Clear log buffer	v1.5.18
GET /map?lat=&lon=&zoom=	Set/read map position	v1.5.18
GET /markers?type=&limit=	List markers by type	v1.5.18

GET /markers/tap?type=&index=	Trigger marker click (reflection)	v1.5.18
GET /markers/nearest?lat=&lon=&type=	Find nearest markers	v1.5.18
GET /markers/search?q=&type=	Search markers (fuzzy)	v1.5.18
GET /vehicles?type=&limit=&index=	Raw vehicle data	v1.5.21
GET /stations?limit=&q=	Station data with search	v1.5.21
GET /bus-stops?limit=&q=	Bus stop data with search	v1.5.21
GET /screenshot	PNG of root view	v1.5.18
GET /livedata	All ViewModel LiveData values	v1.5.18
GET /prefs	Dump SharedPreferences	v1.5.18
GET /toggle?pref=&value=	Toggle preference + fire handler	v1.5.18
GET /search?lat=&lon=	Trigger POI search at point	v1.5.18
GET /refresh?layer=	Force refresh a layer	v1.5.18
GET /follow?type=&icao=/index=	Follow aircraft/vehicle	v1.5.18
GET /stop-follow	Stop following	v1.5.18
GET /perf	Memory, threads, uptime	v1.5.18
GET /overlays	Map overlay inventory	v1.5.18
GET /geofences	Loaded geofence zones by type	v1.5.35
GET /geofences/alerts	Active geofence alerts	v1.5.35

Marker Types: poi, stations, trains, subway, buses, aircraft, webcams, metar, gps

Fuzzy Search: Abbreviation expansion (mass->massachusetts, ave->avenue, st->street, sq->square, etc.)

9.3 Test Harness Scripts

Script	Lines	Duration	Tests	Purpose
test-app.sh	~650	~1 min	30+	Quick smoke test (9 suites)
overnight-test.sh	~1,850	6-8 hrs	67+	Endurance: memory, cache, OpenSky, transit ramp
morning-transit-test.sh	~500	~1 hr	36+	Deep transit validation (peak hours)
run-full-test-suite.sh	~100	7-9 hrs	All	Chains overnight -> morning

Latest Results (2026-03-01): 103 PASS, 0 FAIL

Test Output Structure:

```
overnight-runs/YYYY-MM-DD_HHMM/
  events.log          — timestamped PASS/FAIL/WARN/INFO
  time-series.csv     — 30-column CSV (memory, markers, cache, OpenSky)
  report.md           — final summary with recommendations
  baseline/           — initial state snapshots
  snapshots/          — periodic JSON state every 5 min
```

```
screenshots/        — PNG captures every 15 min
logs/               — error snapshots
```

---

10. XML LAYOUTS & RESOURCES

Layouts (4 files)

Layout	Purpose	Key Views
activity_main.xml	Main screen	CoordinatorLayout, AppBarLayout, MapView, zoom slider, FAB
toolbar_two_row.xml	Toolbar	40dp icon row (Weather + Alerts + Grid) + 24dp status line
grid_dropdown_panel.xml	Grid menu	3×4 PopupWindow with 12 labeled buttons
fab_menu_item.xml	Menu item	Icon (26dp) + label (13sp) on pill background

Drawable Resources (58+ files)

Category	Count	Examples
Weather icons	22	ic_wx_clear_day, ic_wx_rain, ic_wx_thunderstorm, ic_wx_tornado
Grid/toolbar icons	13	ic_grid_menu, ic_transit_rail, ic_aircraft, ic_radar, ic_search, ic_social, ic_chat, ic_profile, ic_legend
POI category icons	8	ic_restaurant, ic_gas_station, ic_park, ic_civic
Utility icons	7	ic_crosshair, ic_record_gps, ic_gpx_export, ic_gps
Feature icons	4	ic_share, ic_dark_mode, ic_star, ic_star_outline
Shapes	4	fab_item_bg, zoom_button_bg, zoom_bubble_bg, zoom_slider_track
Launcher	3	ic_launcher_background, ic_launcher_foreground, ic_launcher

Menu Resources (8 files)

Menu	Items	Purpose
menu_main_toolbar.xml	9	Top-level toolbar items
menu_poi.xml	17	POI category toggles (all checkable)
menu_transit.xml	8	MBTA layers + frequencies
menu_utility.xml	13	GPS, populate, debug tools
menu_alerts.xml	8	Geofence overlays + DB manager
menu_radar.xml	5	Radar + METAR toggles + sliders
menu_aircraft.xml	3	Aircraft toggle + frequency + auto-follow
menu_cams.xml	2	Webcam toggle + categories

Theme

Base: Theme.MaterialComponents.DayNight.NoActionBar **Primary:** #1565C0 (Material Blue 700) **Accent:** #FF6F00 (Material Deep Orange 700) **Dark mode:** Auto via DayNight parent

---

11. MAP INTERACTION MODEL

Gesture	Action	Version
Tap POI marker	Open POI detail dialog (info, comments, actions)	v1.5.46
Long press (~2s)	Manual mode: center map, auto-zoom to 18, search POIs, fetch weather + alerts	v1.5.0/v1.5.48
Scroll/pan	Load cached POIs for visible area (viewport-only), debounced layer reloads	v1.5.6
Zoom in	Show POI labels at >=18, vehicle labels at >=18, bus stops at >=15	v1.5.7/v1.5.29
Zoom out	Hide transit at <=10, hide POIs at <10, 5000-marker guard	v1.5.25/ v1.5.42
Tap vehicle	Vehicle detail dialog (Follow/Route/Arrivals)	v1.5.19
Tap station	Arrival board (30s auto-refresh) -> tap row -> trip schedule	v1.5.17
Tap bus stop	Arrival board with bus predictions	v1.5.19
Tap aircraft	Follow mode (global ICAO24 tracking, flight trail)	v1.5.6
Tap webcam	Preview image + View Live button	v1.5.10
Tap METAR	Decoded weather info (wind, sky, flight category)	v1.5.4
Tap geofence	Zone detail dialog (color bar, metadata)	v1.5.35
Tap status line	Stop follow/scan (context-sensitive)	v1.5.40
Tap Find result	POI Detail dialog (info, website, action buttons)	v1.5.27
Long-press Find	Filter map to single category	v1.5.26
Touch during idle scan	Cancel idle populate, reset 10-min timer	v1.5.41/ v1.5.48

---

12. EXTERNAL API ROUTING TABLE

API	App Endpoint	Proxy Route	TTL	Auth
Overpass (POI)	POST 10.0.0.4:3000/overpass	POST /overpass	365 days	X-Client-ID
NWS Alerts	GET 10.0.0.4:3000/nws-alerts	GET /nws-alerts	1 hour	User-Agent
NWS Weather	GET 10.0.0.4:3000/weather	GET /weather (composite)	5min-24h	User-Agent
Aviation Weather	GET 10.0.0.4:3000/metar	GET /metar	1 hour	None

OpenSky Network	GET 10.0.0.4:3000/aircraft	GET /aircraft	15s	OAuth2 Bearer
Windy Webcams	GET 10.0.0.4:3000/webcams	GET /webcams	10 min	API key
FAA TFRs	GET 10.0.0.4:3000/tfrs	GET /tfrs	5-10 min	None (scraping)
Overpass (cameras)	GET 10.0.0.4:3000/cameras	GET /cameras	24 hr	None
Overpass (schools)	GET 10.0.0.4:3000/schools	GET /schools	24 hr	None
FEMA NFHL	GET 10.0.0.4:3000/flood-zones	GET /flood-zones	30 days	None
Overpass (crossings)	GET 10.0.0.4:3000/crossings	GET /crossings	7 days	None
Photon Geocoder	GET 10.0.0.4:3000/geocode	GET /geocode	24 hr	None
MBTA Bus Stops	GET 10.0.0.4:3000/mbta/bus-stops	GET /mbta/bus-stops	24 hr	API key
USGS Earthquakes	GET 10.0.0.4:3000/earthquakes	GET /earthquakes	2 hr	None
Auth	POST 10.0.0.4:3000/auth/*	POST /auth/register, /login, /refresh, /logout; GET /me	—	JWT
Comments	GET/POST 10.0.0.4:3000/comments/*	GET/POST/DELETE /comments/*	live	JWT
Chat	GET/POST 10.0.0.4:3000/chat/*	REST + Socket.IO	live	JWT
DB Import	POST 10.0.0.4:3000/db/import	POST /db/import; GET /db/import/status	live	None
MBTA Vehicles	direct api-v3.mbta.com	—	—	API key
MBTA Stations	direct api-v3.mbta.com	—	—	API key
MBTA Predictions	direct api-v3.mbta.com	—	—	API key
MBTA Schedules	direct api-v3.mbta.com	—	—	API key
Radar Tiles	direct mesonet.agron.iastate.edu	—	—	None

---

13. PROJECT STATE

The complete STATE.md file is maintained at the project root and serves as the primary reference for current feature status, architecture, and configuration. Key metrics as of v1.5.49:

- **17 POI categories** with 127 subtypes

- **180,059 POIs** in PostgreSQL (auto-imported every 15min)
- **501+ aircraft sightings** across 195 unique aircraft
- **220,657 geofence zones** across 4 downloadable databases
- **8 geofence zone types** (5 live + 3 downloadable-only)
- **50+ proxy endpoints**, **24 debug endpoints**
- **103 automated tests**, 0 failures
- **7-priority StatusLineManager**
- **3-tier website resolution** (OSM -> Wikidata -> DuckDuckGo)
- **Social layer**: device-bonded auth, POI comments with ratings, real-time Socket.IO chat
- **Security hardening**: server-side sanitization, rate limiting, login lockout, client-side input limits

---

14. FULL CHANGELOG

v1.5.49 (2026-03-03) — Automated POI DB Import

- Delta POI import every 15 minutes (inline in server.js)
- Initial full import 30s after startup, then delta-only
- POST /db/import (manual trigger), GET /db/import/status
- dbImport stats in /cache/stats

v1.5.48 (2026-03-03) — Startup/Behavior Tuning

- Default zoom 14 → 18 (first GPS fix, GoTo, long-press)
- Radar transparency 70% → 35%
- Idle auto-populate POI density guard (≥100 POIs within 10km → skip)

v1.5.47 (2026-03-03) — Security Hardening

- Server-side sanitization (sanitizeText/sanitizeMultiline)
- Rate limiting (express-rate-limit): auth, comments, rooms, Socket.IO
- Login lockout: 5 fails → 15min IP lock
- Client-side InputFilter.LengthFilter, comment char counter
- Debug endpoint auth-gated

v1.5.46 (2026-03-03) — POI Click-Through & Device-Bonded Auth

- POI marker tap → full detail dialog (was info-window only)
- Device-bonded auth model (register-only, no login/logout)
- PlaceResult.id "type:id" format for OSM type preservation
- Fixed: delete button hidden on deleted comments

v1.5.45 (2026-03-03) — Social Layer (Auth, Comments, Chat)

- Auth: register/login, Argon2id + JWT (15min access + 365d refresh)
- POI Comments: ratings, votes, soft-delete, in detail dialog

- Chat: Socket.IO real-time, room list, global room, create rooms
- Grid dropdown 3×4 (12 buttons) — Row 3: Social, Chat, Profile, Legend
- 8 social DB tables, 3 new Android repositories

v1.5.44 (2026-03-03) — Share, Dark Mode, Favorites, Search, Animated Radar

- Share POI: 5th action button, shares via Android share sheet
- Dark mode: CartoDB Dark Matter tiles, toolbar moon icon
- Favorites: star in POI detail, SharedPreferences+JSON storage
- Text search: search bar in Find dialog, 500ms debounce
- Animated radar: 7-frame NEXRAD loop (35 min), configurable speed

v1.5.43 (2026-03-02) — Train ETA, POI Categories, Find Radius

- Train next-stop ETA badge (batch predictions API)
- 17th POI category (Offices & Services) + 46 new subtypes
- Find dialog radius-scoped counts (10km Haversine)
- Find dialog auto-fit cell heights
- Fixed: 10km probe zoom (panMap=false)
- Fixed: GoTo stops 10km probe

v1.5.42 (2026-03-02) — 10km Probe Populate

- 10km Probe Populate (expanding spiral, pan without zoom)
- estimateFillRadius() for density-based radius recommendation
- POI display zoom guard lowered to 10, 5000-marker count guard

v1.5.41 (2026-03-02) — Idle Populate Improvements

- 5-min GPS stationarity threshold (was 60s)
- Touch-to-stop, state preservation, no auto-pan
- Long-press fetches weather + alerts

v1.5.40 (2026-03-02) — Slim Toolbar Redesign

- Slim toolbar (40dp) + status line (24dp) + grid dropdown (2x4)
- StatusLineManager with 7 priority levels
- Eliminated followBanner + 10 ICON_* constants

v1.5.39 (2026-03-02) — Database Import & Export

- Import SQLite .db and CSV via SAF file picker
- Export via share intent (FileProvider)
- Local-only database display

v1.5.38 (2026-03-02) — 3 More Geofence Databases

- ExCam cameras (109,500), NCES schools (101,390), DJI no-fly (7,823)

- Total: 4 databases, 220,657 zones

v1.5.37 (2026-03-02) — Downloadable DB Infrastructure

- GeofenceDatabaseRepository, Database Manager dialog
- Military bases database (1,944 zones)
- Catalog + download proxy endpoints

v1.5.36 (2026-03-02) — 4 Additional Zone Types

- Speed cameras, school zones, flood zones, railroad crossings
- GeofenceRepository with 4 proxy endpoints

v1.5.35 (2026-03-02) — TFR Geofence System

- GeofenceEngine (JTS R-tree), TFR polygons, entry/proximity/exit alerting
- FAA TFR scraping (AIXM XML), severity-colored alerts icon

v1.5.34 (2026-03-02) — Weather Dialog

- Rich weather dialog (current + hourly + daily + alerts)
- Composite /weather endpoint (5 NWS calls), 22 weather icons

v1.5.33 (2026-03-02) — Idle Populate & Delta Cache

- Idle auto-populate (60s stationarity), X-Client-ID header
- Covering cache, content hash delta, per-client fair queue

v1.5.32 (2026-03-02) — Geocode Autocomplete

- Photon geocoder via proxy /geocode, US-only, 500ms debounce

v1.5.31 (2026-03-01) — Icon Toolbar & GoTo

- Icon toolbar (8 icons), Go to Location dialog

v1.5.30 (2026-03-01) — Smart GPS

- Dead zone filtering (100m), speed-adaptive polling, 3km POI threshold

v1.5.29 (2026-03-01) — Labeled Vehicles

- Labeled vehicle markers at zoom >= 18

v1.5.28 (2026-03-01) — Silent Fill & 23 Subtypes

- Silent background POI fill, 23 new POI subtypes

v1.5.27 (2026-03-01) — POI Detail Dialog

- POI Detail dialog with website resolution (3-tier waterfall)

- In-app WebView, Directions/Call/Reviews/Map buttons

v1.5.26 (2026-03-01) — Find Dialog

- Find dialog (category grid -> subtype grid -> results)
- /db/pois/counts and /db/pois/find endpoints, long-press filter mode

v1.5.25 (2026-03-01) — Legend & Zoom Guards

- Legend dialog (7 sections), transit zoom guard, long-press auto-zoom

v1.5.24 (2026-03-01) — Flight Trail

- Aircraft flight path visualization (altitude-colored polyline)
- DB history + live path, 1000-point cap

v1.5.23 (2026-03-01) — Aircraft DB & Fuzzy Search

- 4 aircraft DB endpoints, fuzzy search with abbreviations
- Bbox snapping (0.01/0.1 deg)

v1.5.22 (2026-03-01) — Test Harness

- overnight-test.sh, morning-transit-test.sh, run-full-test-suite.sh
- 103 PASS, 0 FAIL

v1.5.21 (2026-03-01) — Debug API Expansion

- /vehicles, /stations, /bus-stops endpoints, relatedObject on markers
- test-app.sh (30+ tests)

v1.5.20 (2026-03-01) — Bus Stops via Proxy

- Bus stops cached through proxy (24h TTL)

v1.5.19 (2026-03-01) — Bus Stops & Vehicle Dialog

- ~7,900 bus stop markers, zoom >= 15 guard
- Vehicle detail dialog (Follow/Route/Arrivals)

v1.5.18 (2026-02-28) — Debug HTTP Server

- Embedded debug server (port 8085), 19 initial endpoints

v1.5.17 (2026-02-28) — Train Stations

- ~270 station markers, arrival board dialog, trip schedule dialog

v1.5.16 (2026-02-28) — Populate v2

- Probe-calibrate-subdivide scanner, recursive 3x3 subdivision

- Overpass queue (serialized, 10s gap, fair queue)

v1.5.15 (2026-02-28) — Cap Retry & Fuzzy Hints

- Auto-retry on 500-element cap, 20km fuzzy hints, MIN_RADIUS 100m

v1.5.14 (2026-02-28) — Populate Tuning

- 30s fixed pacing, cap detection, zoom-14 view

v1.5.13 (2026-02-28) — Populate Scanner v1

- Spiral grid scanner, X-Cache header

v1.5.12 (2026-02-28) — Air Menu & Staleness

- Dedicated Air menu, vehicle staleness detection (>2 min)

v1.5.11 (2026-02-28) — Rate Limiter

- OpenSky rate limiter (exponential backoff), stale cache fallback
- Webcam live player in WebView

v1.5.10 (2026-02-28) — Webcams

- Webcam layer (Windy API, 18 categories, preview + live player)

v1.5.9 (2026-02-28) — Viewport-Only POIs

- Viewport-only markers (~100-400), LRU icon cache (500 entries)

v1.5.8 (2026-02-28) — DB Queries & OpenSky Auth

- 6 PostgreSQL endpoints, aircraft sightings DB, OpenSky OAuth2

v1.5.7 (2026-02-28) — Auto-Follow & POI Labels

- Auto-follow aircraft (POI Builder), POI labels at zoom >= 18

v1.5.6 (2026-02-28) — Aircraft Follow

- Aircraft follow mode (icao24), enhanced markers (callsign, SPI)
- Cached POI bbox display

v1.5.5 (2026-02-28) — Aircraft Tracking

- Aircraft tracking (OpenSky), altitude-colored airplane icons

v1.5.4 (2026-02-28) — Arrows & METAR

- Vehicle direction arrows, human-readable METAR tap info

v1.5.3 (2026-02-28) — 16 POI Categories

- 16 categories with submenus, rich METAR markers, central config

v1.5.2 (2026-02-28) — PostgreSQL

- POI database (PostgreSQL), JSONB tags, import script

v1.5.1 (2026-02-27) — Adaptive Radius

- Adaptive POI search radius, per-grid-cell hints

v1.5.0 (2026-02-27) — Foundation

- Cache proxy, vehicle follow, manual location, radar, 5dp dots

---

15. KNOWN ISSUES & FUTURE WORK

Known Issues

- MBTA API key hardcoded in MbtaRepository.kt (should be in BuildConfig/secrets)
- Windy Webcams API key hardcoded in server.js (free tier)
- 10.0.0.4 proxy IP hardcoded (local network only)
- OpenSky state vector category field (index 17) not always present (guarded)

Future Work

- Monitor cache growth and hit rates over time
- Evaluate proxy -> remote deployment for non-local testing
- Find dialog enhancements: pagination, search within results, recent searches
- Fill Probe Populate implementation (stub exists in v1.5.42)
- Geofence Phase 5: Advanced Sources (deferred — sufficient coverage)
- Social Phase D: room bans, promote/demote mod, mute/kick/ban
- Social governance: COPPA age gate, email encryption, content moderation pipeline

---

APPENDIX: KEY FILE INDEX

File	Lines	Purpose
`ui/MainActivity.kt`	~8,500	Main activity, all UI, map, markers, dialogs, social
`ui/MainViewModel.kt`	~900	ViewModel, 22+ LiveData fields, 60+ methods
`ui/MarkerIconHelper.kt`	680	Icon rendering, LRU cache, labeled markers
`ui/StatusLineManager.kt`	105	7-priority toolbar status line
`ui/WeatherIconHelper.kt`	~50	NWS icon code mapping

ui/menu/AppBarMenuManager.kt	~900	Toolbar, 3×4 grid dropdown, sub-menus, prefs
ui/menu/MenuEventListener.kt	~250	45+ callback interface
ui/menu/PoiCategories.kt	366	17 categories, 127 subtypes
data/model/Models.kt	~450	32+ data classes
data/repository/MbtaRepository.kt	~500	MBTA transit + predictions
data/repository/AircraftRepository.kt	~200	OpenSky aircraft
data/repository/PlacesRepository.kt	~350	Overpass POI with adaptive radius
data/repository/WeatherRepository.kt	~200	NWS + METAR
data/repository/FindRepository.kt	~150	Find dialog DB queries + text search
data/repository/WebcamRepository.kt	~100	Windy webcams
data/repository/TfrRepository.kt	~100	FAA TFRs
data/repository/GeofenceRepository.kt	~250	4 live zone types
data/repository/GeofenceDatabaseRepository.kt	~400	Downloadable DBs + import/export
data/repository/AuthRepository.kt	~200	JWT auth, token storage, auto-refresh
data/repository/CommentRepository.kt	~150	POI comments CRUD
data/repository/ChatRepository.kt	~250	Socket.IO chat + REST rooms/messages
di/AppModule.kt	~60	Hilt DI configuration (12 repositories)
util/GeofenceEngine.kt	282	JTS R-tree spatial engine
util/FavoritesManager.kt	~100	SharedPreferences+JSON favorites CRUD
util/DebugHttpServer.kt	~100	Embedded HTTP server
util/DebugEndpoints.kt	~600	24 debug endpoint handlers
cache-proxy/server.js	~3,700	Express proxy, 50+ endpoints, auth, chat, auto-import
cache-proxy/schema.sql	~50	PostgreSQL schema
cache-proxy/import-pois.js	~100	POI bulk import (standalone, superseded by auto-import)
cache-proxy/geofence-databases/build-military.js	~200	Military base builder
cache-proxy/geofence-databases/build-excam.js	~200	Speed camera builder
cache-proxy/geofence-databases/build-nces.js	~200	School builder
cache-proxy/geofence-databases/build-dji-nofly.js	~150	DJI no-fly builder
test-app.sh	~650	Quick test suite (30+ tests)

`overnight-test.sh`	~1,850	Overnight harness
`morning-transit-test.sh`	~500	Morning transit test
`run-full-test-suite.sh`	~100	Master test runner

Document Generated: 2026-03-03 (updated from v1.5.43 to v1.5.49) **Total Kotlin Lines:** ~11,500 **Total JavaScript Lines:** ~4,800 **Total Test Script Lines:** ~3,100 **GitHub:** https://github.com/deanmauriceellis-cloud/LocationMapApp.git

WickedSalemWitchCityTour — Privacy Policy

Status: DRAFT — pending OMEN review against OMEN-008 before Salem radio-environment ingest goes live. **Draft version:** 0.1 **Drafted:** 2026-04-10 (Session 114) **Scope of this draft:** satisfies OMEN-008 §8 (layered disclosure) for the LocationMapApp Salem module's participation in the RadioIntelligence Salem stream. **Legal entity placeholders:** all references to "we," "us," and the operating entity are placeholders pending final company/trading-name decision. All contact addresses are placeholders.

---

1. Install-screen blurb (short form)

This is the text that appears in the install-time consent surface and in the app's in-settings privacy section. It is intentionally short; the linked Privacy Policy (section 2 onward) is the authoritative disclosure.

> ***Privacy summary.*** *WickedSalemWitchCityTour collects location data to deliver the tour and, while the app is running in Salem, also collects anonymized information about nearby Bluetooth, Wi-Fi, and cellular devices to improve tour analytics and help respond to security incidents in the area. You are consenting to this collection by installing the app. See the full Privacy Policy for what is collected, how it is stored, how long it is kept, and how it may be used.*
>
> *[Read the full Privacy Policy]*

The "Read the full Privacy Policy" link opens the text below (either as an in-app WebView or as a link to a hosted copy of the same text — either is acceptable so long as the content is identical).

---

2. Full Privacy Policy

2.1 Who we are and what this policy covers

WickedSalemWitchCityTour ("the app") is a GPS-guided walking-tour application for Salem, Massachusetts, produced by **[OPERATING ENTITY TBD]** ("we," "us"). This Privacy Policy explains every category of data the app collects, why we collect it, where it is stored, how long it is kept, and who can see it.

This policy covers two distinct collection activities:

1. **Tour operation** — the data the app needs to deliver the walking-tour product itself (your location on the map, which points of interest you are near, which narrations to play).
2. **Salem radio-environment analytics** — a secondary, anonymized data collection that only occurs while you are using the app inside the Salem tour area. This data feeds an aggregate heatmap and density analytics system and is cross-referenced against a security threat list operated by the same entity. This is the part of the policy that matters most for your informed consent and is explained in full in section 2.4 below.

If you are comfortable with GPS-based tour apps but want to understand the radio-environment collection specifically, read section 2.4.

2.2 Data we collect for tour operation

While you are actively using the app:

- **GPS location** — used to position you on the map, trigger point-of-interest narrations, and compute walking directions. Resolution is limited to what the device's GPS hardware provides. Location is used in-memory to drive the tour experience and is written to on-device logs for crash-recovery and debugging. Raw per-fix GPS data is not uploaded to our servers as part of tour operation.
- **Device model, OS version, and app version** — used to diagnose crashes and compatibility issues if you contact support.
- **Tour progress** — which stops you have visited, which narrations have played. Stored locally on your device in the app's private database. Not uploaded.
- **Cached map tiles and point-of-interest data** — bundled with the app or downloaded on demand. Not tied to your identity.

The app works fully offline for the Salem tour. Tour operation does not require a network connection and does not transmit your tour progress or location history to any server.

2.3 What the app does NOT collect for tour operation

- We do not collect your name, email address, phone number, or any account identifier. The app has no user accounts.
- We do not use third-party analytics SDKs (Google Analytics, Firebase Analytics, Facebook SDK, AppsFlyer, or similar) for tour operation.
- We do not sell your data to advertisers or data brokers.
- We do not serve personalized advertising.

2.4 Salem radio-environment analytics (OMEN-008 Salem stream)

This is the section that matters most for your consent. Please read it carefully.

2.4.1 What is collected

While you are using the app inside the Salem tour area, the app also reads the radio environment around your phone. Specifically:

- **Bluetooth Low Energy (BLE) advertisements** broadcast by nearby devices (phones, wearables, tags, beacons, vehicles).
- **Wi-Fi probe requests and beacon frames** broadcast by nearby devices and access points.
- **Cellular tower information** observable by your phone in the normal course of its network operation.
- **Your GPS location at the time of each of those observations**, so the observations can be placed on a map.

These radio signals are broadcast into public space by the devices that emit them. Your phone is the device doing the listening. The app does not transmit anything itself as part of this collection — it only listens to signals that are already being broadcast by devices around you.

2.4.2 The consenting-proxy architecture (the part you should understand)

You are consenting to this collection on your own behalf. The third-party devices the app observes are not — they did not agree to be observed, and we have no practical way to ask them.

This is a known limitation of any radio-environment collection by a mobile application, and we are telling you about it honestly rather than hiding it in legal language. The legal and practical justification is threefold:

1. BLE, Wi-Fi, and cellular identifiers are broadcast in public radio space. Receiving them does not require any special access.
2. Your phone is your own private device. You, the app user, are the one deciding to run software that listens to that public radio space.
3. The collected observations are hashed (see 2.4.3) before being stored or transmitted, so third-party devices are not identifiable by name or raw address in the system of record.

We acknowledge this consent asymmetry in this policy rather than pretending it doesn't exist. If this model is not acceptable to you, do not install the app.

2.4.3 How the data is stored

Every device identifier observed by the app (BLE address, Wi-Fi MAC, cellular identifier) is passed through a **one-way cryptographic hash** before it is stored or transmitted. The hash is produced with a keyed hash function ("salted hash") and the salt lives on the operator's own server hardware, not on the phone and not in the app.

This means:

- The system of record stores **hashes**, not raw MAC addresses or raw device identifiers.
- The same physical device produces the same hash in every observation, so density and heatmap analytics (how many distinct devices passed through an area) are still possible — but the identity of any individual device is not directly visible in the stored data.
- Turning a hash back into a raw identifier requires access to a separate, more-restricted lookup table that is gated behind manual operator action (see 2.4.6).

The hashed observations are transmitted from your phone through a minimal cloud relay to a single **PostgreSQL/PostGIS database on operator-owned hardware**. The relay itself does not retain any of the data on disk — it receives the upload and forwards it directly to the operator's server. The system of record is the operator's server; the cloud relay exists only because phones can be anywhere in the world and need a reachable endpoint.

2.4.4 Retention windows

Data collected under 2.4.1 is retained on a tiered schedule:

Data type	Retention
Aggregate heatmaps and density metrics (no per-device records)	Indefinite
Hashed per-device observations (raw records the aggregates are computed from)	Rolling 30-day window; older records are purged automatically
Hash-to-raw-identifier lookup table (the table needed to de-anonymize a hash)	Rolling 90-day window; older entries are purged automatically

If a specific device is promoted from the Salem dataset into the operator's separate security threat-awareness system (see 2.4.5), the records relevant to that specific device may be copied into the security system before Salem's retention schedule purges them. Promotion is rare, intentional, and audited (see 2.4.6).

2.4.5 Cross-reference with the operator's security systems

This is the second fact you need to understand for informed consent.

The operator of this app also operates a separate defensive security system ("the security system") that maintains a list of device identifiers of interest for threat-awareness reasons unrelated to the Salem tour. The Salem radio-environment data and the security system **share a unified hash function and salt**, meaning that any physical device observed in both contexts produces the same hash in both datasets.

The practical consequence: any device that has ever been observed by the operator's separate security system is directly identifiable in the Salem dataset on first contact, with no hash-table escalation required. The Salem hashed-by-default model protects only devices that have never been seen by the security system.

We are telling you this honestly rather than claiming Salem data is fully anonymized, because it is not fully anonymized for devices that already exist in the security system's records. This is a deliberate design decision made in service of the security system's threat-awareness mission. If this model is not acceptable to you, do not install the app.

When Salem observations arrive at the operator's server, they are automatically cross-referenced against the security system's list of devices of interest. If a match occurs, an alert is produced and delivered to the security system's operator. This matching happens within seconds of upload.

2.4.6 The criminal-exception escalation

The hash-to-raw-identifier lookup table described in 2.4.3 is not accessible by any automated code path. It can only be unlocked by a **manual action taken by a specific human operator**, accompanied by a **typed justification** describing the specific incident that requires the lookup (for example: "vandalism reported at [location] at [time]").

Every such escalation — including the operator identity, the typed justification, the date and time, and the scope of the lookup — is written to an **append-only audit log** that cannot be edited or deleted by any code path in the system. The audit log is preserved indefinitely and is reviewed periodically by an independent governance process.

The escalation path exists so that the operator can respond to actual criminal incidents (vandalism, assault, theft) reported at or near the Salem tour area when the responsible device may have been observed in the dataset. It is not used for marketing, advertising, analytics, curiosity, or any non-criminal purpose.

2.4.7 Who can see the data

- **Aggregate heatmap data** — visible to the operator and potentially published in aggregated form (density statistics, popular-area heatmaps).
- **Hashed per-device observations** — visible only to the operator, on operator-owned hardware, and only during their 30-day retention window.
- **Raw device identifiers (post-escalation)** — visible only to a specific human operator who has performed the manual escalation described in 2.4.6, and only for the specific incident described in the typed justification.
- **Third parties (advertisers, data brokers, marketing platforms)** — never, by design, for any tier of this data.

2.4.8 Data sovereignty and legal jurisdiction

The system of record for the Salem radio-environment dataset is physical hardware in **[JURISDICTION TBD]**, owned and operated by **[OPERATING ENTITY TBD]**. The cloud relay that phones upload through contains no data at rest and is not the system of record.

2.5 Your choices

- **You can decline this collection by not installing the app.** Because the consent model is install-

time and the radio-environment collection is part of the Salem tour experience, there is no in-app toggle to disable it while keeping the rest of the app functional. If you do not consent to 2.4, do not install.

- **You can uninstall at any time.** Uninstalling the app stops all future collection immediately. Data already collected before uninstall remains subject to the retention windows in 2.4.4.
- **You can contact us** at the address in section 2.7 to ask a question about this policy or about data related to a device you own.

2.6 Children

The app is not directed at children under 13 and does not knowingly collect information from them. Historical content in the tour references witch-trial history and may not be suitable for all ages.

2.7 Contact

Questions about this Privacy Policy, or requests related to data about a device you own, can be sent to:

[CONTACT EMAIL TBD] **[MAILING ADDRESS TBD]**

2.8 Changes to this policy

Material changes to this policy (changes that expand what is collected, how it is stored, or who can see it) will be accompanied by an in-app notice on the next app launch after the change is deployed, and the revised policy will be dated at the top.

---

3. Draft notes for OMEN review

This section is not part of the policy text — it is drafting commentary for the OMEN review pass and will be removed before the policy is wired into the app.

1. **Legal entity name is TBD.** The current company/trading-name structure for the shipped app is not yet decided. Every `[OPERATING ENTITY TBD]` placeholder collapses to one name once that decision is made.
2. **Jurisdiction is TBD.** The policy lists "[JURISDICTION TBD]" for the home-box location. This is OMEN-008 §6 material and needs to match the physical reality of where the operator's PostgreSQL/PostGIS box actually lives.
3. **Contact email and mailing address are TBD.** These should route to an operator address that can receive privacy inquiries.
4. **The honest-acknowledgment sections (2.4.2, 2.4.5) are written in plain English by design.** OMEN-008 §5 and §4 specifically required honest disclosure of the consent asymmetry and the cross-stream identity limitation, rather than papering them over in legal language. If OMEN review asks for softer wording, the directive reference should be cited so the softening is an explicit deviation from OMEN-008 rather than an accidental drift.
5. **Retention table matches OMEN-008 §7** exactly for the three Salem tiers. WWWatcher/security-system retention is referenced indirectly (2.4.5 talks about promotion to the security system but doesn't claim to set that system's retention policy, because OMEN-008 §7 gives WWWatcher indefinite retention independent of this policy).
6. **The policy does not mention "RadioIntelligence" by product name.** Per OMEN-008 the back-end product name is internal; the user-facing disclosure talks about "the operator's separate security system" and "aggregate heatmap and density analytics." If OMEN prefers explicit product naming in

the user-facing text, that's a one-word change in sections 2.4.5 and 2.4.7.

7. **No in-app toggle for opt-out.** Per OMEN-008 §1, consent is install-time only and the collection is not surfaced in active app UI. Section 2.5 honors this by saying "decline by not installing." If OMEN wants a kill-switch toggle added, that is a change to OMEN-008 §1 and should be issued as an amendment, not taken in the Privacy Policy alone.
8. **Coverage of the nine OMEN-008 constitutional decisions in this draft:**
    - §1 ingress model → 2.4.1, 2.5 (install-time consent, no stationary sensors mentioned because they aren't part of the Salem stream)
    - §2 hashed-default ceiling → 2.4.3
    - §3 criminal-exception escalation → 2.4.6
    - §4 consenting proxy → 2.4.2
    - §5 cross-stream identity space → 2.4.5 (the honest-limitation paragraph)
    - §6 data sovereignty → 2.4.3 (hardware), 2.4.8 (jurisdiction)
    - §7 retention tiers → 2.4.4
    - §8 layered disclosure → the document structure itself (section 1 = install-screen blurb, section 2 = linked full policy)
    - §9 real-time pipeline → 2.4.5 ("within seconds of upload")
9. **Things deliberately NOT promised:** the policy does not promise a specific hash algorithm, a specific salt-rotation cadence, a specific p95 latency figure, or specific audit-log review cadence. Those are internal engineering commitments that live in the RadioIntelligence architecture doc and can change without a user-facing policy rev. Naming them in the user-facing policy would bake engineering choices into a legal document.
10. **This draft is written before any collection code exists.** The EULA gate in OMEN-008 §8 means the policy exists before the feature — that's the correct sequencing. When the Salem radio-environment collection code is eventually written, it must match what this document promises; any divergence is a bug in the code, not a problem with the policy.

Next step: surface this file path (`docs/PRIVACY-POLICY.md`) in the Session 114 OMEN report and request OMEN review against OMEN-008 §8. No collection code to be written until OMEN signs off.